

Processo : 109.009-4/23

Origem : SEC EST DEFESA CIVIL

Setor :

Natureza : RELATÓRIO DE AUDITORIA GOVERNAMENTAL - AUDITORIA DE CONFORMIDADE - ORDINARIA

Interessado : SEC EST DEFESA CIVIL

Observação : Verificar os aspectos das políticas de Governança e Gestão de TI enquanto norteadores das contratações de Tecnologia da Informação do Executivo Estadual no âmbito do SETIC, analisando, de forma subsidiária, a regularidade das contratações enquanto reflexo de tais políticas para identificar suas causas e propor medidas para mitigá-las.

RELATÓRIO DE AUDITORIA GOVERNAMENTAL

DADOS DA FISCALIZAÇÃO

Número da fiscalização: 62/2023

Modalidade: AUDITORIA DE CONFORMIDADE

Forma de autorização: ORDINÁRIA

Ato originário: Processo TCE-RJ nº 302.804-7/22

Jurisdicionado: AGENERSA - AG REG ENERGIA SANEAMENTO; AGERIO - AGENCIA ESTADUAL DE FOMENTO; AGETRANSP - AGENCIA REG SERV PUB TRANSP; CASERJ - CIA CENTRAL ARMAZENS E SILOS RJ; CEASA - CENTRAIS ABASTECIMENTO EST RJ; CECIERJ - FUNDAÇÃO CENTRO CIÊNCIAS EDUC; CEHAB - CIA ESTADUAL DE HABITACAO RJ; CENTRAL - CIA EST ENG TRANSP LOGÍSTICA; CEPERJ - FUND EST EST PESQ FORM SERV PUBLI; CGE - CONTROLADORIA GERAL DO ESTADO DO RJ; CODERTE - CIA DESENV RODOV TERMINAIS ERJ; CODIN - COMPANHIA DESENV INDUSTRIAL RJ; DEGASE - DEPART GERAL ACÕES SOCIO-EDUCATIV; DER/RJ - FUND DEPART ESTRADAS DE RODAGEM; DETRAN - DEPARTAMENTO DE TRÂNSITO; DETRO - DEP. DE TRANSPORTES RODOVIARIOS RJ; EMATER - EMP ASSIST TECN E EXT RURAL RJ; EMOP - EMPRESA DE OBRAS PUBLICAS DO ERJ; FAETEC - FUNDACAO APOIO ESCOLA TECNICA; FAPERJ - FUNDAÇÃO CARLOS CHAGAS FILHO; FIA - FUNDO PARA INFANCIA E ADOLESCENCIA; FIPERJ - FUND INSTIT PESCA DO ESTADO RJ; FLXIII - FUNDACAO LEAO XIII; FMIS - FUNDAÇÃO MUSEU DA IMAGEM E DO SOM; FS - FUNDAÇÃO SAÚDE ERJ; FSC - FUNDACAO SANTA CABRINI; FTMRJ - FUNDACAO TEATRO MUNICIPAL; FUNARJ - FUNDAC ANITA MANTUANO DE ARTES RJ; GSI - GABINETE DE SEGURANÇA INSTITUCIONAL; GVG - VICE-GOVERNADORIA DO ESTADO DO RJ; IASERJ - INSTIT ASSIST DOS SERVIDORES RJ; IEEA - INST EST ENGENHARIA E

ARQUITETURA; INEA - INSTITUTO ESTADUAL DO AMBIENTE; IO - IMPRENSA OFICIAL DO EST RJ; IPER/RJ - INST PESOS MEDIDAS RJ; IRM - INSTITUTO RIO METROPOLE; ISP - INST SEGURANCA PUBLICA; ITERJ - INST TERRAS E CARTOGRAFIA DO RJ; IVB - INSTITUTO VITAL BRAZIL; JUCERJA - JUNTA COMERCIAL DO ESTADO RJ; LOTERJ - LOTERIA DO ESTADO DO RJ; PESAGRO - EMP PESQUISAS AGROPECUARIAS RJ; PGE - PROCURADORIA-GERAL DO ESTADO; PROCON - AUT PROTECAO DEF CONSUMIDOR ERJ; PRODERJ - CENTRO TECN DA INF E COMUNI RJ; RIOPREVIDENCIA - FUNDO DE PREV DO EST RJ; RIOTRILHOS - COMPANHIA TRANSP TRILHOS RJ; RJPREV - FUNDAÇÃO PREVID COMPLEMENTAR; SEAP - SEC EST ADMINISTRACAO PENITENCIARIA; SEAS - SEC EST AMBIENTE E SUSTENTABILIDADE; SEAPPA - SEC EST AGRICULTURA E PECUÁRIA; SECC - SEC EST DA CASA CIVIL; SECEC - SEC EST CULTURA E ECONOMIA CRIATIVA; SECTI - SEC EST CIENCIA, TECNOLOGIA, INOVAÇÃO; SEDEC - SEC EST DEFESA CIVIL; SEDSODH - SEC EST DESENV SOCIAL E DIREITOS HUMANOS; SEEDUC - SEC EST EDUCACAO; SEELJE - SEC EST ESPORTE, LAZER, JUVENTUDE; SEFAZ - SEC EST FAZENDA; SEGOV - SEC EST GOVERNO; SEIC - SEC EST INFRAESTRUTURA E CIDADES; SEPLAG - SEC EST PLANEJAMENTO E GESTÃO; SEPM - SEC EST POLICIA MILITAR; SEPOL - SEC EST POLICIA CIVIL; SERGB - SEC EXTRAORDINARIA REP GOV BRASILIA; SES - SEC EST SAÚDE; SETD - SEC EST TRANSFORMACAO DIGITAL; SETRAB - SEC EST TRABALHO E RENDA; SETRANS - SEC EST TRANSPORTES; SETUR - SEC EST TURISMO; SUDERJ - SUPERINT DESPORTOS ESTADO RJ; TURISRIO - CIA TURISMO DO ESTADO RJ; UENF - UNIV EST NORTE FLUMINENSE; UERJ - FUND UNIVERSIDADE DO ESTADO RJ

Objetivo da fiscalização: Verificar os aspectos das políticas de Governança e Gestão de TI enquanto norteadores das contratações de Tecnologia da Informação do Executivo Estadual no âmbito do SETIC, analisando, de forma subsidiária, a regularidade das contratações enquanto reflexo de tais políticas para identificar suas causas e propor medidas para mitigá-las.

Ofícios de apresentação: AUD/SGE/GAP nº 2659/23, de 14/08/2023 SEC EST DEFESA CIVIL, AUD/SGE/GAP nº 2660/23, de 14/08/2023 SEC EST CIENCIA, TECNOLOGIA, INOVAÇÃO, AUD/SGE/GAP nº 2661/23, de 14/08/2023 SEC EST CULTURA E ECONOMIA CRIATIVA, AUD/SGE/GAP nº 2662/23, de 14/08/2023 SEC EST DA CASA CIVIL, AUD/SGE/GAP nº 2663/23, de 14/08/2023 SEC EST AGRICULTURA E PECUÁRIA, AUD/SGE/GAP nº 2665/23, de 14/08/2023 SEC EST AMBIENTE E SUSTENTABILIDADE, AUD/SGE/GAP nº 2666/23, de 14/08/2023 SEC EST ADMINISTRACAO PENITENCIARIA, AUD/SGE/GAP nº 2667/23, de 14/08/2023 RJ PREV - FUNDAÇÃO PREVID COMPLEMENTAR, AUD/SGE/GAP nº 2668/23, de 14/08/2023 RIOTRILHOS - COMPANHIA TRANSP TRILHOS RJ, AUD/SGE/GAP nº 2669/23, de 14/08/2023 RIOPREVIDENCIA - FUNDO DE PREV DO EST RJ, AUD/SGE/GAP nº 2670/23, de 14/08/2023 PRODERJ - CENTRO TECN DA INF E COMUNI RJ, AUD/SGE/GAP nº 2671/23, de 14/08/2023 PROCON-AUT PROTECAO DEF CONSUMIDOR ERJ, AUD/SGE/GAP nº 2672/23, de 14/08/2023 PGE - PROCURADORIA-GERAL DO ESTADO, AUD/SGE/GAP nº 2673/23, de 14/08/2023 PESAGRO-EMP PESQUISAS AGROPECUARIAS RJ, AUD/SGE/GAP nº 2674/23, de

14/08/2023 SEC EST DESENV SOCIAL E DIREITOS HUMANOS, AUD/SGE/GAP nº 2675/23, de 14/08/2023 SEC EST EDUCACAO, AUD/SGE/GAP nº 2676/23, de 14/08/2023 SEC EST FAZENDA, AUD/SGE/GAP nº 2677/23, de 14/08/2023 JUCERJA-JUNTA COMERCIAL DO ESTADO RJ, AUD/SGE/GAP nº 2678/23, de 14/08/2023 SEC EST TRANSFORMACAO DIGITAL, AUD/SGE/GAP nº 2679/23, de 14/08/2023 UERJ-FUND UNIVERSIDADE DO ESTADO RJ, AUD/SGE/GAP nº 2681/23, de 14/08/2023 UENF-UNIV EST NORTE FLUMINENSE, AUD/SGE/GAP nº 2682/23, de 14/08/2023 TURISRIO - CIA TURISMO DO ESTADO RJ, AUD/SGE/GAP nº 2683/23, de 14/08/2023 SUDERJ-SUPERINT DESPORTOS ESTADO RJ, AUD/SGE/GAP nº 2684/23, de 14/08/2023 SEC EST TURISMO, AUD/SGE/GAP nº 2685/23, de 14/08/2023 SEC EST TRANSPORTES, AUD/SGE/GAP nº 2686/23, de 14/08/2023 SEC EST TRABALHO E RENDA, AUD/SGE/GAP nº 2688/23, de 14/08/2023 SEC EST SAÚDE, AUD/SGE/GAP nº 2689/23, de 14/08/2023 SEC EXTRAORDINARIA REP GOV BRASILIA, AUD/SGE/GAP nº 2691/23, de 14/08/2023 SEC EST POLICIA CIVIL, AUD/SGE/GAP nº 2692/23, de 14/08/2023 SEC EST POLICIA MILITAR, AUD/SGE/GAP nº 2693/23, de 14/08/2023 SEC EST PLANEJAMENTO E GESTÃO, AUD/SGE/GAP nº 2694/23, de 14/08/2023 SEC EST GOVERNO, AUD/SGE/GAP nº 2695/23, de 14/08/2023 SEC EST ESPORTE, LAZER, JUVENTUDE, AUD/SGE/GAP nº 2696/23, de 14/08/2023 IVB-INSTITUTO VITAL BRAZIL, AUD/SGE/GAP nº 2697/23, de 14/08/2023 LOTERJ- LOTERIA DO ESTADO DO RJ, AUD/SGE/GAP nº 2698/23, de 14/08/2023 ISP - INST SEGURANCA PUBLICA, AUD/SGE/GAP nº 2699/23, de 14/08/2023 ITERJ-INST TERRAS E CARTOGRAFIA DO RJ, AUD/SGE/GAP nº 2700/23, de 14/08/2023 DETRAN- DEPARTAMENTO DE TRÂNSITO, AUD/SGE/GAP nº 2701/23, de 14/08/2023 DER/RJ-FUND DEPART ESTRADAS DE RODAGEM, AUD/SGE/GAP nº 2702/23, de 14/08/2023 DEGASE-DEPART GERAL AÇÕES SOCIO-EDUCATIV, AUD/SGE/GAP nº 2703/23, de 14/08/2023 CODIN-COMPANHIA DESENV INDUSTRIAL RJ, AUD/SGE/GAP nº 2704/23, de 14/08/2023 CODERTE-CIA DESENV RODOV TERMINAIS ERJ, AUD/SGE/GAP nº 2705/23, de 14/08/2023 CONTROLADORIA GERAL DO ESTADO DO RJ, AUD/SGE/GAP nº 2706/23, de 14/08/2023 CEPERJ-FUND EST EST PESQ FORM SERV PUBLI, AUD/SGE/GAP nº 2707/23, de 14/08/2023 CENTRAL - CIA EST ENG TRANSP LOGÍSTICA, AUD/SGE/GAP nº 2708/23, de 14/08/2023 CEHAB-CIA ESTADUAL DE HABITACAO RJ, AUD/SGE/GAP nº 2709/23, de 14/08/2023 CECIERJ - FUNDAÇÃO CENTRO CIÊNCIAS EDUC, AUD/SGE/GAP nº 2710/23, de 14/08/2023 CEASA-CENTRAIS ABASTECIMENTO EST RJ, AUD/SGE/GAP nº 2711/23, de 14/08/2023 CASERJ-CIA CENTRAL ARMAZENS E SILOS RJ, AUD/SGE/GAP nº 2712/23, de 14/08/2023 AGETRANSP - AGENCIA REG SERV PUB TRANSP, AUD/SGE/GAP nº 2713/23, de 14/08/2023 AGERIO- AGENCIA ESTADUAL DE FOMENTO, AUD/SGE/GAP nº 2714/23, de 14/08/2023 AGENERSA - AG REG ENERGIA SANEAMENTO, AUD/SGE/GAP nº 2715/23, de 14/08/2023 DRM-DEPARTAMENTO RECURSOS MINERAIS RJ, AUD/SGE/GAP nº 2716/23, de 14/08/2023 EMATER-EMP ASSIST TECN E EXT RURAL RJ, AUD/SGE/GAP nº 2717/23, de 14/08/2023 DETRO-DEP. DE TRANSPORTES RODOVIARIOS RJ, AUD/SGE/GAP nº 2718/23, de 14/08/2023 FAETEC-FUNDACAO APOIO ESCOLA TECNICA, AUD/SGE/GAP nº 2719/23, de 14/08/2023 INSTITUTO RIO METROPOLE, AUD/SGE/GAP nº 2720/23, de

14/08/2023 IPEM-INST PESOS MEDIDAS RJ, AUD/SGE/GAP nº 2721/23, de 14/08/2023 IO-IMPrensa OFICIAL DO EST RJ, AUD/SGE/GAP nº 2722/23, de 14/08/2023 INEA - INSTITUTO ESTADUAL DO AMBIENTE, AUD/SGE/GAP nº 2723/23, de 14/08/2023 EMOP-EMPRESA DE OBRAS PUBLICAS DO ERJ, AUD/SGE/GAP nº 2724/23, de 14/08/2023 IASERJ-INSTIT ASSIST DOS SERVIDORES RJ, AUD/SGE/GAP nº 2725/23, de 14/08/2023 VICE-GOVERNADORIA DO ESTADO DO RJ, AUD/SGE/GAP nº 2726/23, de 14/08/2023 GABINETE DE SEGURANÇA INSTITUCIONAL, AUD/SGE/GAP nº 2727/23, de 14/08/2023 IEEA-INST EST ENGENHARIA E ARQUITETURA, AUD/SGE/GAP nº 2728/23, de 14/08/2023 FTM-FUNDACAO TEATRO MUNICIPAL, AUD/SGE/GAP nº 2729/23, de 14/08/2023 FUNARJ-FUNDAC ANITA MANTUANO DE ARTES RJ, AUD/SGE/GAP nº 2730/23, de 14/08/2023 FIA/RJ -FUNDAÇÃO INFANCIA E ADOLESCENCIA, AUD/SGE/GAP nº 2731/23, de 14/08/2023 FIPERJ-FUND INSTIT PESCA DO ESTADO RJ, AUD/SGE/GAP nº 2732/23, de 14/08/2023 FAPERJ-FUNDAÇÃO CARLOS CHAGAS FILHO, AUD/SGE/GAP nº 2733/23, de 14/08/2023 FMIS - FUNDAÇÃO MUSEU DA IMAGEM E DO SOM, AUD/SGE/GAP nº 2734/23, de 14/08/2023 FS - FUNDAÇÃO SAÚDE ERJ, AUD/SGE/GAP nº 2735/23, de 14/08/2023 FSC-FUNDACAO SANTA CABRINI, AUD/SGE/GAP nº 2736/23, de 14/08/2023 FLXIII-FUNDACAO LEO XIII, AUD/SGE/GAP nº 2755/23, de 14/08/2023 SEC EST INFRAESTRUTURA E CIDADES

Período abrangido: janeiro/21 a dezembro/23

Período de execução: 01/08/23 à 30/11/23

Equipe: Augusto César Benvenuto de Almeida, mat. 02/4823
João Paulo de Freitas Ramirez, mat. 02/4820

Supervisão: Bruno Mattos Souza de Souza Melo, mat. 02/4258

SUMÁRIO

SUMÁRIO	5
LISTA DE ANEXOS	7
LISTA DE SIGLAS	8
LISTA DE ORGANIZAÇÕES	10
1. RESUMO	14
2. VISÃO GERAL DO OBJETO	17
2.1 O Sistema Estadual de Tecnologia de Informação e Comunicação – SETIC	17
2.2 PRODERJ	20
3. VISÃO GERAL DA AUDITORIA	22
3.1. Ato de origem	22
3.2. Objetivo e questões de auditoria	22
3.3. Motivação da auditoria	23
3.4. Metodologia utilizada	24
3.5. Limitações	26
3.6. Benefícios estimados	26
3.7. Antecedentes	27
4. RESULTADOS DA AUDITORIA	28
4.1 Do SETIC	28
Organizações e seus setores de TI	29
4.1.2. Organizações e os normativos do SETIC	30
4.1.3. Organizações e suas percepções do SETIC	32
4.2. Do iGovTI	34
4.2.1. Do índice	34
4.2.2. Da aplicação	36
4.2.3. Dos resultados	37
4.2.3.1. Do quadro geral	37
4.2.3.2. Das práticas de governança de TI	41
4.2.3.3. Das práticas de gestão de TI	44
4.2.4. Do cotejo ao resultado anterior	47
4.3. Dos Achados	50
4.3.1. Achado 01 – Estrutura organizacional do Setor de TI inadequada	50
4.3.2. Achado 02 – Ausência de elaboração ou revisão do PEDTIC	58
4.3.3. Achado 03 – Ausência de Comitê Permanente do PEDTIC	66
4.3.4. Achado 04 – Práticas de gestão de serviço de TI incipientes	73
4.3.5. Achado 05 – Práticas de gestão de segurança da informação incipientes	81
4.3.6. Achado 06 – Gestão de recursos humanos de TI inadequada	93
4.3.7. Achado 07 – Contratações de TI não aderentes com os dispositivos da Instrução Normativa PRODERJ/PRE nº 01/2021	107

4.3.8. Achado 08 – Portais institucionais em produção sem análise de vulnerabilidades pelo Diretor Geral do SETIC	117
4.3.9. Achado 09 - Portais institucionais em produção sem proteção de dados na comunicação com o usuário ..	123
4.3.10. Achado 10 – Atraso na análise e emissão de parecer das solicitações de contratação de TIC dos órgãos do nível setorial do SETIC	128
5. COMENTÁRIOS DO GESTOR	135
5.1. Achado 01 - Estrutura organizacional do Setor de TI inadequada	135
5.2. Achado 02 - Ausência de elaboração ou revisão do PEDTIC	135
5.3. Achado 03 - Ausência de Comitê Permanente do PEDTIC	136
5.4. Achado 04 - Práticas de gestão de serviço de TI incipientes	136
5.5. Achado 05 - Práticas de gestão de segurança da informação incipientes	136
5.6. Achado 06 - Gestão de recursos humanos de TI inadequada	137
5.7. Achado 07 - Contratações de TI não aderentes com os dispositivos da Instrução Normativa PRODERJ/PRE nº 01/2021.....	137
5.8. Achado 08 - Portais institucionais em produção sem análise de vulnerabilidades pelo Diretor Geral do SETIC	138
5.9. Achado 09 - Portais institucionais em produção sem proteção de dados na comunicação com o usuário	138
5.10. Achado 10 - Atraso na análise e emissão de parecer das solicitações de contratação de TIC dos órgãos do nível setorial do SETIC	138
6. ANÁLISE DA EQUIPE	139
7. CONSIDERAÇÕES FINAIS	141
8. PROPOSTA DE ENCAMINHAMENTO	143

LISTA DE ANEXOS

Tabela – ANEXOS	
Documento nº	Descrição
001	Ofícios de Apresentação (arquivo digital “001 - Ofícios de Apresentação.zip”)
002	Matriz de Planejamento (arquivo digital “002 - Matriz de Planejamento.pdf”)
003	Termos de Solicitação de Informações e Documentos (arquivo digital “003 - TSIDs.zip”)
004	Respostas recebidas dos Termos de Solicitação de Informações e Documentos (arquivos digitais “004 – TSIDs – Respostas – Parte 1.zip”, “004 – TSIDs – Respostas – Parte 2.zip”, “004 – TSIDs – Respostas – Parte 3.zip”, “004 – TSIDs – Respostas – Parte 4.zip” e “004 – TSIDs – Respostas – Parte 5.zip”)
005	Matrizes SWOT (arquivo digital “005 – Matrizes SWOT.zip”)
006	Matriz de Achados (arquivo digital “006 – Matriz de Achados.pdf”)
007	Questionário de Governança e Gestão de TI aplicado aos jurisdicionados e seus artefatos (arquivo digital “007 – Questionário de Governança e Gestão de TI.zip”)
008	Respostas submetidas ao Questionário de Governança e Gestão de TI (arquivos digitais “008-Questionário de Governança e Gestão de TI - Respostas - Parte 1.zip” e “008-Questionário de Governança e Gestão de TI - Respostas - Parte 2.zip”)
009	Questionário para etapa de Comentários do Gestor e suas respostas (arquivo digital “009 – Questionário de Comentários do Gestor.zip”)
010	Diagnóstico do SETIC e a percepção dos gestores de TI das organizações do nível setorial (arquivo digital “010 – Análise do SETIC.pdf”)
011	Avaliação da adoção das práticas de governança e gestão de TI no âmbito do SETIC (arquivo digital “011 – Análise do iGovTI.pdf”)
012	Evidências Complementares (arquivo digital “012 – Evidências Complementares – Parte 1.zip” e “012 – Evidências Complementares – Parte 2.zip”)
013	Relatórios individuais das organizações do SETIC (arquivo digital “013 – Relatórios individualizados dos jurisdicionados.zip”)

LISTA DE SIGLAS

SIGLA	Descrição
ABNT	Associação Brasileira de Normas Técnicas
COBIT	<i>Control Objectives for Information and Related Technologies</i>
COSO	<i>Committee of Sponsoring Organizations of the Treadway Commission</i>
ERJ	Estado do Rio de Janeiro
HTTPS	<i>Hypertext Transfer Protocol Secure</i>
IEC	<i>International Electrotechnical Commission</i>
iGovTI	Índice de Governança e Gestão de TI
IN	Instrução Normativa
ISACA	<i>Information Systems Audit and Control Association</i>
ISO	<i>International Organization for Standardization</i>
ISSAI	<i>International Standards of Supreme Audit Institutions</i>
ITGI	<i>Information Technology Governance Institute</i>
ITIL	<i>Information Technology Infrastructure Library</i>
LGPD	Lei Geral de Proteção dos Dados
NBR	Norma Técnica Brasileira
NSTIC/RJ	Nível Setorial de Tecnologia da Informação e Comunicação do Estado do Rio de Janeiro
PAC	Plano Anual de Contratação
PAAG	Plano Anual de Auditoria Governamental
PDTI	Plano Diretor de Tecnologia da Informação
PEDTIC	Plano Estratégico e Diretor de Tecnologia da Informação e Comunicação
PLS	Plano de Suprimentos
PSI	Política de Segurança da Informação



SEI	Sistema Eletrônico de Informações
SETIC	Sistema Estadual de Tecnologia da Informação e Comunicação
SGSI	Sistema de Gestão de Segurança da Informação
SSL	<i>Secure Sockets Layer</i>
TCE-RJ	Tribunal de Contas do Estado do Rio de Janeiro
TCU	Tribunal de Contas da União
TIC	Tecnologia da Informação e Comunicação
TSID	Termo de Solicitação de Informações e Documentos

LISTA DE ORGANIZAÇÕES

SIGLA	Nome
AGENERSA	Agência Reguladora de Energia e Saneamento Básico do Estado do Rio de Janeiro
AGERIO	Agência de Fomento do Estado do Rio de Janeiro
AGETRANSP	Agência Reguladora de Serviços Públicos Concedidos de Transportes Aquaviários, Ferroviários, Metroviários e de Rodovias do Estado do Rio de Janeiro
CASERJ	Companhia de Armazéns e Silos do Estado do Rio de Janeiro
CEASA	Centrais de Abastecimento do Estado do Rio de Janeiro
CECIERJ	Centro de Ciências e Educação Superior a Distância do Estado do Rio de Janeiro
CEHAB	Companhia Estadual de Habitação do Rio de Janeiro
CENTRAL	Companhia Estadual de Engenharia de Transportes e Logística
CEPERJ	Fundação Centro Estadual de Estatísticas, Pesquisas e Formação de Servidores Públicos do Rio de Janeiro
CGE	Controladoria Geral do Estado do Rio de Janeiro
CODERTE	Companhia de Desenvolvimento Rodoviário e Terminais do Estado do Rio de Janeiro
CODIN	Companhia de Desenvolvimento Industrial do Estado do Rio de Janeiro
DEGASE	Departamento Geral de Ações Socioeducativas
DER/RJ	Departamento de Estradas de Rodagem do Rio de Janeiro
DETRAN	Departamento de Trânsito do Estado do Rio de Janeiro
DETRO	Departamento de Transportes Rodoviários do Estado do Rio de Janeiro
DRM	Departamento de Recursos Minerais do Estado do Rio de Janeiro
EMATER	Empresa de Assistência Técnica e Extensão Rural do Estado do Rio de Janeiro
EMOP	Empresa de Obras Públicas do Estado do Rio de Janeiro
FAETEC	Fundação de Apoio à Escola Técnica
FAPERJ	Fundação Carlos Chagas Filho de Amparo à Pesquisa do Estado do Rio de Janeiro
FIA/RJ	Fundação para a Infância e Adolescência
FIPERJ	Fundação Instituto de Pesca do Estado do Rio de Janeiro

FLXIII	Fundação Leão XIII
FMIS	Fundação Museu da Imagem e do Som do Rio de Janeiro
FS	Fundação Saúde
FSC	Fundação Santa Cabrini
FTMRJ	Fundação Teatro Municipal do Rio de Janeiro
FUNARJ	Fundação Anita Mantuano de Artes do Estado do Rio de Janeiro
GSI	Gabinete de Segurança Institucional do Governo do Estado do Rio de Janeiro
GVG	Gabinete da Vice-Governadoria
IASERJ	Instituto de Assistência dos Servidores do Estado do Rio de Janeiro
IEEA	Instituto Estadual de Engenharia e Arquitetura
INEA	Instituto Estadual do Ambiente
IO	Imprensa Oficial do Estado do Rio de Janeiro
IPEM/RJ	Instituto de Pesos e Medidas do Estado do Rio de Janeiro
IRM	Instituto Rio Metrôpole
ISP	Instituto de Segurança Pública
ITERJ	Instituto de Terras e Cartografia do Estado do Rio de Janeiro
IVB	Instituto Vital Brazil
JUCERJA	Junta Comercial do Estado do Rio de Janeiro
LOTERRJ	Loteria do Estado do Rio de Janeiro
PESAGRO	Empresa de Pesquisa Agropecuária do Estado do Rio de Janeiro
PGE	Procuradoria Geral do Estado do Rio de Janeiro
PROCON	PROCON
PRODERJ	Centro de Processamento de Dados do Estado do Rio de Janeiro
RIOPREVI	Fundo Único de Previdência Social do Estado do Rio de Janeiro
RIOTRILH	Companhia de Transportes Sobre Trilhos do Estado do Rio de Janeiro

RJPREV	Fundação de Previdência Complementar do Estado do Rio de Janeiro
SEAP	Secretaria de Estado de Administração Penitenciária
SEAPPA	Secretaria da Agricultura, Pecuária, Pesca e Agronegócio
SEAS	Secretaria de Estado do Ambiente e Sustentabilidade
SECC	Secretaria de Estado da Casa Civil
SECEC	Secretaria de Estado de Cultura e Economia Criativa
SECTI	Secretaria de Estado de Ciência, Tecnologia e Inovação
SEDEC	Secretaria de Estado de Defesa Civil
SEDSODH	Secretaria de Estado de Desenvolvimento Social e Direitos Humanos
SEEDUC	Secretaria Estadual de Educação
SEELJE	Secretaria de Esportes e Lazer
SEFAZ	Secretaria de Estado da Fazenda
SEGOV	Secretaria de Estado de Governo
SEIC	Secretaria de Estado de Infraestrutura e Cidades
SEPLAG	Secretaria de Planejamento e Gestão
SEPM	Secretaria de Estado de Polícia Militar
SEPOL	Secretaria Estadual de Polícia Civil
SERGB	Secretaria Extraordinária de Representação do Governo em Brasília
SES	Secretaria de Estado de Saúde
SETD	Secretaria de Estado de Transformação Digital
SETRAB	Secretaria de Estado de Trabalho e Renda
SETRANS	Secretaria de Transportes
SETUR	Secretaria de Estado de Turismo
SUDERJ	Superintendência De Desportos Do Estado Do Rio De Janeiro
TURISRIO	Companhia de Turismo do Estado do Rio de Janeiro



UENF	Universidade Estadual do Norte Fluminense Darcy Ribeiro
UERJ	Universidade do Estado do Rio de Janeiro

1. RESUMO

Trata-se de relatório de auditoria de conformidade com aspectos operacionais realizada nos 75 órgãos integrantes do Sistema Estadual de Tecnologia de Informação e Comunicação – SETIC no período entre 01/08/2023 e 30/11/2023, com o objetivo de verificar os aspectos das políticas de Governança e Gestão de TI enquanto norteadores das contratações de Tecnologia da Informação do Executivo Estadual no âmbito do SETIC, analisando, de forma subsidiária, a regularidade das contratações enquanto reflexo de tais políticas.

Objetivou-se atender aos pressupostos básicos¹ e diretrizes elencadas para o Biênio 2023-2024 da Corte.

O período abrangido para os objetos analisados foi de janeiro de 2021 a dezembro de 2023, data limite dos trabalhos da auditoria, e o volume de recursos fiscalizados alcançou montantes na ordem de R\$1.960.000.000,00.

Durante a fase inicial de planejamento, iniciou-se as atividades de pesquisa sobre a matéria auditada, estudo da legislação pertinente, reuniões com especializadas desta Corte de Contas para identificar os principais atores de sua área de fiscalização e com o Diretor Geral do SETIC para elaboração de matriz SWOT a fim de identificar as forças, fraquezas, ameaças e oportunidades do Sistema.

Na execução das atividades, foram aplicadas as técnicas de análise documental, questionário, exame analítico dos dados e entrevistas, com vistas a responder às questões formuladas na matriz de planejamento.

Para o questionário proposto, adotou-se a metodologia de autoavaliação de controles internos (do inglês *Control Self-Assessment*), na qual os gestores preenchem as respostas que melhor refletem a situação de seus órgãos em relação às práticas adotadas de governança e gestão de TI. Com a coleta do resultado, foi calculado o índice

¹ **Pressupostos Básicos do Biênio 2023-2024:**

2. Fortalecimento dos mecanismos de consensualidade aplicáveis aos processos de controle externo
3. Incremento de eficiência e efetividade na gestão administrativa e no controle externo

Diretrizes:

5. Consolidar o uso de mecanismos de consensualidade, com o objetivo de impulsionar a celeridade e a adequação das ações corretivas, de forma a obter resultados mais benéficos à sociedade.
9. Empreender fiscalizações que promovam, do planejamento à decisão definitiva, soluções que busquem o aperfeiçoamento das práticas de gestão e agreguem valor à administração pública, mitigando as causas, de forma a cessar os efeitos adversos e intensificar os benefícios à sociedade.

iGovTI dos órgãos do nível setorial do SETIC e adicionado ao resultado do iGovTI do PRODERJ, calculado em sede de auditoria passada, Processo TCE-RJ n.º 104.113-4/2022, permitindo mapear o nível de maturidade na adoção das melhores práticas de governança e gestão de TI para todos os órgãos integrantes do Sistema.

Ao longo do trabalho foram encontrados 10 (dez) achados de auditoria que ensejaram determinações e recomendações para o jurisdicionado.

Ao término da fase de execução da auditoria foram submetidos relatórios preliminares aos jurisdicionados a fim de coletar seus comentários quanto aos achados, conclusões e encaminhamentos propostos pela Equipe, concluindo assim o caráter dialógico do trabalho realizado.

A conclusão do processo fiscalizatório aponta, em linhas gerais, para um cenário de baixa adesão dos órgãos setoriais do SETIC aos normativos expedidos pelo PRODERJ, como órgão Diretor Geral do SETIC e um nível incipiente na adoção das boas práticas de governança e gestão de TI.

Da percepção dos gestores de TI das organizações integrantes do nível setorial do SETIC acerca do Sistema, verificou-se que, em geral, a atuação do PRODERJ como Diretor Geral é considerada positiva e satisfatória, ajudando-os a lidar com os problemas de forma mais eficiente e melhorando a governança e gestão de TI em seus órgãos. Contudo, foram apresentadas críticas, principalmente, quanto a sua atuação como integrador de soluções de TIC do ERJ.

Da atuação do PRODERJ verificou-se, apesar de melhorias graduais, falhas no atendimento dos prazos para avaliar as solicitações de contratação de TIC, assim como falhas na segurança dos portais sob sua gestão.

Do resultado da fiscalização foi possível mensurar uma evolução na adoção às boas práticas de governança e gestão de TI por parte dos órgãos do SETIC, uma vez que se verificou uma ampla majoração no índice iGovTI do trabalho² realizado em 2020 para a fiscalização atual.

Entre os benefícios estimados em decorrência da realização da auditoria, destacam-se:

² Levantamento, Processo TCE-RJ nº 105.096-3/2020 que tinha por objetivo verificar aspectos-chaves de governança de TI dos principais entes que fazem uso de tecnologia da informação da esfera estadual, mensurando o indicador de governança de TI (iGovTI) de cada um desses entes.

- Aperfeiçoamento da condução realizada pelo PRODERJ da governança, da gestão, do planejamento, da definição de estratégias, da normatização e da supervisão do SETIC e das ações relacionadas;
- Melhoria no papel do PRODERJ de integrador de soluções de TIC no âmbito estadual quando da elaboração e comunicação das atas de registro de preço;
- Melhoria no papel do PRODERJ de agente fornecedor de serviços e infraestrutura em geral;
- Aprimoramento das práticas de contratação de bens e serviços de TIC conduzidas pelas organizações que compõem o SETIC;
- Aprimoramento da estrutura organizacional das assessorias de informática (setor de TI) das organizações integrantes do nível setorial do SETIC;
- Disseminação e indução das boas práticas de governança e gestão de TI às organizações integrantes do nível setorial do SETIC, como planejamento de TI, gestão de serviços de TI, gestão de segurança da informação, gestão de recursos humanos de TI e contratações de TI;
- Contribuição para o aprimoramento do planejamento e da organização das políticas voltadas à evolução tecnológica, inovação e transformação digital dos serviços prestados à população do Estado;
- Diagnóstico das práticas de governança e gestão de TI que são adotadas pelas organizações do Poder Executivo do ERJ e a percepção de seus gestores de TI quanto a avaliação do SETIC;
- Subsídios para o aperfeiçoamento do controle por parte do TCE-RJ.

Com base nos achados de auditoria, foram efetuadas propostas de encaminhamento ao Plenário desta Corte, tendo sido sugeridas determinações e recomendações às organizações integrantes do SETIC.

As informações veiculadas neste relatório possuem como usuários, além do Ministério Público de Contas, o Corpo Deliberativo deste TCE-RJ, os dirigentes máximos dos jurisdicionados, os responsáveis pelo controle interno dos órgãos e entidades auditadas e a sociedade em geral.

2. VISÃO GERAL DO OBJETO

2.1 O Sistema Estadual de Tecnologia de Informação e Comunicação – SETIC

O Sistema Estadual de Tecnologia de Informação e Comunicação – SETIC tem seu início estabelecido no Decreto Estadual nº 26.995 de 18 de agosto de 2000, quando foi instituído o extinto Sistema Estadual de Tecnologia da Informação – SETI e seu órgão colegiado, normativo e fiscalizador, o Conselho Estadual de Tecnologia da Informação – CONSETI.

O sistema foi criado com objetivo de estabelecer uma política estadual para gestão, controle, divulgação e integração dos sistemas de informação no âmbito estadual, de forma que o CONSETI seria o responsável por editar normas e políticas de tecnologia da informação, supervisionar e orientar os órgãos e entidades quanto a aspectos de informática, e induzir a discussão para estabelecimento de políticas e estratégias de tecnologia da informação.

A estrutura em formato de sistema decorre do art. 30 do Decreto-Lei nº 200/1967 que prevê essa organização nas atividades auxiliares que são comuns aos órgãos da Administração Pública e que necessitem de coordenação central.

Após diversas alterações³ ao modelo de governança e gestão de TIC, foi editado o Decreto Estadual nº 46.665/2019 que reestrutura o modelo em voga e institui o atual Sistema Estadual de Tecnologia da Informação e Comunicação – SETIC, estruturando-o em 3 camadas: a Subsecretaria de Tecnologia da Informação e Comunicação - SUBTIC da Secretaria de Estado da Casa Civil e Governança, como Direção Geral do sistema; o PRODERJ, como nível central do sistema; e as assessorias de informática, ou setores equivalentes, de todos os órgãos da administração direta e indireta do estado do Rio de Janeiro, como nível setorial.

Por fim, em setembro de 2020, foi editado o Decreto Estadual nº 47.278/2020 que define o atual modelo de gestão e governança de TIC no âmbito do Estado do Rio de

³ Decreto Estadual nº 32.716/2003 que instituiu o modelo de gestão de TI no Estado do Rio de Janeiro, dispondo das atribuições e competências dos atores do SETI;

Decreto Estadual nº 40.709/2007 que altera as atribuições e competências dispostas aos atores do SETI;

Decreto Estadual nº 46.584/2019 que remove as atribuições e competências do CONSETI e as atribui à Subsecretaria de Tecnologia e Comunicação da Secretaria de Estado da Casa Civil e Governança;

Janeiro. O normativo consolida as camadas anteriores de Direção Geral e Órgão Central numa única camada sob a competência do PRODERJ, como órgão Diretor.

Desta forma, atualmente o Sistema Estadual de Tecnologia da Informação e Comunicação - SETIC é composto pelo conjunto de recursos humanos, tecnológicos e de equipamentos voltados para o estabelecimento e a implementação de políticas para a informação e a comunicação pública, organizando-se em dois níveis: Direção Geral, sob competência do PRODERJ; e nível setorial, representado pelas assessorias de informática, ou setores equivalentes, de todos os órgãos da administração direta e indireta do estado do Rio de Janeiro.

O novo modelo do SETIC atribuiu ao PRODERJ competências relevantes, como a coordenação e supervisão do Sistema, a normatização de aspectos⁴ de TIC, a elaboração e disponibilização de atas de registro de preço para contratação de bens e serviços de TIC, e a avaliação e consolidação dos planos de TI dos órgãos do nível setorial do sistema.

Em relação a sua composição, o SETIC é formado por 74 organizações do nível setorial, coordenadas pelo PRODERJ como órgão Diretor Geral. Em conjunto, as organizações do sistema contrataram⁵, desde o ano de 2021, aproximadamente R\$1.96B em bens e serviços de TI.

Nesse contexto, destaca-se a concentração que há nos gastos de TI das organizações do Sistema, uma vez que as 10 maiores unidades contratantes de TI alcançam mais de 80% de todas as contratações de TI relacionadas por todo o SETIC, segue:

Organização	Montante em contratos	Proporção do montante em relação ao total de contratações do SETIC
SEEDUC	R\$ 412.14M	20.99%
PRODERJ	R\$ 366.21M	18.65%
SEFAZ	R\$ 239.49M	12.19%
DETRAN	R\$ 127.61M	6.50%
SES	R\$ 118.25M	6.02%

⁴ Segurança da informação, contratações de TI, treinamento e qualificação de recursos humanos de TI, padronização, integração de soluções, entre outros, conforme disposto no inciso XVIII do art. 5º do Decreto Estadual nº 47.278/2020.

⁵ Segundo resposta ao item 08 do TSID02 em que se solicitou às organizações os processos de contratação de soluções de TIC realizados a partir de 2021.

SEPOL	R\$ 78.11M	3.97%
FS	R\$ 72.31M	3.68%
SEPM	R\$ 65.86M	3.36%
UERJ	R\$ 64.71M	3.30%
FAETEC	R\$ 55.40M	2.82%
Soma dos 10 maiores	R\$ 1.6B	81,49%

Tabela 1 - Organizações que mais contrataram objetos de TIC

No que tange a recursos humanos, as organizações integrantes do SETIC somam⁶ 1340 profissionais de tecnologia da informação compostos por 724 servidores efetivos, 441 servidores comissionados e 175 profissionais terceirizados.

Vínculo	Quantidade	Proporção
Servidores efetivos	724	54,03%
Servidores comissionados	441	32,91%
Profissionais terceirizados	175	13,06%

Tabela 2 - Distribuição de profissionais de TI do SETIC

Considerando uma visão integrada de governo, que deve ser visto como um pelos cidadãos, o Sistema pode ser avaliado como uma organização de TI de grande porte que despende bilhões de reais em contratos administrativos e que presta serviços para a Administração Pública.

Sob essa ótica, verifica-se a importância de haver uma coordenação que avalie as necessidades das partes interessadas do sistema, alinhe e direcione as estratégias e objetivos a serem alcançados pelos participantes e monitore o cumprimento das estratégias, objetivos e normas dispostos pelo coordenador.

Buscando avaliar as necessidades das partes interessadas, o Diretor Geral examina e consolida os Planos Estratégicos e Diretores de Tecnologia da Informação e Comunicação – PEDTIC das organizações, conforme inciso XIX do art. 5º do Decreto Estadual nº 47.278/2020, e recebe as solicitações de contratação de objetos de TIC, de acordo com o art. 7º do mesmo normativo e art. 4º da Instrução Normativa PRODERJ/PRE nº 01/2021.

⁶ Segundo resposta ao item 03 do TSID02 em que se solicitou a relação de profissionais de TI da organização, discriminando seu cargo, vínculo e se desempenha atividades de gestão.

Para direcionar os participantes, foi editada a Política e a Estratégia de Governança de TIC do Estado do Rio de Janeiro, por meio da Portaria PRODERJ/PRE nº 825/2020, além de atos normativos que regulamentam procedimentos de TI, como contratações (IN01), planejamento de TI (Portaria 825) e segurança da informação (IN02)

Por fim, para monitorar o Sistema, o Diretor Geral deve supervisionar o cumprimento dos atos normativos existentes, como disposto no inciso I, art. 5º do Decreto Estadual nº 47.278/2020, e tomar as medidas cabíveis para assegurar seu devido cumprimento, como disposto no art. 3º do Decreto Estadual nº 48.754/2023.

Diante disso, explicita-se a relevância do Diretor Geral do Sistema que precisa ser orientador, ágil e estruturado para conseguir atender eficientemente às competências dispostas no art. 5º do Decreto Estadual nº 47.278/2020.

2.2 PRODERJ

O Centro de Processamento de Dados do Estado do Rio de Janeiro – CPDERJ – teve sua criação decretada por força do Decreto Lei n.º 6.097 de julho de 1968, instrumento que o instituía como uma fundação, atribuindo-lhe autonomia administrativa e financeira. Essa norma conferia à organização o objetivo de executar os serviços de processamento de dados e tratamento de informações dos órgãos da administração direta e indireta do Governo do Estado.

Em junho de 1981, pelo Decreto n.º 4.188, o CPDERJ teve seu regime jurídico transformado de fundação pública para autarquia, vinculando-se à Secretaria de Estado de Fazenda do Estado do Rio de Janeiro, e assim, sob nova denominação, criou-se o Centro de Processamento de Dados do Estado do Rio de Janeiro - PRODERJ.

A Lei n.º 4.480 de dezembro de 2004 modificou o nome e atualizou atribuições do PRODERJ. A norma alterou a nomenclatura para a atual PRODERJ – Centro de Tecnologia de Informação e Comunicação do Estado do Rio de Janeiro, e atribuiu ao órgão as competências para propor as diretrizes e orientações técnicas acerca da Política de Tecnologia de Informação e Comunicação, além de atuar como agente central na oferta de todos os serviços e infraestrutura de TI necessários à administração do Estado.

Essa lei já impõe à autarquia o papel de órgão central de TI e a responsabilidade de normatizar e padronizar como a Administração Pública Estadual deverá atuar no âmbito da Tecnologia da Informação.

Em 17 de setembro de 2020, o Decreto n.º 47.278 alterou a estrutura do Poder Executivo do Estado do Rio de Janeiro, extinguindo os órgãos da Subsecretaria de Tecnologia da Informação, Comunicação e Governo Digital - SUBTIC, da Subsecretaria de Modernização e Informação, bem como seus setores, e do Laboratório de Aceleração da Eficiência Pública - LAEP, da estrutura da Secretaria de Estado da Casa Civil – SECC, transferindo as suas atribuições e competências para o PRODERJ, especialmente a de estabelecer a política de Tecnologia da Informação e Comunicação do Governo do Estado do Rio de Janeiro e exercer o papel de Direção Geral do Sistema Estadual de Tecnologia da Informação e Comunicação - SETIC. O Decreto n.º 47.278 também criou, na estrutura organizacional do PRODERJ, a Vice-Presidência de Estratégia, Governança e Inovação e a Vice-Presidência de Governo Digital, bem como seus desdobramentos estruturais.

Em maio de 2022, foi publicado o Decreto n.º 48.091, aprovando o regimento interno do PRODERJ e definindo sua estrutura organizacional, os setores que a integram, as competências das respectivas unidades, as relações de subordinação e as atribuições dos servidores que exercem as funções de direção, chefia, assessoramento e gerência.

3. VISÃO GERAL DA AUDITORIA

A presente Auditoria foi conduzida em conformidade com o Manual de Auditoria Governamental do TCE-RJ, baseado nas Normas Brasileiras de Auditoria Aplicadas ao Setor Público.

3.1. Ato de origem

Processo TCE-RJ nº 302.804-7/2022, que aprovou o Plano Anual de Auditorias Governamentais para o exercício de 2023 desta Corte de Contas.

3.2. Objetivo e questões de auditoria

Este trabalho tem por objetivo verificar os aspectos das políticas de Governança e Gestão de TI enquanto norteadores das contratações de Tecnologia da Informação do Executivo Estadual no âmbito do SETIC, analisando, de forma subsidiária, a regularidade das contratações enquanto reflexo de tais políticas para identificar suas causas e propor medidas para mitigá-las.

A partir do objetivo do trabalho, formularam-se as questões e subquestões de auditoria adiante elencadas:

- i. Os órgãos setoriais do SETIC possuem estruturas organizacionais formalmente estabelecidas para suas assessorias de TI?
- ii. O órgão Diretor Geral do SETIC avalia, direciona e monitora as necessidades de TI das partes interessadas no âmbito do Estado do Rio de Janeiro?
 - a. As necessidades de TI são avaliadas, otimizadas e priorizadas?
 - b. Os recursos de TI (recursos humanos, tecnológicos e de equipamentos) do SETIC são racionalizados no atendimento às necessidades de TI dos órgãos do SETIC?
 - c. Há percepção de geração de valor da TI pelas partes interessadas do SETIC?
- iii. Os órgãos setoriais do SETIC avaliam, direcionam e monitoram as suas necessidades de TI?

- a. Os órgãos setoriais possuem arranjo organizacional para avaliar e priorizar suas necessidades de TI?
- b. As necessidades de TI são avaliadas, otimizadas e priorizadas?
- iv. Os órgãos do SETIC adotam as boas práticas de gestão de serviços de TI?
- v. Os órgãos do SETIC adotam as boas práticas de segurança da informação?
 - a. Os órgãos setoriais estão elaborando sua política e procedimentos de segurança da informação?
- vi. Os órgãos do SETIC possuem os recursos humanos suficientes, necessários e competentes para exercerem o planejamento, gestão, coordenação, supervisão e controle da Tecnologia da Informação?
- vii. Os órgãos setoriais do SETIC adotam os atos, regulamentos e instruções normativas elaboradas pelo Diretor Geral do SETIC?
 - a. Os órgãos setoriais do SETIC estão enviando ao Diretor Geral suas solicitações de contratação de TIC?
 - b. Os portais dos órgãos setoriais sob gestão do PRODERJ estão atendendo aos requisitos dispostos na IN nº 03/22?
 - c. A comunicação da vigência dos normativos é suficiente?
 - d. O Diretor Geral acompanha adequadamente a adoção dos normativos e de boas práticas pelos órgãos setoriais?

3.3. Motivação da auditoria

Esta Auditoria de Conformidade encontra-se prevista no Plano Setorial da Coordenadoria Setorial de Auditoria em Políticas de Tecnologia da Informação (CAS-TI), decorrente do Plano de Auditoria Governamental do TCE-RJ (PAAG), fiscalização n.º 62/2023, aprovada no Processo TCE-RJ n.º 302.804-7/2022.

A escolha do tema considerou a relevância do Sistema Estadual de Tecnologia da Informação e Comunicação (SETIC) como maior contratante de produtos e serviços de TI sob jurisdição desta Corte de Contas, assim como a possibilidade de verificar as práticas de Governança e Gestão de TI adotadas pelas organizações integrantes do Sistema, o que terá o condão de contribuir com a melhoria das políticas públicas concernentes à TIC no âmbito estadual.

Importante ressaltar, também, o complemento das ações realizadas na Auditoria de Conformidade (Processo TCE-RJ nº 104.113-4/2022) que teve o PRODERJ como jurisdicionado e que agora terá os demais atores do SETIC, aproveitando-se do conhecimento adquirido em tal auditoria, o que deverá maximizar os resultados desta ação de controle.

3.4. Metodologia utilizada

No início do trabalho, a Equipe de Auditoria realizou levantamentos acerca das melhores práticas e dos normativos existentes e vigentes sobre o tema da fiscalização e promoveu reuniões com as especializadas desta Corte de Contas cujos jurisdicionados tiveram as maiores despesas com objetos de TI, quais sejam: Saúde, Educação e Segurança Pública, com o intuito de identificar os principais atores para cada especializada.

Adotou-se as técnicas de análise documental, elaboração de questionário, exame analítico de dados, elaboração de matrizes SWOT e entrevistas com os gestores de TI dos órgãos jurisdicionados, com vistas a responder às questões formuladas na matriz de planejamento.

Para mensurar as práticas de governança e gestão de TI dos órgãos do nível setorial, foi aplicado o Questionário de Governança de Tecnologia da Informação, já utilizado em trabalhos anteriores desta Corte (Processos TCE-RJ n.º 105.096-3/2020, 104.113-4/2022 e 205.089-9/2023), que mapeia a adoção das boas práticas de governança e gestão de TI por parte das organizações.

Para o Diretor Geral do Sistema, optou-se por não aplicar o Questionário, considerando-se o resultado obtido no trabalho anterior⁷, realizado no segundo semestre de 2022. Assumiu-se que uma diferença entre as coletas seria residual, uma vez que o lapso temporal entre os trabalhos é reduzido.

A partir das respostas ao Questionário calculou-se o índice iGovTI e seus diversos agregadores, possibilitando, assim, mensurar quais práticas estão sendo adotadas, e em que grau, permitindo, assim, a comparabilidade entre as organizações.

⁷ Processo TCE-RJ nº 104.113-4/2022 que tinha por objetivo verificar a regularidade de contratações de Tecnologia da Informação do Centro de Tecnologia de Informação e Comunicação do Estado do Rio de Janeiro (PRODERJ) e a atuação do mesmo enquanto indutor da Governança de TI no estado do Rio de Janeiro.

A ferramenta escolhida para enviar as perguntas aos jurisdicionados e coletar suas respostas foi o *LimeSurvey*, um *software* livre que permite a aplicação de questionários *online* com uma gama de funcionalidades, amplamente adotado pelo Tribunal de Contas do Estado do Rio de Janeiro em suas auditorias.

Para aferir o nível de satisfação dos órgãos do nível setorial quanto à estrutura atual do SETIC, além da seção “1030 - Avaliação do SETIC pelos órgãos setoriais” do Questionário, foram realizadas reuniões com jurisdicionados⁸ integrantes do nível setorial do SETIC com a finalidade de coletar sua percepção acerca do Sistema, mapeando os pontos fracos e fortes em forças, fraquezas, ameaças e oportunidades, materializadas nas Matrizes SWOT.

Para tal, foi selecionada uma amostra estratificada de forma que possuísse organizações tanto da Administração Direta quanto da Indireta, que estivessem cumprindo e descumprindo os normativos expedidos pelo Diretor Geral e considerando, também, o montante de contratações de TIC no período de 2018 a 2023.

Essa amostra permitiu coletar informações de organizações de diferentes estruturas de TI, tamanhos e níveis de maturidade e, assim, consolidar uma visão holística dos órgãos do nível setorial quanto ao SETIC.

Ao final da fase de execução, foram elaborados 74 relatórios preliminares individuais contendo os achados de auditoria, seus critérios, evidências, situações encontradas e propostas de encaminhamento sugeridas pela Equipe. Tais relatórios foram enviados aos jurisdicionados integrantes do nível setorial do SETIC para que, por meio de um segundo questionário na plataforma *LimeSurvey*, participassem da etapa de Comentários do Gestor e fornecessem suas considerações acerca dos apontamentos feitos pela Equipe.

Por fim, para o PRODERJ, realizou-se uma apresentação junto ao jurisdicionado no intuito de expor os achados relativos à sua atuação como Diretor Geral do SETIC. Estes achados foram fornecidos à organização, por meio de relatório preliminar, para coleta formal dos comentários do gestor e posterior análise da Equipe.

⁸ Foram realizadas reuniões com a AGETRANSP, Fundação Saúde (FS), PRODERJ, Secretaria Estadual de Educação (SEEDUC), Secretaria Estadual de Fazenda (SEFAZ) e Secretaria Estadual de Polícia Militar (SEPM)

3.5. Limitações

As limitações estão relacionadas com a metodologia do questionário utilizada nessa auditoria, dado que as informações são obtidas através de questionário eletrônico e, portanto, possuem caráter auto declaratório.

Para endereçar o caráter declaratório das respostas fornecidas, foi solicitado o envio de algumas das evidências que ensejaram seu preenchimento.

Cabe ressaltar a ausência de resposta por parte da Secretaria Estadual de Polícia Civil – SEPOL ao Questionário de Governança e Gestão de TI. Foram feitas diversas comunicações à organização, porém, sem o resultado desejado. Destaque-se que essa omissão constará nos bancos de dados desta especializada e será levada em consideração na seleção de ações de controle futuras.

Ressalta-se que tais limitações não impediram o pleno atingimento do objetivo proposto deste trabalho.

3.6. Benefícios estimados

Entre os benefícios estimados desta fiscalização, para o PRODERJ, como Diretor Geral do Sistema, pode-se elencar a melhoria na condução da governança, gestão, planejamento, normatização e supervisão do SETIC, além do aperfeiçoamento no seu papel de integrador de soluções de TIC no âmbito do Poder Executivo do ERJ, quando da elaboração das atas de registro preço, e no seu papel como agente fornecedor de serviços e infraestrutura em geral.

Para as organizações que compõem o nível setorial do SETIC, estima-se uma melhoria na eficiência do atendimento de suas solicitações de contratação de TIC e na tempestividade do atendimento aos planos de suprimentos (PLS) elaborados pelo PRODERJ.

São esperados aprimoramentos nas estruturas organizacionais de suas assessorias de informática (setor de TI), adequando-as às boas práticas e fornecendo uma estrutura mínima que seja formalizada e posicionada junto à Alta Administração.

Ainda para os órgãos setoriais do SETIC, estimam-se, também, melhorias na adoção das boas práticas de governança e gestão de TI, principalmente as que tratam

de planejamento de TI, gestão de serviços de TI, gestão de segurança da informação, gestão de recursos humanos de TI e contratações de TI.

Por fim, pode-se mencionar o levantamento de subsídios para o aperfeiçoamento do controle dessa especializada pelo diagnóstico realizado das práticas de governança e gestão de TI que são adotadas pelas organizações do Poder Executivo do ERJ e a percepção de seus gestores de TI quanto a avaliação do SETIC.

3.7. Antecedentes

Constatou-se que os temas de gestão e governança no escopo de Tecnologia da Informação outrora foram objeto de recomendações e determinações em trabalhos anteriores desta Corte de Contas, como:

Processo TCE-RJ	Natureza	Observações
105.096-3/2020	Relatório de Auditoria Governamental - Levantamento - Ordinária	Verificar aspectos chaves de governança de TI dos principais entes que fazem uso de tecnologia da informação da esfera estadual, mensurando o indicador de governança de TI (iGovTI) de cada um desses entes.
104.113-4/2022	Relatório de Auditoria Governamental – Auditoria de Conformidade - Ordinária	Verificar a regularidade de contratações de Tecnologia da Informação do Centro de Tecnologia de Informação e Comunicação do Estado do Rio de Janeiro (PRODERJ) e a atuação do mesmo enquanto indutor da Governança de TI no estado do Rio de Janeiro.
205.089-9/2023	Relatório de Auditoria Governamental – Auditoria de Conformidade - Ordinária	Verificar os aspectos das políticas de Governança e Gestão de TI enquanto norteadores das contratações de Tecnologia da Informação no âmbito dos municípios, analisando, de forma subsidiária, a regularidade das contratações enquanto reflexo de tais políticas.

Tabela 3 - Relação de processos fiscalizatórios com o tema de Gestão e Governança de TI

4. RESULTADOS DA AUDITORIA

4.1 Do SETIC

Como já apresentado na Seção 2.1, o Sistema Estadual de Tecnologia da Informação e Comunicação – SETIC, regulamentado pelo Decreto Estadual nº 47.278/2020, configura-se como o conjunto de recursos humanos, tecnológicos e de equipamentos voltados para o estabelecimento e a implementação de políticas para a informação e a comunicação pública, sendo estruturado em dois níveis de atuação: I - Direção Geral, representado pelo PRODERJ; e II – Setorial, representado pelas assessorias de informática, ou setores equivalentes, de todos os órgãos da Administração Direta e Indireta do Estado do Rio de Janeiro, assim chamadas de NSTIC/RJ.

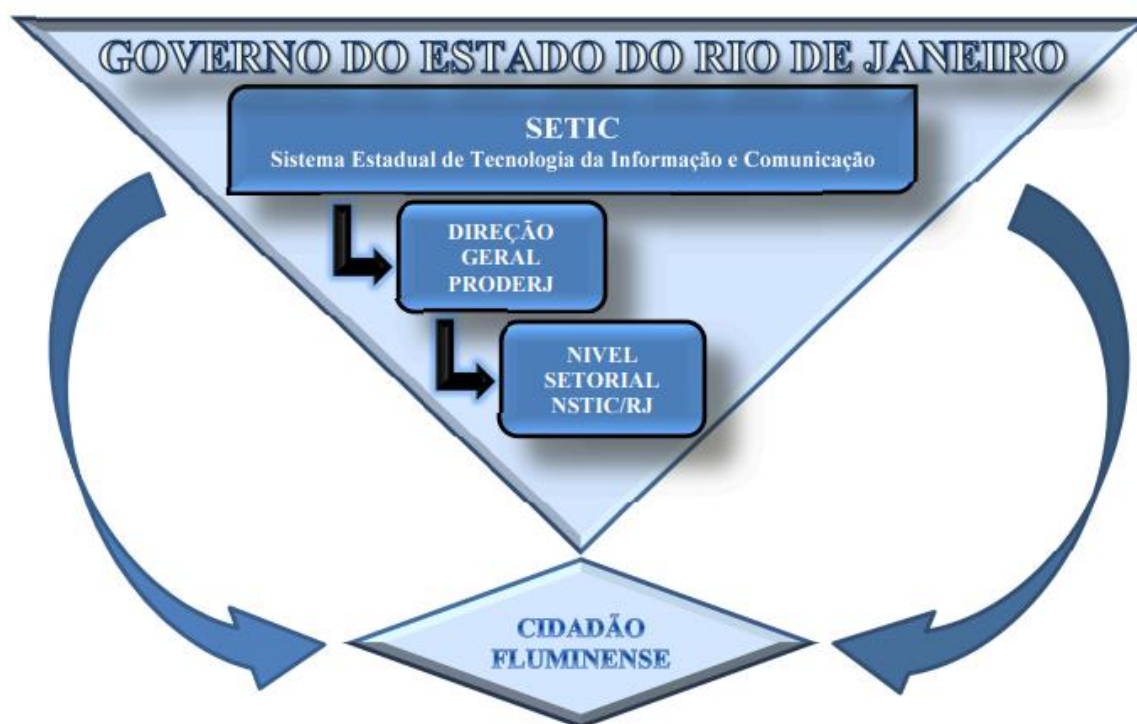


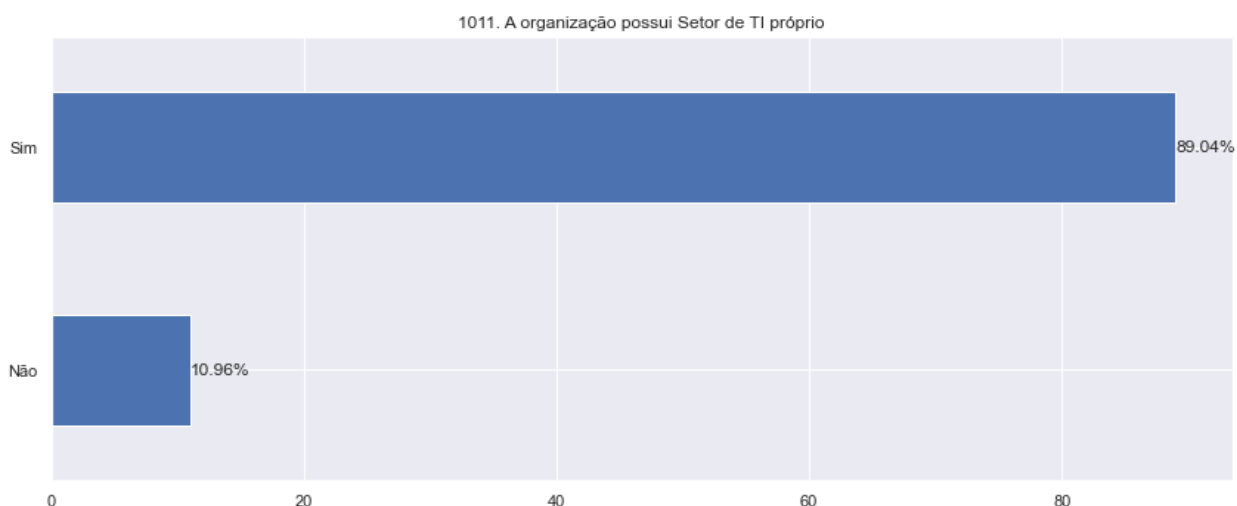
Figura 1- Representação da estrutura do SETIC disposta na Portaria PRODERJ/PRE nº 825/2021

Considerando a estrutura supramencionada, nessa seção será avaliada a percepção dos gestores de TI das organizações que constituem o nível setorial do SETIC, pessoas responsáveis pelas assessorias de informática (setores de TI) das

organizações, podendo, também, ser denominados como os principais responsáveis pelo NSTIC/RJ, nos termos do Art. 4º do Anexo C da Portaria PRODERJ/PRE nº 825/2021, em relação a aspectos do SETIC e da atuação do seu Diretor Geral.

Para avaliar a percepção dos gestores serão utilizados os itens contidos nas seções “1010 Informações do Setor de TI”, “1020 Normativos do SETIC” e “1030 Avaliação do SETIC pelos órgãos setoriais” do Questionário de Governança e Gestão de TI, submetido aos órgãos integrantes do nível setorial do SETIC, por meio do TSID03.

Organizações e seus setores de TI

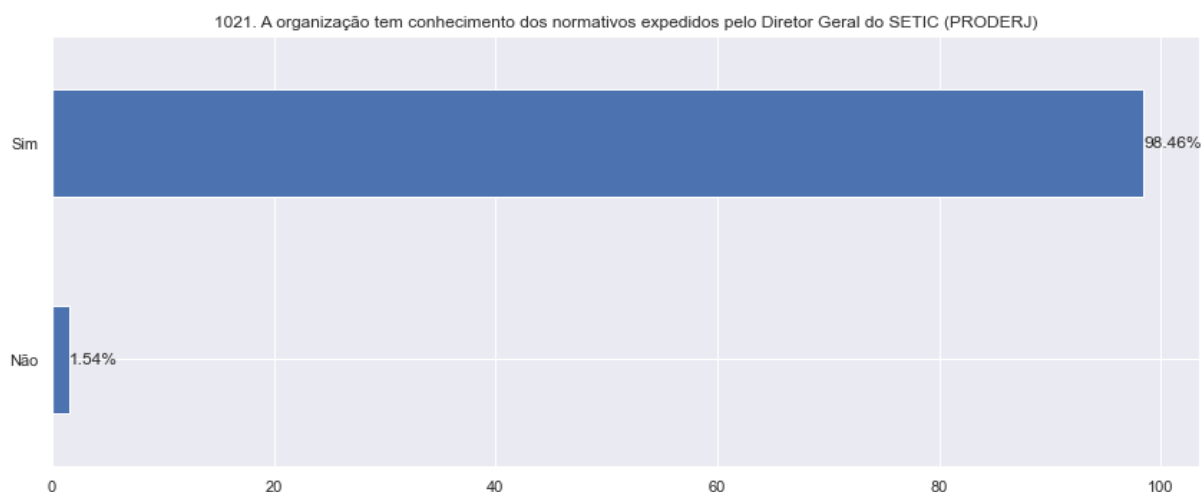


Do item 1011 do Questionário, verificou-se que 65 (89%) das 73 organizações respondentes afirmaram possuir um Setor de TI na sua estrutura. Entre os que informaram negativamente encontram-se a CASERJ, FIPERJ, FTMRJ, GVG, IASERJ, SEAS, SEGOV e TURISRIO.

Como justificativa à inexistência de Setores de TI, em 7 dos 8 casos, informou-se que havia uma organização terceira que dava todo o suporte de TI necessário àquela que não o possuía. Apenas a FIPERJ não declarou como tem suas necessidades de TIC atendidas.

As seções a seguir consideram apenas as respostas dos jurisdicionados que possuem Setor de TI, 65 dos 73 auditados questionados, uma vez que os itens são direcionados especificamente aos responsáveis do Setor.

4.1.2. Organizações e os normativos do SETIC

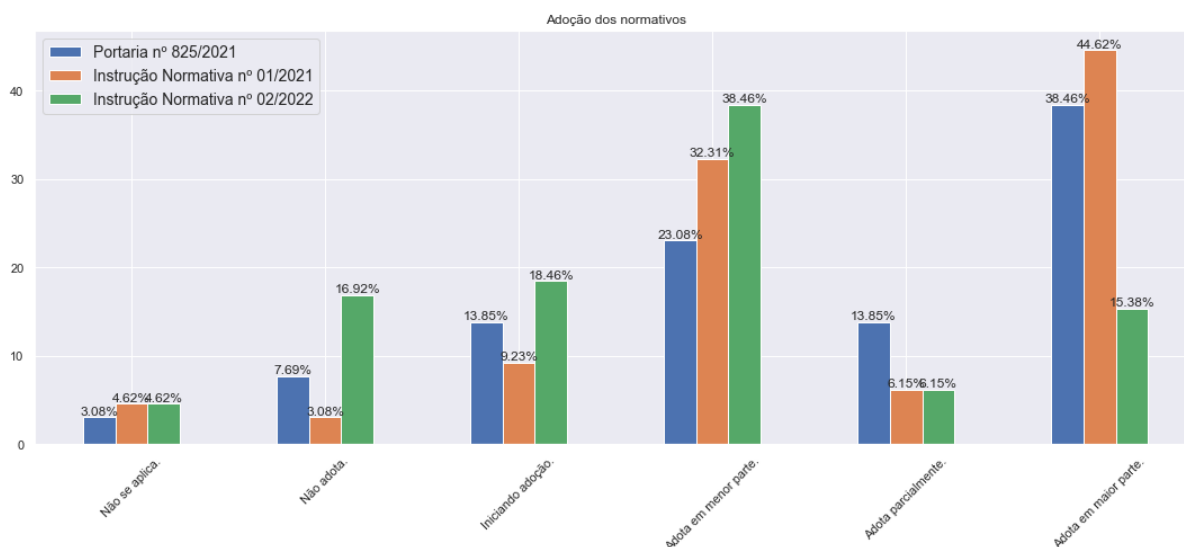


Do item 1021 do Questionário, verificou-se que 64 (98%) das 65 organizações auditadas que possuem Setor de TI afirmaram ter conhecimento dos normativos⁹ expedidos pelo Diretor Geral do SETIC.

Os normativos com maior grau de ciência/conhecimento foram a Portaria PRODERJ/PRE nº 825/2021 e a Instrução Normativa PRODERJ/PRE nº 01/2021, comportamento que pode ser explicado pela maior longevidade dos normativos, uma vez que foram os primeiros a serem editados pelo Diretor Geral.

Quando se analisou acerca do cumprimento desses normativos, observou-se um maior atendimento à IN01 que regulamenta as contratações de TIC, conforme se pode depreender do gráfico a seguir:

⁹ A Portaria PRODERJ/PRE nº 825/2021, Instrução Normativa PRODERJ/PRE nº 01/2021, Instrução Normativa PRODERJ/PRE nº 02/2022 e Instrução Normativa PRODERJ/PRE nº 03/2022



Os normativos em questão tratam de práticas relevantes à área de TIC e que devem ser adotadas pelas organizações, quais sejam: planejamento de TI, contratações e segurança da informação.

Quanto à adoção das práticas de planejamento dispostas na Portaria PRODERJ/PRE nº 825/2021, verificou-se a necessidade de ajustes e da adoção de controles no processo de elaboração dos instrumentos de planejamento das organizações, especialmente no que tange às atividades de monitoramento e controle, como a revisão anual dos PEDTIC e o registro em processo SEI das atas das reuniões do Comitê Permanente do PEDTIC.

Em relação aos dispositivos elencados na IN01/2021, verificou-se a necessidade de ajustes e da adoção de controles no processo de contratação de bens e serviços de TIC das organizações, especialmente no que tange ao planejamento e ao alinhamento estratégico da contratação, como a previsão das contratações nos instrumentos de planejamento como o PEDTIC e o PAC.

Para os dispositivos elencados na IN02/2022, normativo que, entre os supracitados, é o que apresenta pior grau de cumprimento, verificou-se a necessidade de ajustes e adoção de controles no processo de segurança da informação das organizações, especialmente no que tange à elaboração e à aprovação dos procedimentos de segurança da informação, como elaborar e manter procedimentos de segurança da informação em linguagem clara e a aprovação desses procedimentos pela Alta Administração do órgão.

Esses pontos de controle foram verificados na presente fiscalização e se materializaram nos achados descritos na seção 4.3.

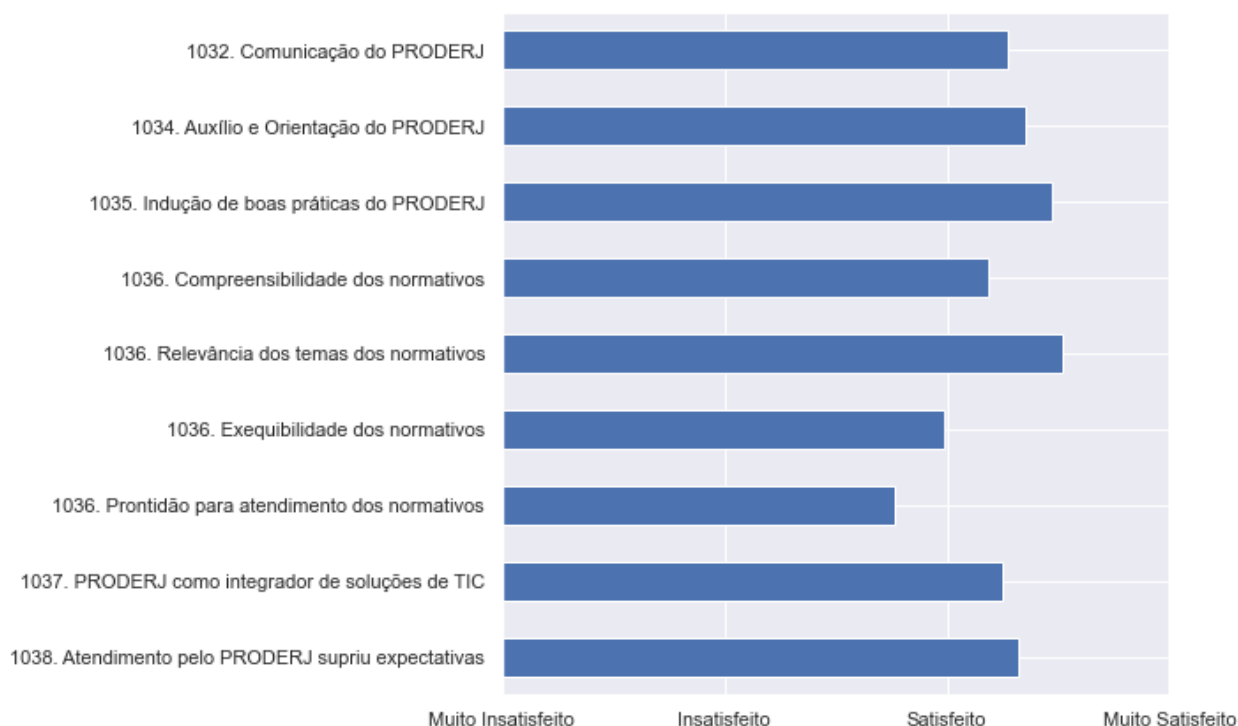
4.1.3. Organizações e suas percepções do SETIC

Para capturar a percepção dos gestores de TI das organizações que integram o nível setorial do SETIC foram criados na seção 1030 do Questionário itens que utilizam a Escala Likert¹⁰ de 4 pontos.

A seção dispõe de questões para mensurar aspectos da atuação do Diretor Geral do SETIC, como: a relevância de suas comunicações; a satisfação dos gestores de TI pelo auxílio e orientação recebidos; a efetividade das boas práticas induzidas; a compreensibilidade, a relevância temática e a exequibilidade das normas editadas; a sua atuação como integrador de soluções de TIC; e a satisfação dos gestores de TI pelo atendimento prestado.

Padronizando as respostas numa mesma escala, observa-se que os aspectos mais bem percebidos pelos gestores relacionam-se com a relevância dos temas dos normativos editados, com as boas práticas induzidas e com o auxílio e orientação, conforme figura a seguir:

¹⁰ Escala Likert é um tipo de escala de resposta psicométrica usada habitualmente em pesquisas de opinião. Ao responderem a um questionário baseado nesta escala, os perguntados especificam seu nível de concordância com uma afirmação.



Dos pontos positivos relatados foram encontrados, entre outros: a diversidade de canais de comunicação, como os grupos de WhatsApp, listas de e-mail, ofícios e a plataforma AtendeRJ; as respostas rápidas; orientações claras e suficientes; as iniciativas de capacitação pelo Academia PRODERJ; o apoio na mudança da cultura organizacional quando da normatização de boas práticas; a orientação na tomada de decisões do gestor de TI pela indução das boas práticas.

Como pontos a melhorar, destacaram-se aspectos relacionados à sua atuação centralizadora de contratações de TI, como integrador de soluções de TIC, quando do planejamento e elaboração das Atas de Registro de Preço:

- Comunicação de PLS intempestiva ou insuficiente: alguns órgãos apontaram falhas na divulgação dos Planos de Suprimento (PLS) elaborados pelo Diretor Geral, não sendo avisados com a antecedência adequada, ausência de comunicação durante elaboração dos itens e objetos das Atas ou comunicação insuficiente acerca dos objetos presentes nas Atas;
- Não há uma consulta do Diretor Geral aos órgãos do nível setorial do SETIC durante a fase de definição do objeto a ser contratado e o planejamento das atas de registro de preço, implicando o não atendimento das necessidades dos órgãos;

- A morosidade no processo de elaboração e contratação, que pode prejudicar a continuidade dos serviços de TIC das organizações.

Outro ponto de melhoria relevante levantado pelas organizações setoriais decorre da necessidade de regulamentação de outros temas, como a definição de uma política de *disaster recovery* e nuvem de governo e a revisão de normas existentes.

Em breve síntese, as avaliações dos gestores de TI indicam que, em geral, a atuação do Diretor Geral junto aos órgãos do nível setorial do SETIC é considerada positiva e satisfatória, tendo ajudado tais gestores a lidar com os problemas de forma mais eficiente e a melhorar a governança e gestão de TIC em seus órgãos.

Ressalte-se que os pontos abordados nessa seção serão registrados no banco de dados desta especializada e serão considerados na seleção de ações de fiscalização vindouras.

Uma avaliação mais detalhada acerca dos pontos levantados pelos gestores de TI encontra-se no Anexo “010 – Análise do SETIC” do relatório, assim como as respostas e opiniões dos gestores de TI encontram-se no Anexo “008 - Questionário de Governança e Gestão de TI - Respostas”.

4.2. Do iGovTI

4.2.1. Do índice

O Índice de Governança e Gestão de TI – iGovTI, configura-se como um indicador que busca mensurar e mapear, de forma geral, a situação de governança e gestão de TI em organizações.

A mensuração do índice é calculada por meio da combinação¹¹ de itens de verificação criados para avaliar a adoção das melhores práticas pelas organizações. Os agregadores relacionados ao índice iGovTI são:

#	Agregador	Significado
1	iGovTI	Índice de Governança e Gestão de TI

¹¹ A memória de cálculo dos itens que compõem o iGovTI constam no Anexo “007 – Questionário de Governança e Gestão de TI”.

#	Agregador	Significado
1.1	GovernançaTI	Índice de Governança de TI
1.1.1	ModeloTI	Capacidade em estabelecer modelo de gestão de TI
1.1.2	MonitorAvaliaTI	Capacidade em monitorar o desempenho da gestão de TI
1.1.3	ResultadoTI	Capacidade em prestar serviços públicos com qualidade
1.2	iGestTI	Índice de Gestão de TI
1.2.1	PlanejamentoTI	Capacidade em realizar planejamento de TI
1.2.2	PessoasTI	Capacidade em gestão de pessoal de TI
1.2.3	ProcessosTI	Capacidade em processos de TI
1.2.3.1	iGestServicosTI	Capacidade em gerir serviços de TI
1.2.3.2	iGestNiveisServicoTI	Capacidade em gerir nível de serviço de TI
1.2.3.3	iGestRiscosTI	Capacidade em gerir riscos de TI
1.2.3.4	iGestSegInfo	Índice de Gestão da Segurança da Informação
1.2.3.4.1	EstruturaSegInfo	Capacidade em definir políticas de responsabilidades para a gestão da TI
1.2.3.4.2	ProcessoSegInfo	Capacidade em estabelecer processos e atividades para a gestão da TI
1.2.3.5	ProcessoSoftware	Capacidade em executar processos de <i>software</i>
1.2.3.6	iGestProjetosTI	Capacidade em gerir projetos de TI
1.2.3.7	iGestContratosTI	Capacidade em Gestão de Contratos de TI

O iGovTI verifica e mensura práticas de Governança de TI, Planejamento de TI, Gestão de Pessoas, Gestão Serviços de TI, Gestão de Riscos, Gestão de Projetos, Gestão de Contratos de TI, Processo de Software e Segurança da Informação.

Os itens de verificação se traduzem em questões. As respostas de cada questão são convertidas em valores numéricos entre 0 e 1, conforme tabela a seguir.

Nota	Respostas
1	- Adota em grande parte ou totalmente - Não se aplica (risco tratado)
0,5	Adota parcialmente
0,15	Adota em menor parte
0,05	Há decisão formal ou plano aprovado para adotá-la
0	- Não adota - Não se aplica (risco tratado)

Nos casos em que se responda que adota parcialmente ou em grande parte, serão descontados uniformemente da nota inicial o valor dos subitens de detalhamento da prática que não forem adotados pela organização.

Nos casos em que a não aplicabilidade do item seja alegada, avalia-se a justificativa apresentada e, caso aceita, o item será considerado como "Adota em grande parte ou totalmente", caso contrário, como "Não adota".

Calculadas as notas finais do índice, seus valores são classificados em quatro níveis de maturidade, conforme tabela a seguir, acerca das práticas de governança e gestão de TI, quais sejam: Inexpressivo, Iniciando, Intermediário e Aprimorado.

Nível de maturidade	Nota final do iGovTI
Aprimorado	De 0.70 até 1.00
Intermediário	De 0.40 até 0.70
Iniciando	De 0.15 até 0.40
Inexpressivo	De 0.00 até 0.15

4.2.2. Da aplicação

Para mensurar a aderência às boas práticas de governança e gestão de TI dos órgãos integrantes do SETIC, foi aplicado o Questionário de Governança e Gestão de Tecnologia da Informação¹² que ensejou o cálculo do índice iGovTI para o ano corrente e consequente cotejo com índice aferido em trabalho prévio¹³ desta Corte.

O presente questionário foi submetido aos órgãos do nível setorial do SETIC por meio do TSID03 e, uma vez finalizado, as respostas submetidas foram consolidadas e analisadas pela Equipe de Auditoria.

Para o Diretor Geral do Sistema, optou-se¹⁴ por não aplicar o Questionário e considerou-se o resultado obtido no trabalho anterior¹⁵ realizado no segundo semestre de 2022.

¹² Questionário presente no Anexo "007 – Questionário de Governança e Gestão de TI".

¹³ Levantamento, Processo TCE-RJ nº 105.096-3/2020 que tinha por objetivo verificar aspectos-chaves de governança de TI dos principais entes que fazem uso de tecnologia da informação da esfera estadual, mensurando o indicador de governança de TI (iGovTI) de cada um desses entes.

¹⁴ Uma vez que o lapso temporal entre os trabalhos é reduzido, assumiu-se que uma diferença entre as coletas seria residual.

¹⁵ Processo TCE-RJ nº 104.113-4/2022 que tinha por objetivo verificar a regularidade de contratações de Tecnologia da Informação do Centro de Tecnologia de Informação e Comunicação do Estado do Rio de Janeiro (PRODERJ) e a atuação do mesmo enquanto indutor da Governança de TI no estado do Rio de Janeiro.

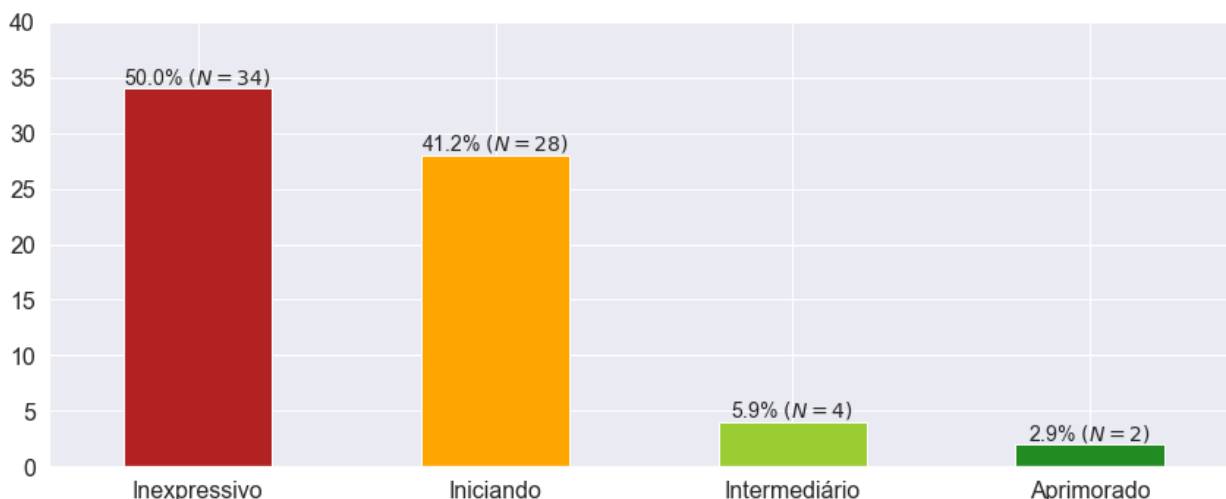
Ressalte-se que, da análise quantitativa e estatística a ser apresentada a seguir, foram desconsideradas seis organizações¹⁶ por declararem pela não aplicabilidade em mais de 25% de suas respostas ao Questionário e não constam as respostas da Secretaria Estadual de Polícia Civil pela ausência de envio no prazo estabelecido de suas respostas.

Dessa forma, serão avaliadas 68 das 75 organizações integrantes do SETIC, o PRODERJ como Diretor Geral e 67 organizações do nível setorial do Sistema.

4.2.3. Dos resultados

4.2.3.1. Do quadro geral

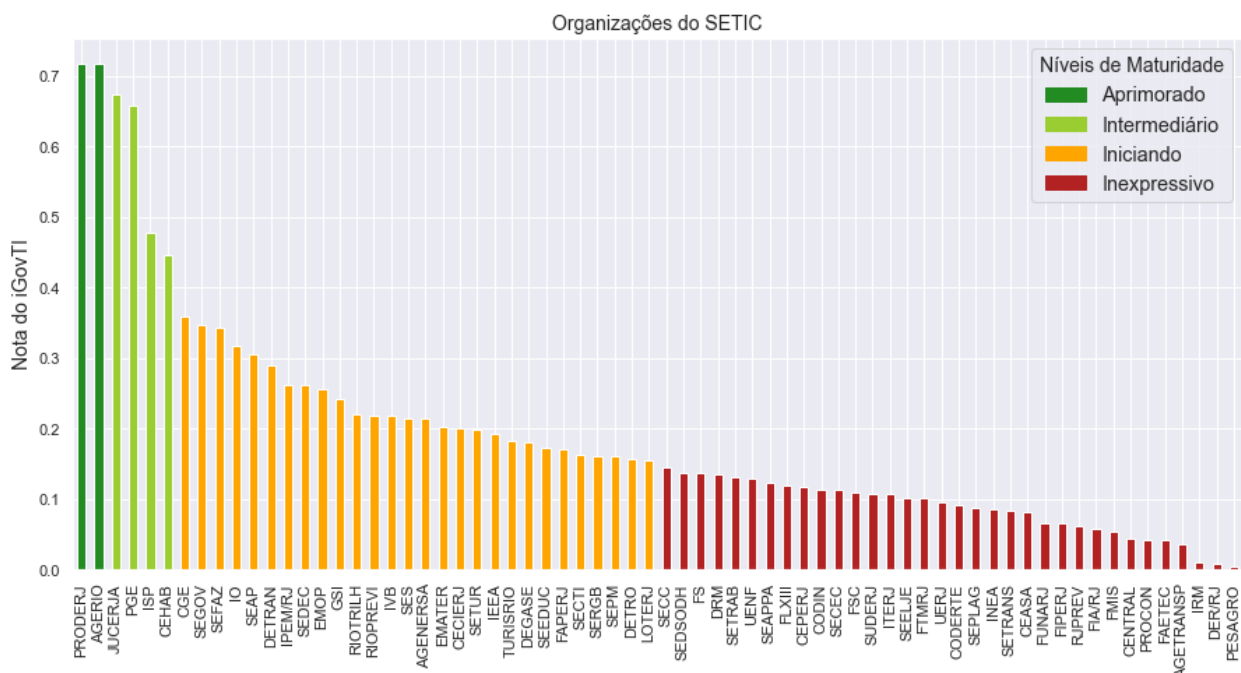
A visão geral do índice iGovTI, considerando as respostas submetidas pelos jurisdicionados, denota um quadro de incipiência generalizada na adoção das boas práticas de governança e gestão de TI pelas organizações do SETIC, bem como apresenta um exíguo conjunto de organizações que atingiram níveis relevantes de maturidade no exercício dessas práticas, segue:



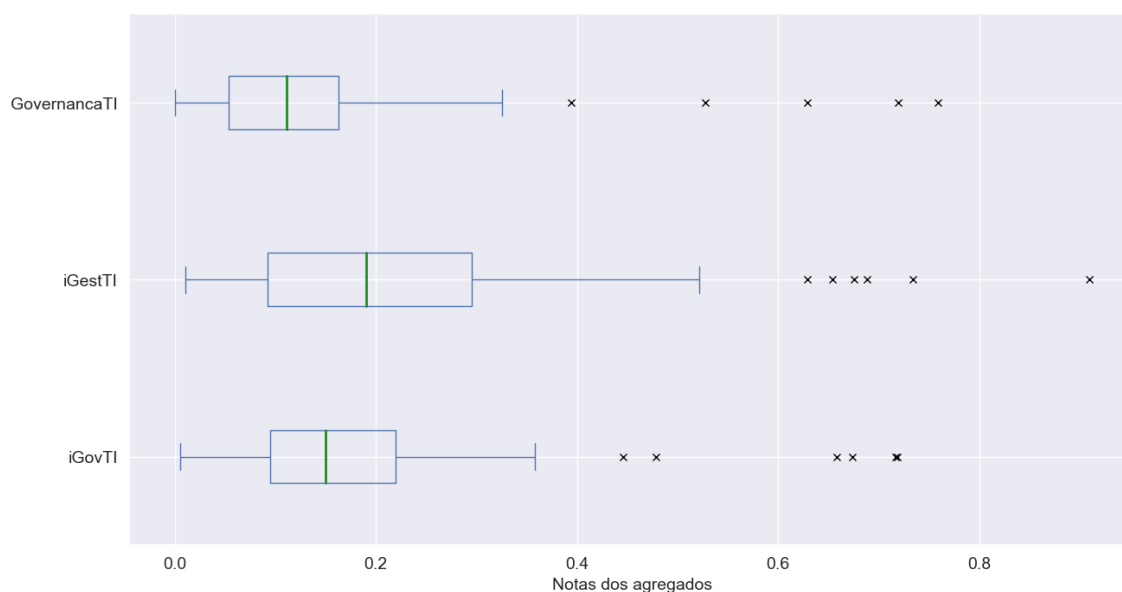
Dos resultados obtidos, observa-se que menos de 10% das organizações integrantes do SETIC atingiram ao menos o nível Intermediário de maturidade na adoção das boas práticas de governança e gestão de TI.

¹⁶ As organizações que responderam com “Não se aplica” em mais de 25% das questões foram o CASERJ, a Vice Governadoria, o IASERJ, a Secretaria Estadual de Infraestrutura e Cidade (SEIC), Secretaria Estadual de Ambiente e Sustentabilidade (SEAS) e Secretaria Estadual de Transformação Digital (SETD).

Segmentando-se os níveis de maturidade das organizações é possível verificar uma disparidade entre os 4 mais bem colocados com os demais, segue:



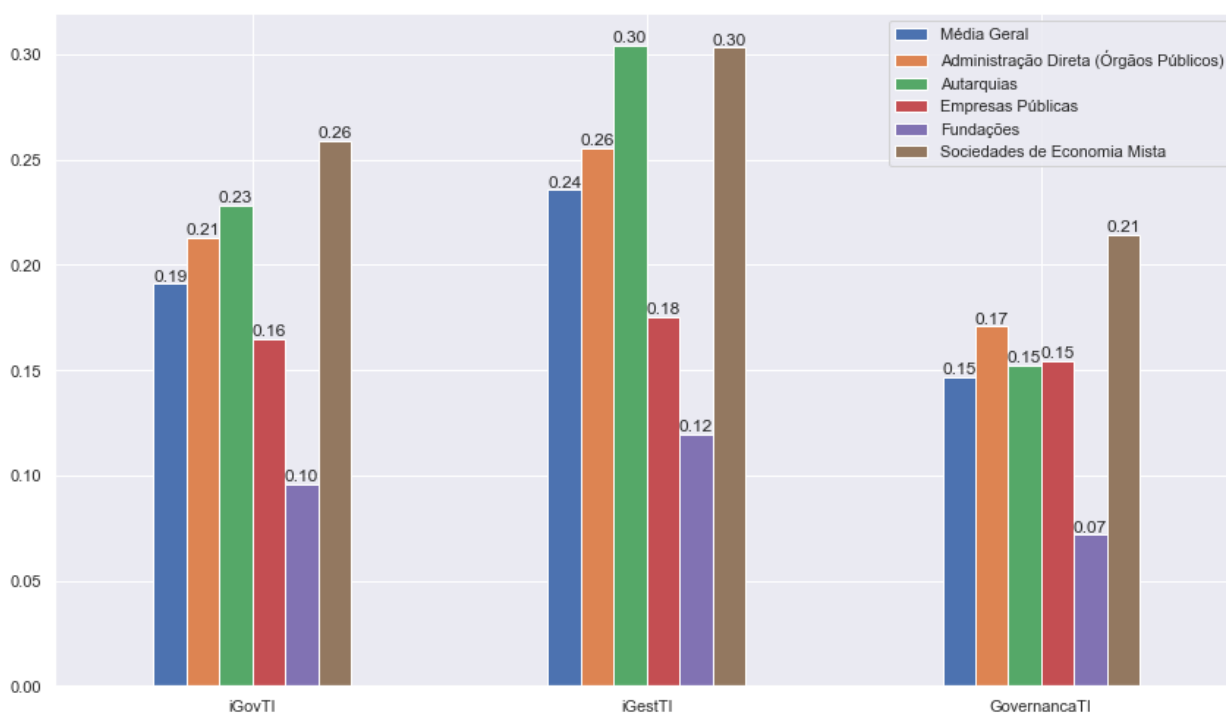
Analisando os componentes que formam o iGovTI, quais sejam o GovernançaTI e o iGestTI, é possível avaliar onde se encontram as maiores deficiências das organizações, ou seja, se ocorrem em maior grau nas práticas de governança ou de gestão de TI.



Da análise do *boxplot* apresentado acima, observa-se, pelas medianas em verde, que as organizações adotam mais práticas de gestão de TI do que governança de TI e

que existem organizações maduras em ambos os componentes do iGovTI, tanto o GovernançaTI quanto o iGestTI.

Agrupando-se as organizações setorialmente por tipo de administração (direta ou indireta) e regime jurídico (órgão público, autarquia, fundação, sociedade de economia mista ou empresa pública), verifica-se que as práticas são mais adotadas, em média, pela Administração Direta em relação à Indireta, porém ao se observar os regimes que compõem a Administração Indireta as Sociedades de Economia Mista (SEM) e as Autarquias destacam-se como maiores níveis de maturidade do iGovTI.



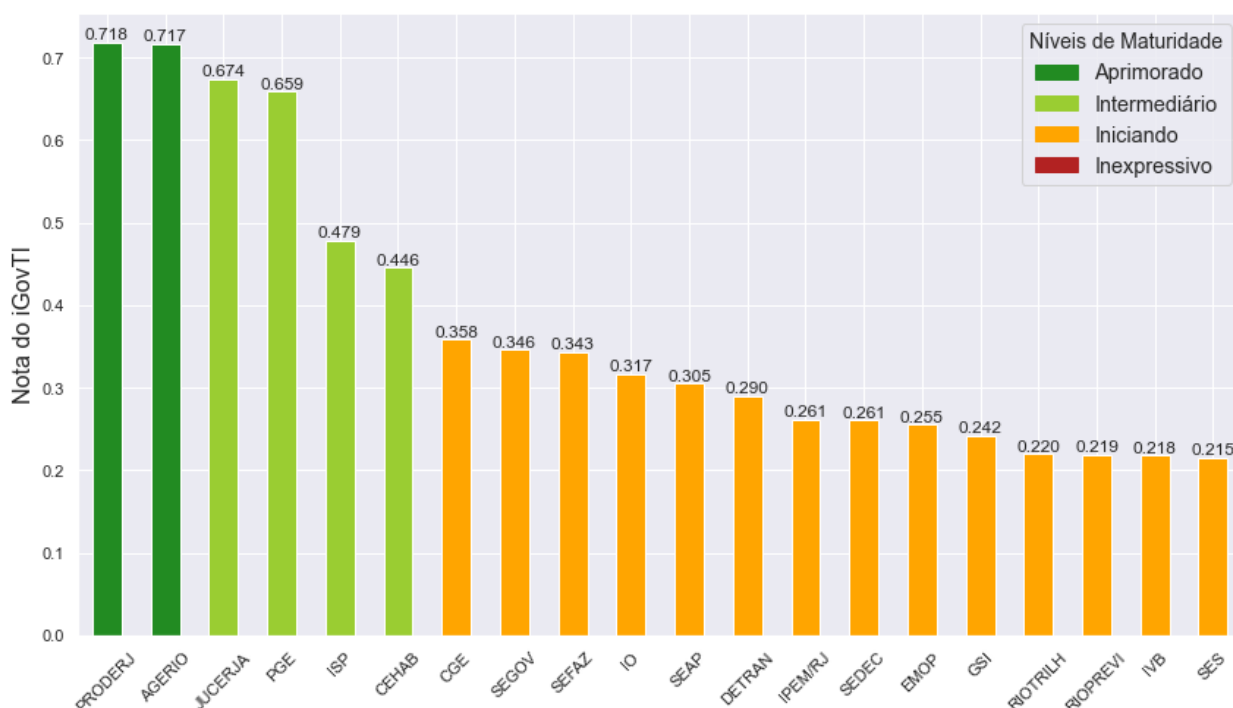
	Média Geral	Administração Direta	Administração Indireta			
		Órgãos públicos	Autarquia	Empresa Pública	Fundação	Sociedade de Economia Mista
GovernançaTI	0.1468	0.1707	0.1524	0.1545	0.0718	0.2145
iGestTI	0.2355	0.2555	0.3044	0.1754	0.1196	0.3032
iGovTI	0.1912	0.2131	0.2284	0.1650	0.0957	0.2589

Da análise setorial acima, observa-se que, em média, as organizações adotam mais práticas de gestão de TI do que governança de TI e verifica-se que as organizações que possuem os maiores níveis de maturidade considerando as práticas de governança

e gestão de TI foram as Sociedades de Economia Mista (SEM), seguidas pelas Autarquias e os Órgãos Públicos da Administração Direta.

Noutro giro, explicita-se que as Empresas Públicas e Fundações possuem níveis de maturidade mais incipientes e necessitam de um esforço maior por parte do Diretor Geral e órgãos de controle para induzi-las na adoção dessas boas práticas de governança e gestão de TI.

Por fim, apresenta-se as vinte organizações mais bem classificadas em relação ao índice iGovTI:



Em breve síntese, quanto ao quadro geral do iGovTI, observa-se um cenário em que 91% das organizações que integram o SETIC adotam incipientemente as práticas de governança e gestão de TI avaliadas pelo indicador, porém existe um seleto e exíguo grupo de organizações que as adotam em maior grau.

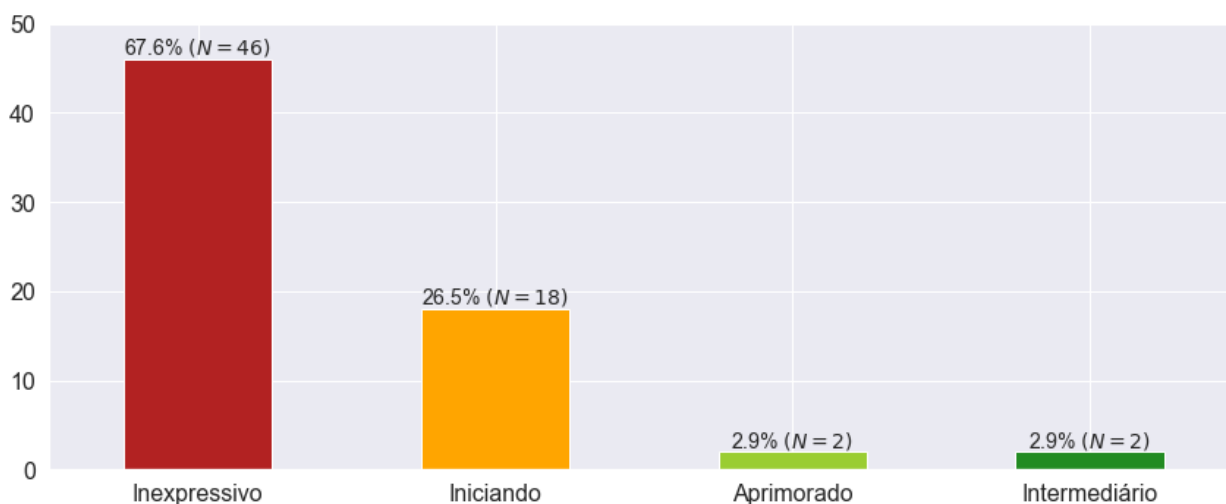
Destaca-se que as organizações adotam mais práticas de gestão de TI do que governança de TI e que o grupo de organizações mais maduras, na média, quanto às práticas combinadas de governança e gestão de TI foram as Sociedades de Economia Mista, seguidas pelas Autarquias e Órgãos Públicos.

Uma vez analisado o índice iGovTI resta avaliar os agregadores que o compõem, o GovernançaTI e o iGestTI, com o intuito de explicitar as principais deficiências das organizações quando da adoção das práticas avaliadas.

4.2.3.2. Das práticas de governança de TI

As práticas¹⁷ de Governança de TI foram analisadas pelo agregador GovernancaTI, composto pelos agregadores ModeloTI, que mede a capacidade da organização em estabelecer um modelo de gestão de TI, MonitorAvaliaTI, que mede a capacidade da organização em monitorar o desempenho da gestão de TI e ResultadoTI, que mede a capacidade em prestar serviços públicos com qualidade, conforme apresentado na seção 4.2.1.

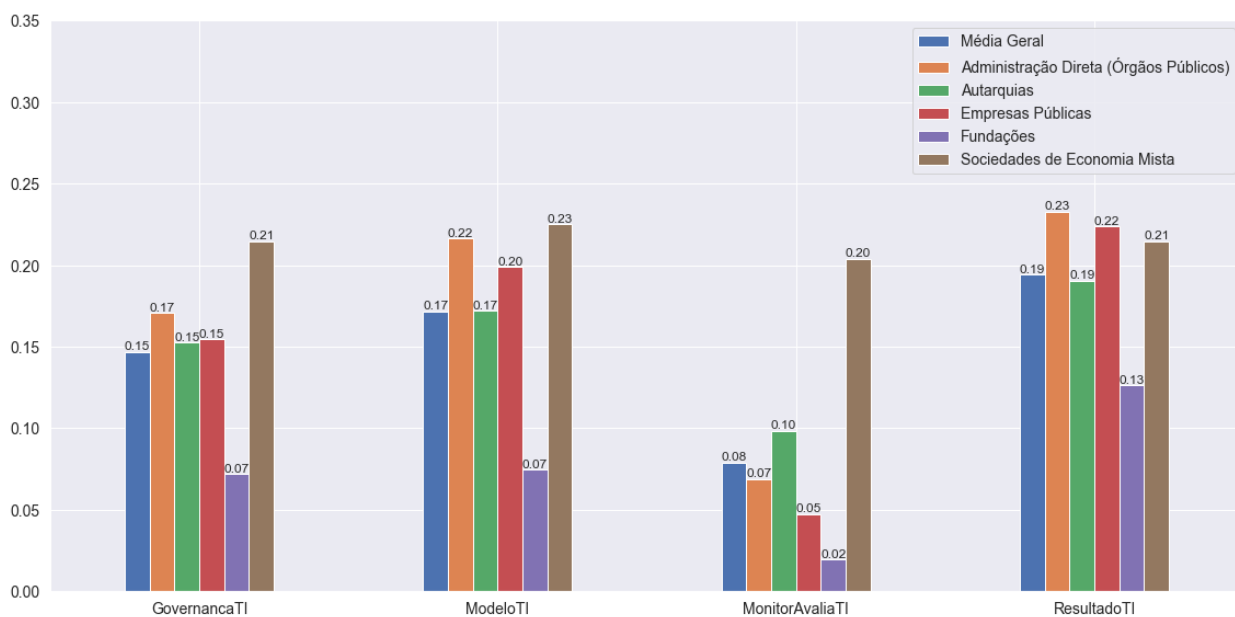
Segue a visão geral dos níveis de capacidade das organizações em relação às práticas de governança de TI verificadas pelo Questionário:



Dos resultados obtidos observa-se um quadro mais incipiente do GovernancaTI do que em relação ao iGovTI, ratificando a informação de que, na média, as organizações adotam mais práticas de gestão do que de governança.

Agrupando-se as organizações setorialmente por tipo de administração e regime jurídico, verifica-se que as práticas de governança de TI são mais adotadas, em média, pelas Sociedades de Economia Mista (SEM).

¹⁷ Os itens de verificação que compõem os agregadores podem ser encontrados no Anexo “007-Questionário de Governança e Gestão de TI” no arquivo Memória de Cálculo.pdf.



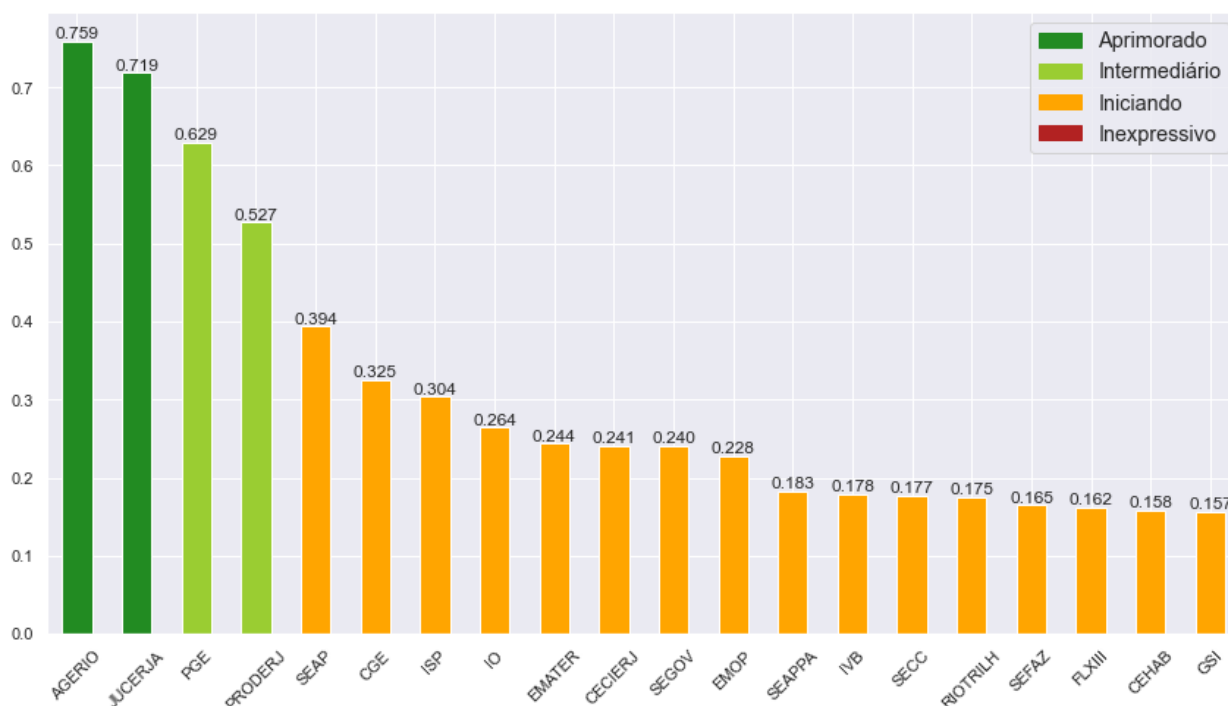
	Média Geral	Administração Direta	Administração Indireta			
		Órgãos públicos	Autarquia	Empresa Pública	Fundação	Sociedade de Economia Mista
ResultadoTI	0.1943	0.2326	0.1904	0.2237	0.1263	0.2146
MonitorAvaliaTI	0.0790	0.0690	0.0985	0.0474	0.0195	0.2040
ModeloTI	0.1717	0.2164	0.1719	0.1989	0.0747	0.2250
GovernancaTI	0.1468	0.1707	0.1524	0.1545	0.0718	0.2145

Da análise das médias setoriais dos componentes do GovernancaTI acima, destaca-se a baixa capacidade, em geral, das organizações em monitorar o desempenho realizado pela sua gestão de TI, medido pelo agregado MonitorAvaliaTI.

Quando não ocorre o devido acompanhamento das estratégias traçadas quando do planejamento realizado, há o risco de não atingimento das metas e objetivos traçados, implicando uma falta de eficácia e efetividade ao planejamento.

Os esforços para se estabelecer um modelo de gestão de TI, medido pelo agregado ModeloTI, devem ser acompanhados por um devido processo de monitoramento do cumprimento das diretrizes, objetivos, indicadores e metas traçados a fim de se alcançar eficácia e promover a melhoria contínua da gestão.

Elencando as organizações que mais adotam as práticas de governança de TI e classificando o nível de capacidade do agregado GovernancaTI, tem-se:



Em breve síntese, quanto ao agregador GovernancaTI, verifica-se que existem poucas organizações maduras a nível de adoção das práticas de governança de TI, apenas a AGERIO e a JUCERJA, e que o nível geral de adoção dessas práticas pelas organizações do SETIC ainda é muito incipiente.

As práticas mais adotadas pelas organizações, na média, estão relacionadas a capacidade da organização em prestar serviços públicos com qualidade (ResultadoTI), enquanto as menos adotadas estão relacionadas com a capacidade da organização em monitorar o desempenho da sua gestão de TI (MonitorAvaliaTI) e com a capacidade da organização estabelecer seu modelo de gestão de TI.

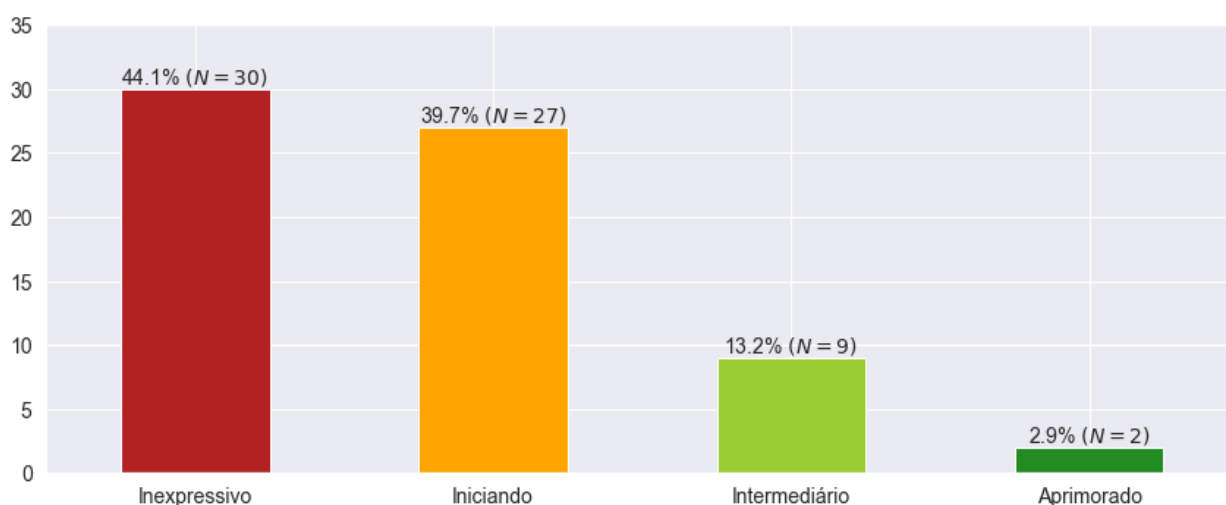
O grupo que mais segue as melhores práticas são, na média, as Sociedades de Economia Mista e os Órgãos Públicos da Administração Direta, respectivamente.

Dessa forma, constata-se um cenário incipiente na adoção das práticas de governança de TI por parte das organizações integrantes do SETIC que enseja acompanhamento e ações de controle para aprimoramento das práticas mais deficientes, como estabelecer um modelo de gestão de TI e monitorar seu desempenho.

4.2.3.3. Das práticas de gestão de TI

As práticas¹⁸ de Gestão de TI foram avaliadas pelo agregador iGestTI, composto pelos agregadores PlanejamentoTI, PessoasTI, iGestServicosTI, iGestNiveisServicoTI, iGestRiscosTI, EstruturaSegInfo, ProcessoSegInfo, ProcessoSoftware, iGestProjetosTI e iGestContratosTI, conforme apresentado na seção 4.2.1.

Segue a visão geral dos níveis de capacidade das organizações em relação às práticas de gestão de TI verificadas pelo Questionário.



Dos resultados obtidos observa-se uma melhoria do quadro apresentado pelos agregadores GovernancaTI e o índice iGovTI, ratificando a informação de que, na média, as organizações adotam mais práticas de gestão do que de governança.

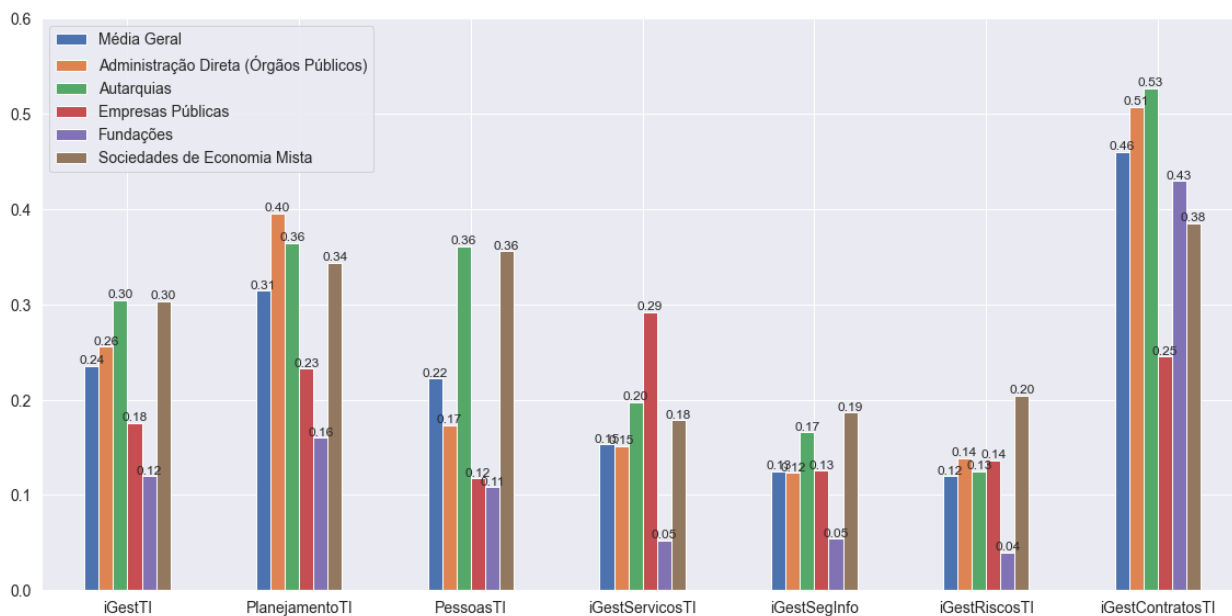
Assim, cerca de 16% das organizações integrantes do SETIC atingiram ao menos o nível Intermediário de capacidade nas práticas de gestão de TI.

Analisando os componentes que formam o iGestTI verificou-se onde se encontram as maiores deficiências das organizações em relação às práticas de gestão de TI, quais sejam, planejamento de TI, gestão de riscos de TI, gestão de serviços de TI, segurança da informação, gestão de pessoas.

Agrupando-se as organizações setorialmente por tipo de administração e regime jurídico, verifica-se que as práticas de gestão de TI são mais adotadas, em média, pelas Autarquias e Sociedades de Economia Mista (SEM), duas entidades da Administração Indireta, e que as práticas mais adotadas são as verificadas pelos agregadores

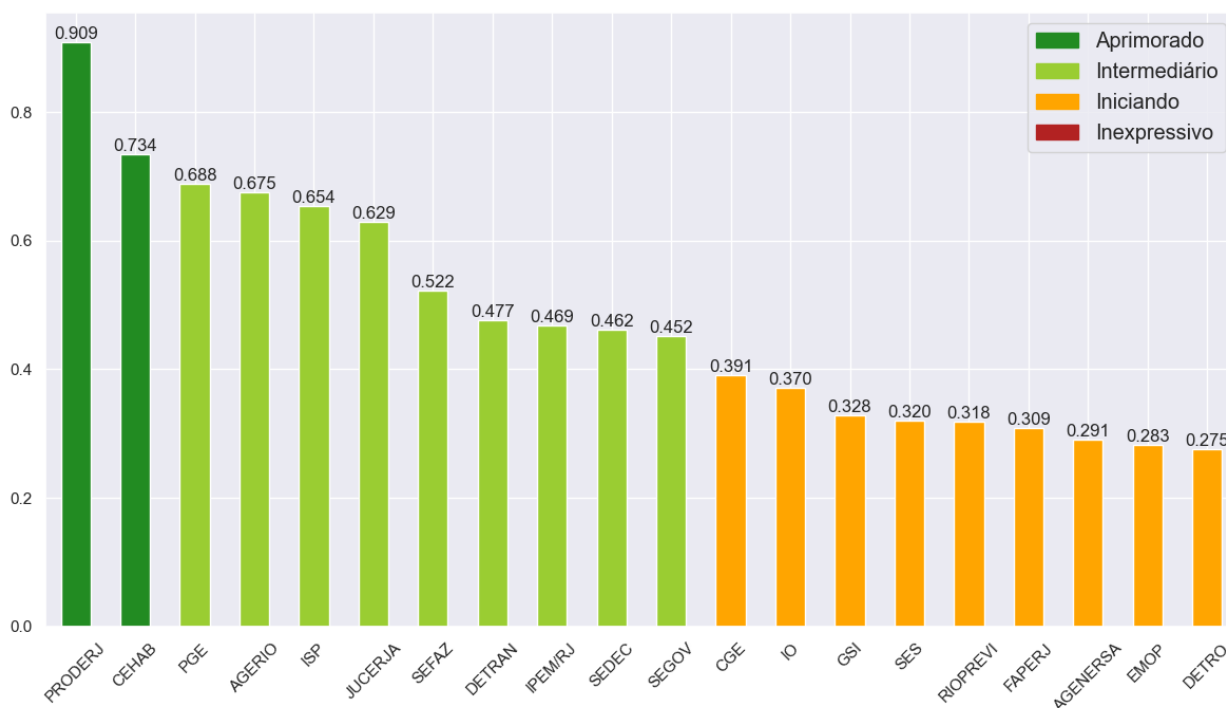
¹⁸ Os itens de verificação que compõem os agregadores podem ser encontrados no Anexo “007-Questionário de Governança e Gestão de TI” no arquivo Memória de Cálculo.pdf.

iGestContratosTI, que avalia a capacidade da organização em gerenciar seus contratos de TI, e PlanejamentoTI, que avalia a capacidade da organização em realizar seu planejamento de TI .



	Média Geral	Administração Direta	Administração Indireta			
		Órgãos públicos	Autarquia	Empresa Pública	Fundação	Sociedade de Economia Mista
iGestContratosTI	0.4601	0.5070	0.5267	0.2451	0.4295	0.3849
iGestRiscosTI	0.1196	0.1389	0.1250	0.1366	0.0396	0.2046
iGestSegInfo	0.1253	0.1232	0.1658	0.1257	0.0542	0.1864
iGestServicosTI	0.1532	0.1515	0.1974	0.2922	0.0525	0.1785
PessoasTI	0.2222	0.1734	0.3608	0.1175	0.1082	0.3557
PlanejamentoTI	0.3145	0.3956	0.3647	0.2325	0.1603	0.3440
iGestTI	0.2355	0.2555	0.3044	0.1754	0.1196	0.3032

Elencando as organizações que mais adotam as práticas de gestão de TI e classificando o nível de capacidade do agregador iGestTI, tem-se:



Em breve síntese, quanto ao agregador iGestTI, verifica-se que existem mais organizações maduras em relação a esse aspecto do que nas práticas de governança, uma vez que cerca de 16% das organizações integrantes do SETIC atingiram ao menos o nível Intermediário de capacidade nas práticas de gestão de TI, porém o nível geral de adoção dessas práticas pelas organizações do SETIC ainda enseja melhorias para atingir níveis necessários de modo que o setor de TI possa entregar valor a suas organizações.

As práticas mais adotadas pelas organizações, na média, estão relacionadas a gestão de contratos de TI (iGestContratosTI) e as atividades de planejamento de TI (PlanejamentoTI), enquanto as menos adotadas estão relacionadas com aspectos de gestão de riscos de TI (iGestRiscosTI) e segurança da informação (iGestSegInfo).

O grupo que mais segue as melhores práticas são, na média, as Autarquias e as Sociedades de Economia Mista, respectivamente.

Dessa forma, constata-se um cenário incipiente de adoção das práticas de gestão de TI por parte das organizações integrantes do SETIC que enseja acompanhamento e ações de controle para aprimoramento dos aspectos mais deficientes como Gestão de Riscos de TI e Segurança da Informação.

Uma avaliação mais detalhada acerca dos resultados do iGovTI encontra-se no Anexo “011 – Análise do iGovTI” do relatório, assim como o Questionário, seus artefatos

e respostas dos gestores de TI encontram-se nos Anexos “007 - Questionário de Governança e Gestão de TI” e “008 - Questionário de Governança e Gestão de TI - Respostas”.

4.2.4. Do cotejo ao resultado anterior

O Processo TCE-RJ nº 105.096-3/2020, relativo à auditoria realizada no segundo semestre de 2020, trata de levantamento cujo objetivo foi de verificar aspectos-chaves de governança de TI dos principais entes que fazem uso de tecnologia da informação da esfera estadual, mensurando o indicador de governança de TI (iGovTI) de cada um desses entes.

Como resultado do levantamento aferiu-se as seguintes notas para o iGovTI e seus componentes GovernançaTI e iGestTI à época:

Órgão	iGovTI	GovernançaTI	iGestTI
AGERIO	0,54	0,58	0,51
PCIVIL	0,53	0,43	0,62
TJRJ	0,51	0,69	0,33
DETRAN	0,44	0,48	0,4
MPRJ	0,41	0,62	0,21
ALERJ	0,39	0,21	0,58
PRODERJ	0,39	0,4	0,38
INEA	0,32	0,24	0,4
CEDAE	0,21	0,09	0,33
SEFAZ	0,21	0,17	0,25
SEPLAG	0,17	0,21	0,13
PMERJ	0,14	0,09	0,19
SEEDUC	0,11	0,09	0,13
SEDEC	0,02	0,03	0,00
SES	0,00	0,00	0,00

Diante disso, será realizada avaliação comparativa para verificar possíveis impactos da ação de fiscalização passada, uma vez que essa resultou em encaminhamentos aos dirigentes máximos das organizações fiscalizadas, nos termos da Decisão Plenária de 16/02/2022, Acórdão TCE-RJ nº 16.435/2022:

I - Pela **COMUNICAÇÃO**, com base no art. 26, § 1º, do Regimento Interno, aos atuais titulares dos órgãos/entidades relacionados a seguir, para ciência do

inteiro teor destes autos e adoção de **RECOMENDAÇÃO** no sentido da adoção das medidas cabíveis, com vistas ao incremento da gestão e da governança de Tecnologia da Informação (TI) no âmbito do Estado do Rio de Janeiro.

(grifo nosso)

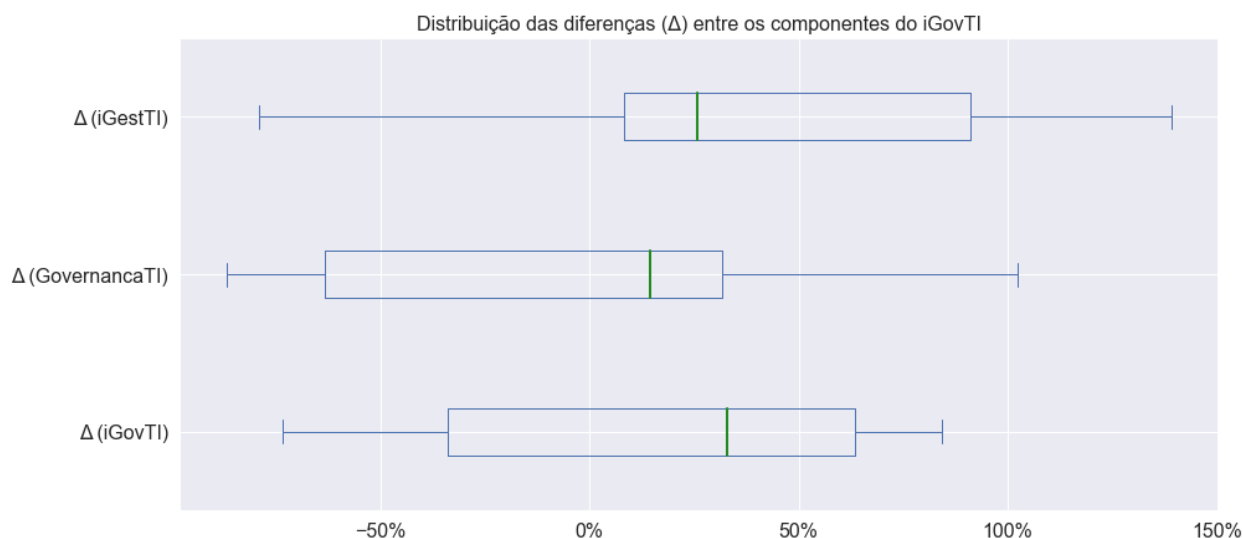
Para realizar o cotejo serão considerados apenas as organizações presentes em ambas as fiscalizações: AGERIO, DETRAN, INEA, PRODERJ, SEDEC, SEEDUC, SEFAZ, SEPLAG, SEPM e SES.

Em relação a nota do iGovTI afere-se uma ampla melhoria na adoção das práticas de governança e gestão de TI por parte das organizações integrantes do SETIC, como observa-se a seguir:

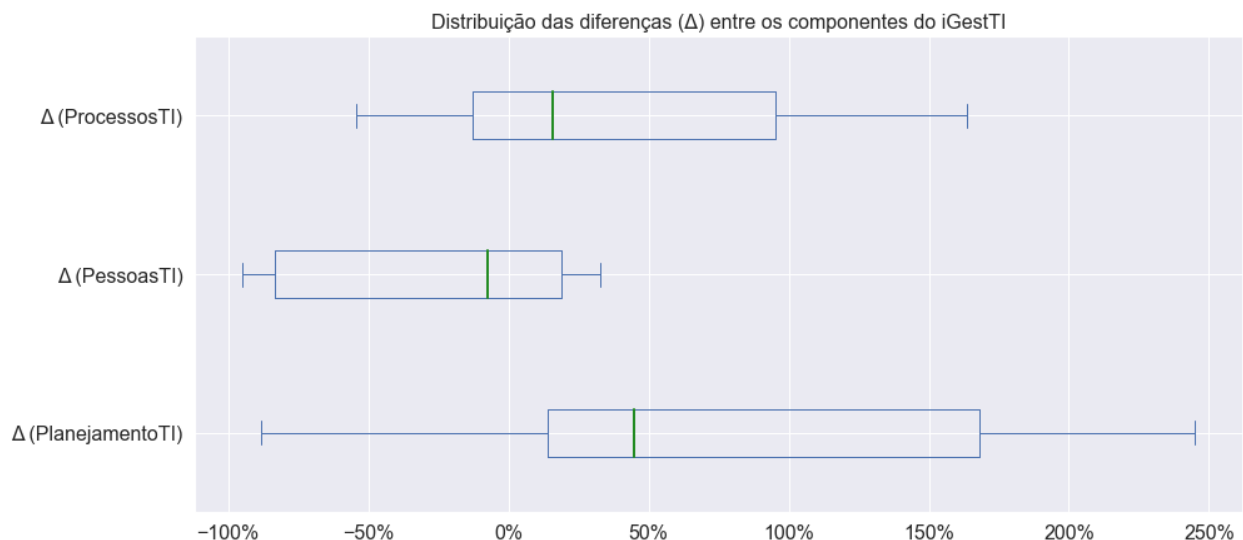
Organização	iGovTI (2020)	Nível de Maturidade (2020)	iGovTI (2023)	Nível de Maturidade (2023)	Δ
AGERIO	0.5400	Intermediário	0.7170	Aprimorado	32.77%
DETRAN	0.4400	Intermediário	0.2901	Iniciando	-34.08%
PRODERJ	0.3900	Iniciando	0.7181	Aprimorado	84.13%
INEA	0.3200	Iniciando	0.0854	Inexpressivo	-73.30%
SEFAZ	0.2100	Iniciando	0.3434	Iniciando	63.51%
SEPLAG	0.1700	Iniciando	0.0876	Inexpressivo	-48.45%
SEPM	0.1400	Inexpressivo	0.1614	Iniciando	15.25%
SEEDUC	0.1100	Inexpressivo	0.1719	Iniciando	56.27%
SEDEC	0.0200	Inexpressivo	0.2611	Iniciando	1205.67%
SES	0.0000	Inexpressivo	0.2153	Iniciando	-

Verifica-se que houve aprimoramentos em 7 (70%) das 10 organizações analisadas, resultando em evolução nos níveis de maturidade em 6 delas.

Decompondo essas diferenças nos seus componentes GovernançaTI e iGestTI constata-se que as melhorias foram, em maior parte, fruto de adoção de práticas de Gestão de TI, como planejamento, gestão de serviços, segurança da informação e gestão de pessoas, segue:



Nessa toada, decompondo o iGestTI pelos seus agregadores PlanejamentoTI, ProcessosTI e PessoasTI, constata-se que as melhorias ao indicador foram, em maior parte, fruto da adoção das práticas de planejamento de tecnologia da informação, segue:



Dessa forma, constata-se que após a ação de fiscalização empreendida por esta Corte de Contas, no Processo TCE-RJ nº 105.096-3/2020, houve um amplo aprimoramento na adoção das boas práticas de governança e gestão de TI medidas pelo índice iGovTI por parte das organizações que integram o SETIC, com destaques para as práticas de planejamento de TI.

4.3. Dos Achados

Todos os achados de auditoria, elencados a seguir, estão evidenciados nas respostas ao questionário eletrônico, exame documental de processos administrativos e respostas aos termos de solicitação de informações e documentos – TSID, encaminhados ao jurisdicionado.

Os encaminhamentos propostos para os achados serão de comunicação com determinação para correção das irregularidades apuradas e recomendação para adoção de boas práticas de governança e gestão de TI.

4.3.1. Achado 01 – Estrutura organizacional do Setor de TI inadequada

4.3.1.1 Critérios

- Constituição Federal de 1988, art. 37, *caput*, princípio da eficiência;
- Decreto-Lei nº 200/1967, art. 10, § 2º;
- Portaria SGD/ME nº 778/2019, art. 4º, § 1º;
- Norma Técnica ABNT NBR ISO/IEC 38.500/2018 - princípio da responsabilidade;
- COBIT 2019, processo APO01 – Estrutura de gestão de TI gerenciada, práticas de gestão APO01.04 – Definir e implementar as estruturas organizacionais, APO01.05 – Estabelecer papéis e responsabilidades, APO01.06 - Aprimorar o posicionamento da função de TI.

4.3.1.2 Evidências

- Análise das respostas aos itens 01 e 02 do TSID02¹⁹, que solicitaram, respectivamente:
 - as informações acerca dos Normativos que estabelecem as atribuições e competências dos setores responsáveis pelo planejamento, gestão, supervisão e controle da Tecnologia da Informação da organização; e
 - a relação dos setores responsáveis pelo planejamento, gestão, supervisão e controle da Tecnologia da Informação da organização;

¹⁹ Presentes no Anexo 004 do relatório

- Respostas "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 1111 do Questionário de Governança e Gestão de TI²⁰, submetido pelo TSID03, para verificar a adoção da prática "a alta administração estabeleceu modelo de gestão de tecnologia da informação" .

4.3.1.3 Situação Encontrada

A definição da estrutura organizacional é fundamental para a definição de responsabilidades, segregação de funções e prestação de contas, sendo indispensável para o estabelecimento de controles internos. Conforme preconiza o COSO²¹, uma estrutura organizacional relevante inclui a definição de áreas fundamentais de autoridade e responsabilidade, bem como a definição de linhas apropriadas de comunicação.

Sobre esse aspecto, a norma técnica ABNT NBR ISO/IEC 38.500/2018 fornece uma estrutura de princípios para os dirigentes usarem na avaliação, no gerenciamento e no monitoramento do uso da tecnologia da informação em suas organizações.

Esta norma estabelece os princípios para o uso eficaz, eficiente e aceitável da tecnologia da informação, assegurando às organizações que os seguem uma melhor avaliação dos riscos do uso da TI e uma exploração mais assertiva das oportunidades advindas de sua utilização.

No que tange aos princípios necessários a uma boa governança de TI, destaca-se o princípio da responsabilidade. Nesta seara, a norma dispõe que (grifou-se): "Indivíduos e grupos dentro da organização compreendem e aceitam suas responsabilidades em relação ao fornecimento de e demanda por TI. Aqueles com responsabilidade por ações também têm autoridade para realizar essas ações".

Recomenda, também, em suas orientações para adoção dos princípios, que "as estruturas de governança avaliem as opções de atribuição das responsabilidades em relação ao uso atual e futuro da TI pela organização", assegurando o uso efetivo, eficiente e aceitável da TI em apoio aos objetivos da organização.

²⁰ Presentes no Anexo 008 do relatório.

²¹ O *Committee of Sponsoring Organizations of the Treadway Commission* - COSO é um framework de gerenciamento de riscos corporativos que auxilia as organizações a identificar, avaliar e responder aos riscos que ameaçam seus objetivos.

A ABNT NBR ISO/IEC 38.500/2018 serve, ainda, como uma bússola para diversos modelos de governança e gestão de informação e tecnologia, como o COBIT.

Em sua versão de 2019, o COBIT define os componentes para construir e sustentar um sistema de governança: processos, estruturas organizacionais, políticas e procedimentos, informação, cultura e comportamentos, habilidades e infraestrutura.

Alinhando-se às diretrizes e aos princípios estabelecidos pela ABNT NBR ISO/IEC 38.500, o processo APO01²² do COBIT 2019 enfatiza a necessidade da definição e da aplicação de um modelo de gestão de TI, definindo processos de gerenciamento, estruturas organizacionais, funções e responsabilidades, atividades confiáveis e replicáveis, itens de informação, políticas e procedimentos, habilidades e competências, cultura e comportamento, serviços, infraestrutura e aplicativos, com vistas ao alinhamento com a estratégia da organização e ao alcance de eficácia, eficiência e economicidade no uso de recursos de TIC, bem como à otimização de riscos.

Dentre as práticas de gestão do processo APO01 pode-se sobrelevar as seguintes:

Estabelecer as estruturas organizacionais internas e ampliadas necessárias (por exemplo, comitês) conforme o projeto do sistema de gestão, possibilitando a tomada de decisões eficaz e eficiente. Garantir que o conhecimento necessário em tecnologia e informação esteja incluído na composição das estruturas de gestão.

(APO01.04²³ – Definir e implementar as estruturas organizacionais);

Definir e comunicar as funções e responsabilidades para a tecnologia da informação empresarial, incluindo níveis de autoridade, responsabilidades e prestação de contas.

(APO01.05²⁴ – Estabelecer funções e responsabilidades);

²² APO01 - Managed I&T Management Framework Purpose: Implement a consistent management approach for enterprise governance requirements to be met, covering governance components such as management processes; organizational structures; roles and responsibilities; reliable and repeatable activities; information items; policies and procedures; skills and competencies; culture and behavior; and services, infrastructure and applications.

²³ APO01.04 - Define and implement the organizational structures: Put in place the required internal and extended organizational structures (e.g., committees) per the management system design, enabling effective and efficient decision making. Ensure that required technology and information knowledge is included in the composition of management structures.

²⁴ APO01.05 - Establish roles and responsibilities: Define and communicate roles and responsibilities for enterprise I&T, including authority levels, responsibilities and accountability.

Posicionar as capacidades de TI na estrutura organizacional global para refletir a importância estratégica e a dependência operacional da TI dentro da empresa. A linha de reporte do CIO e a representação da TI dentro da alta administração devem ser proporcionais à importância da Tecnologia da Informação dentro da empresa.

(APO01.06²⁵ – Otimizar a colocação da função de TI).

Sobre um outro aspecto, a Administração Pública Federal reconhece por meio da Portaria SGD/ME nº 778/2019²⁶, art. 4º, § 1º, que o posicionamento do setor de TI deve se dar, preferencialmente, junto à alta administração com o fito de otimizar seus benefícios e seus riscos a partir do alinhamento estratégico da organização com sua área de tecnologia da informação.

Noutro giro, dispõe o Decreto-Lei nº 200/1967, em seu art. 10, § 2º, que a administração pública deve se concentrar nas atividades de planejamento, supervisão, coordenação e controle. Tal disposição confere a diretriz no estabelecimento das competências e atribuições do setor da área de tecnologia da informação.

Dessa forma, torna-se relevante o estabelecimento de uma estrutura organizacional formalizada para o setor de TI da organização, preferencialmente com seu posicionamento diretamente relacionado à alta administração, com competências e atribuições que reflitam atividades de planejamento, coordenação, gestão e controle.

No presente trabalho, para mensurar e avaliar a adequação da estrutura organizacional do setor de TI, foi requisitado no item 01 do TSID02 os normativos que estabelecem as atribuições e competências do(s) setor(es) responsável(is) pelo planejamento, gestão, supervisão e controle da Tecnologia da Informação da organização.

Após a coleta, avaliou-se nos normativos a existência do Setor de TI (assessoria de TI) da organização, sua formalização e normatização na estrutura administrativa, sua vinculação à alta administração e o conjunto de atribuições incumbidas ao Setor.

²⁵ APO01.06 - Optimize the placement of the IT function: Position the IT capabilities in the overall organizational structure to reflect the strategic importance and operational dependency of IT. within the enterprise. The reporting line of the CIO and representation of IT within senior management should be commensurate with the importance of I&T within the enterprise.

²⁶ Art.4º, § 1º Para a obtenção de melhores resultados, a área de TIC de cada órgão ou entidade devem, preferencialmente, estar vinculada à alta administração com o intuito de apoiá-la na tomada de decisões e no alcance dos objetivos estratégicos.

Além disso, foram utilizados itens dispostos no Questionário de Governança e Gestão de TI, submetido por meio do TSID03.

Por fim, considerou-se, ainda, os esclarecimentos informados pelos jurisdicionados mediante a resposta ao TSID04, que solicitou os comentários do gestor, conforme descrito na seção 3.4 do relatório.

Os procedimentos de verificação para a conflagração deste achado foram:

- Item 08 do TSID02: verificou-se a existência de normatização para o Setor de TI;
- Item 01 do TSID02: verificou-se a existência de atribuições de planejamento, coordenação, gestão e controle da TI para o Setor de TI;
- Item 01 e 02 do TSID02: verificou-se a vinculação do Setor de TI à alta administração;
- Subitem “c” do item 1111 do Questionário de Governança e Gestão de TI: verifica a definição dos papéis e responsabilidades da área de gestão de tecnologia da informação.

A identificação de respostas do tipo “Não adota”, ou “Adota em menor parte”, ou “Há decisão formal ou plano aprovado para adotá-lo” para a questão 1111 do Questionário de Governança e Gestão de TI, ou a identificação de resposta do tipo “Não” para o detalhamento “C” da questão 1111 foram consideradas situações incondizentes com as boas práticas encontradas no COBIT 2019 e na norma ABNT NBR ISO/IEC 38.500/2018.

Ademais, a ausência de normativo que trate das atribuições e competências do Setor de TI, ou a ausência de atribuições de planejamento, coordenação, gestão e controle da TI para o Setor de TI em análise à resposta ao item 01 do TSID02 foram situações igualmente consideradas inapropriadas.

Mais ainda, a não vinculação do Setor de TI à alta administração em análise das respostas ao item 01 e ao item 02 ambos do TSID02 foram da mesma forma consideradas inadequadas.

Segue o resultado da aplicação dos procedimentos de verificação nas organizações do nível setorial do SETIC:

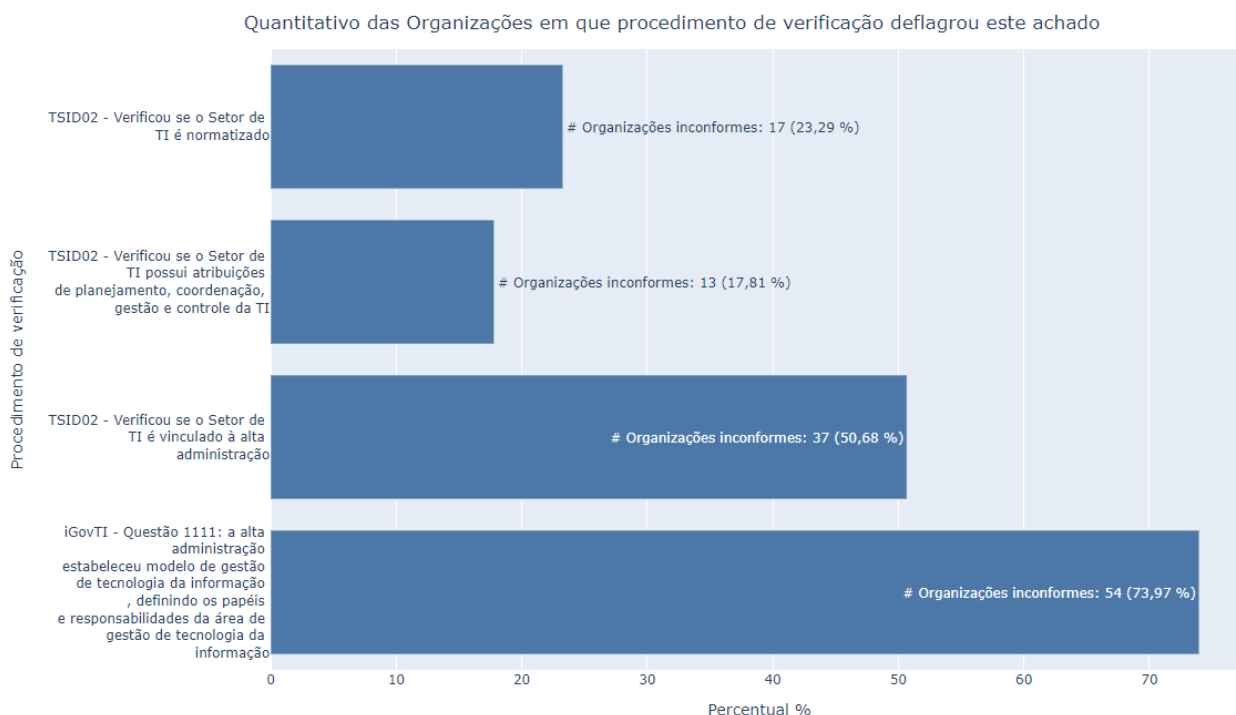


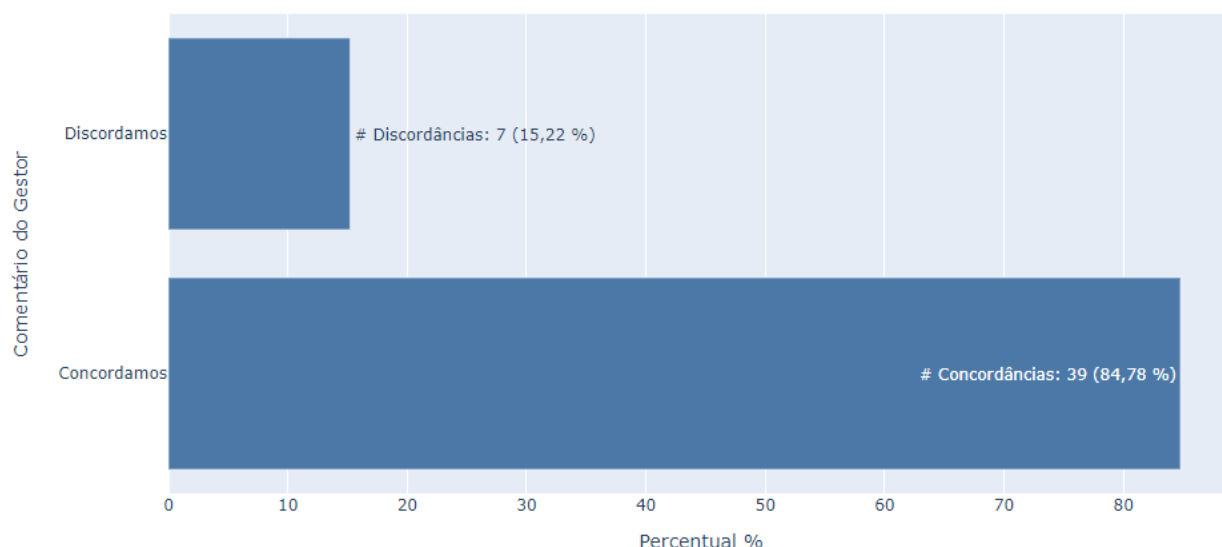
Figura 2 - Resultado das organizações aos procedimentos de verificação

Da análise empreendida, verificou-se, após a realização dos procedimentos e da análise dos comentários dos gestores, que aproximadamente 23% das organizações não estão normatizadas e que cerca de 18% das organizações não possuem atribuições de planejamento, coordenação, gestão e controle da TI.

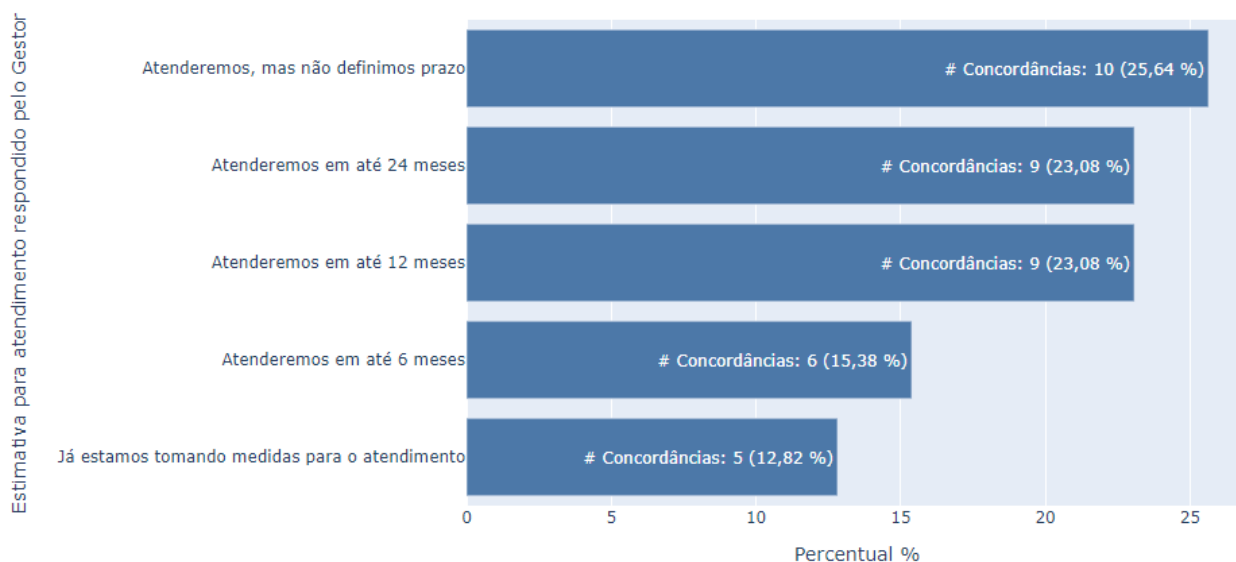
Outrossim, da análise nota-se que em aproximadamente 51% das organizações o Setor de TI não está vinculado à alta administração e que cerca de 74% declararam não ter definido um modelo de gestão da TI, definindo os papéis e responsabilidades da área.

Dos Comentários do Gestor

Em relação aos comentários dos gestores, podemos notar que houve ampla concordância com o disposto na situação encontrada e no encaminhamento proposto, constituindo aproximadamente 85% das respostas para este achado, como apresentado na figura a seguir:



Ademais, considerando apenas os comentários que exprimem concordâncias, vemos que a maior parte (aproximadamente 74%) dos gestores estimam atender às propostas de encaminhamento deste achado em até 24 meses, inclusive, 28% deles esperam cumprir os encaminhamentos num curto prazo de até 6 meses, como apresentado na figura a seguir:



Dessa forma, constata-se a existência de oportunidades de melhoria quanto à estrutura organizacional do Setor de TI presente. Assim, será sugerida proposta de encaminhamento às organizações em que se constatou a situação relatada.

4.3.1.4 Causas

- Não investigadas.

4.3.1.5 Efeitos

- Possível ineficiência operacional, podendo dificultar a entrega de serviços de TI de forma oportuna e eficaz;
- Dificuldade de atração e retenção de talentos, podendo ser visto como ambiente pouco profissional e insatisfatório;
- Dificuldade de resposta a demandas, mudanças e necessidades da organização;
- Soluções de TI que não atendem às necessidades da organização;
- Falta de alinhamento estratégico entre a TI e a organização.

4.3.1.6 Propostas de encaminhamento

- **Comunicação com Recomendação** às organizações a seguir elencadas, para que, observando as melhores práticas descritas no processo APO01 – Estrutura de gestão de TI gerenciada - do COBIT 2019:
 - Estabeleçam formalmente as estruturas organizacionais internas da área de TI conforme o projeto do sistema de gestão, possibilitando a tomada de decisões eficaz e eficiente, visando a garantir que o conhecimento necessário em tecnologia e informação esteja incluído na composição das estruturas de gestão;
 - Definam e comuniquem as funções e responsabilidades para a tecnologia da informação, incluindo competências, atribuições, responsabilidades e prestação de contas, assegurando a ela, ao menos, as atribuições de planejamento, coordenação, gestão e controle da TI;
 - Posicionem o setor de TI diretamente relacionado à alta administração na estrutura organizacional de forma a refletir a importância estratégica e a dependência operacional da TI dentro da organização.

Organizações: AGENERSA, AGERIO, AGETRANSP, CEASA, CEHAB, CENTRAL, CEPERJ, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO,

DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IEEA, IPERJ, IRM, ISP, ITERJ, IVB, LOTERJ, PESAGRO, PGE, PROCON, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEGOV, SEIC, SEPLAG, SEPM, SERGB, SES, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

4.3.2. Achado 02 – Ausência de elaboração ou revisão do PEDTIC

4.3.2.1 Critérios

- Constituição Federal de 1988, art. 37, *caput*, princípio da eficiência;
- Decreto Lei n.º 200/1967, art. 6º, inciso I, princípio do planejamento;
- Decreto Estadual n.º 47.278/2020, art. 6º, inciso I e II;
- Decreto Estadual n.º 48.650/2023, art. 20, inciso VIII;
- Portaria PRODERJ/PRE n.º 825/2021, Anexo C, art. 3º, inciso I;
- Norma Técnica ABNT NBR ISO/IEC 38.500/2018, item 5.3, princípio da estratégia;
- COBIT 2019, processos EDM02 – Entrega de Benefícios Garantidos e APO01 - Estrutura de Gestão de TI Gerenciada;
- Processo TCE-RJ nº 212.981-7/2017, Decisão Plenária de 08/05/2018, item VII, a), 1;
- Processo TCE-RJ nº 214.788-9/2018, Decisão Plenária de 04/10/2018, item V, 1);
- Acórdão 2.094/2004-TCU-Plenário, item 9.1.1;
- Acórdão 2.023/2005-TCU-Plenário, item 9.1.9;
- Acórdão 1.233/2012-TCU-Plenário, itens 9.1.2.1 a 9.1.2.6;
- Acórdão 1.055/2014-TCU-Plenário, item 9.1.1;
- Acórdão 1.411/2014-TCU-Plenário, itens 9.1.5 e 9.1.6;
- Acórdão 1.684/2014-TCU-Plenário, itens 9.1.5 e 9.1.6.

4.3.2.2 Evidências

- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 1022 do Questionário de Governança e Gestão de TI²⁷, submetido pelo TSID03, para verificar a adoção da prática "a organização atende a Portaria PRODERJ/PRE nº 825/2021 expedida pelo Diretor Geral do SETIC (PRODERJ)";
- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 2112 do Questionário de Governança e Gestão de TI²⁸, submetido pelo TSID03, para verificar a adoção da prática "a organização possui plano de tecnologia da informação vigente";
- Não elaboração ou revisão dos PEDTICs de algum destes anos: 2021, 2022, 2023 com base na análise das respostas ao item 06 e ao item 07 ambos do TSID02²⁹, que solicitaram, respectivamente:
 - relação do(s) Plano(s) Estratégico e Diretor de Tecnologia da Informação e Comunicação (PEDTIC), passados, vigentes ou em elaboração; e
 - Plano(s) Estratégico e Diretor de Tecnologia da Informação e Comunicação (PEDTIC) publicados e/ou em elaboração da organização;

4.3.2.3 Situação Encontrada

O planejamento da área de tecnologia da informação das organizações é indispensável para o devido alinhamento estratégico entre esse setor e a alta administração, conferindo um dos pilares essenciais para uma boa governança e gestão.

Nesta toada, é relevante sublinhar a norma técnica ABNT NBR ISO/IEC 38.500/2018, que fornece uma estrutura de princípios para os dirigentes usarem na avaliação, no gerenciamento e no monitoramento do uso da tecnologia da informação em suas organizações.

Esta norma estabelece os princípios para o uso eficaz, eficiente e aceitável da tecnologia da informação, assegurando às organizações que os seguem uma melhor avaliação dos riscos do uso da TI e uma exploração mais assertiva das oportunidades advindas do uso da TI.

²⁷ Presente no Anexo 008 do relatório.

²⁸ Presente no Anexo 008 do relatório.

²⁹ Presente no Anexo 004 do relatório.

No que tange aos princípios aplicáveis a uma boa governança de TI, destaca-se o princípio da estratégia. Nesta seara, a norma dispõe que a estratégia de negócio da organização leva em conta as capacidades atuais e futuras da TI e realça que os planos estratégicos para TI satisfazem as necessidades atuais e contínuas da estratégia de negócio da organização. Verifica-se, portanto, uma explícita reciprocidade entre TI e organização, sendo essencial um alinhamento harmônico entre ambos para garantir a realização de benefícios e maximizar a entrega de valor pela TI.

Alinhando-se às diretrizes e aos princípios estabelecidos pela ABNT NBR ISO/IEC 38.500, o COBIT 2019 enfatiza a necessidade da definição e da aplicação de práticas e ferramentas de planejamento robustas e consistentes de forma a suportar a melhor tomada de decisão por parte da alta gestão, com vistas ao alcance de eficácia, eficiência e economicidade no uso de recursos de TIC, bem como à otimização de riscos. Dentre as atividades desse framework que perpassam os temas estratégia, planejamento e planos de ação, pode-se sobrelevar as seguintes:

Criar e manter portfólios de programas de investimento habilitados para TI, serviços e ativos de TI, que formam a base para o orçamento de TI atual e apoiam os planos táticos e estratégicos de TI.

(EDM02.01 – Atividade 1)

Avaliar o portfólio de investimentos, serviços e ativos para alinhamento com os objetivos estratégicos da empresa; valor da empresa, tanto financeiro quanto não financeiro; risco, risco de entrega e risco de benefícios; alinhamento de processos de negócios

(EDM02.02 – Atividade 8)

Defina as iniciativas necessárias para fechar as lacunas entre o ambiente atual e o ambiente de destino. Integre as iniciativas em uma estratégia de TI coerente que alinhe a TI com todos os aspectos do negócio.

(APO02.05 – Atividade 1)

Nesse bojo, a obrigatoriedade de elaboração de um instrumento de planejamento da TI, o Plano Diretor de TI - PDTI, por cada órgão foi objeto de apreciação por esta Corte no escopo do Processo TCE-RJ nº 212.981-7/2017. Neste feito, o corpo instrutivo asseverou o seguinte:

O PDTI é o instrumento de diagnóstico, planejamento e gestão dos recursos e processos da área de TI, que visa atender às necessidades de informação de um órgão para um determinado período, além de ser uma ferramenta

imprescindível para que a organização cumpra os princípios constitucionais de publicidade e eficiência.

O não alinhamento das contratações de TI em relação ao PDTI, pela inexistência deste, acarreta uma maior exposição ao risco de se ter contratações ineficazes e ineficientes em atender ao órgão.

Em decisão proferida em 08/05/2018, a Sra. Conselheira Marianna Montebello Willeman, alinhou-se ao entendimento técnico e assim pontuou:

Trasladando-se o conceito para a Administração Pública, o Plano Diretor é indispensável como ferramenta de planejamento para a estruturação, gestão de recursos e contratações de TI. Muito mais do que um simples regulamento interno, o PDTI é um instrumento de diagnóstico, planejamento e gestão, de sorte que, seguramente, muitos dos problemas identificados na auditoria poderiam ter sido evitados se a Administração Municipal houvesse cumprido a etapa de planejamento de modo satisfatório.

O Tribunal de Contas da União também compartilha deste entendimento, determinando a seus jurisdicionados que harmonizem³⁰ suas contratações de TIC ao planejamento estratégico da organização e com seu plano diretor de informática, definam³¹ com os diversos setores da organização um Plano Estratégico para a área de TI que propicie a alocação de recursos conforme as necessidades e prioridades da organização, entre outras decisões³² importantes sobre o tema.

No contexto do SETIC, a Portaria PRODERJ/PRE n.º 825/2021 reconhece que a eficiência e a efetividade do gasto público devem nortear as ações do governo, com vistas ao melhor atendimento ao cidadão.

Ademais, o seu Anexo C determina que todos os órgãos que compõem o Nível Setorial de Tecnologia da Informação e Comunicação do Estado do Rio de Janeiro - NSTIC/RJ - deverão elaborar o Plano Estratégico e Diretor de Tecnologia da Informação e Comunicação - PEDTIC, nos termos da Portaria de Governança de TIC do Estado do

³⁰ Acórdão 2.094/2004-TCU-Plenário, item 9.1.1;

³¹ Acórdão 2.023/2005-TCU-Plenário, item 9.1.9;

³² Acórdão 1.233/2012-TCU-Plenário, itens 9.1.2.1 a 9.1.2.6, que define requisitos mínimos que devem constar no plano estratégico de TI;

Acórdão 1.055/2014-TCU-Plenário, item 9.1.1;

Acórdão 1.411/2014-TCU-Plenário, itens 9.1.5 e 9.1.6, que reforça os requisitos mínimos do plano estratégico de TI e estabelece requisitos mínimos para o plano diretor de TI;

Acórdão 1.684/2014-TCU-Plenário, itens 9.1.5 e 9.1.6, que define que no plano diretor de TI deve constar vinculação entre as ações de TI a indicadores e metas;

Rio de Janeiro e/ou demais normas que venham a ser publicadas pelo PRODERJ que, conforme a orientação desta mesma portaria, exerce o papel de Direção Geral do SETIC.

Esse Anexo determina em seu art. 3º que o PEDTIC terá abrangência de quatro anos e revisões anuais. Deste modo, tais revisões visam a ajustar o planejamento idealizado à situação realista da organização, conferindo agilidade ao instrumento para a consecução dos objetivos estratégicos da entidade.

Noutro giro, como forma de reforçar os ditames da Portaria PRODERJ/PRE nº 825/2021 e seus anexos, o Governo do Estado do Rio de Janeiro editou o Decreto nº 48.754/2023, que determina que os órgãos e entidades do Poder Executivo devem elaborar e enviar ao PRODERJ seus PEDTICs anualmente³³.

Esse novo normativo destaca o Acórdão TCE-RJ nº 15.302/2023-PLENV, que já havia detectado a ausência de elaboração do PEDTIC por parte de órgãos setoriais do SETIC.

No presente trabalho, para avaliar a elaboração e revisão dos planos de tecnologia da informação das organizações, foram requisitados, pelos itens 06 e 07 do TSID02, a relação e os documentos do(s) Plano(s) Estratégico e Diretor de Tecnologia da Informação e Comunicação (PEDTIC), passados, vigentes ou em elaboração.

Além disso, foi utilizado o Questionário de Governança e Gestão de TI, submetido por meio do TSID03, que possui itens de verificação para mapear a adoção das práticas de planejamento de tecnologia da informação, como elaboração do plano e sua revisão periódica.

Por fim, considerou-se, ainda, os esclarecimentos informados pelos jurisdicionados mediante a resposta ao TSID04, que solicitou os comentários do gestor, conforme descrito na seção 3.4 do relatório.

Os procedimentos de verificação para a conflagração deste achado são:

- Item 06 e 07 do TSID02: verifica a elaboração e revisão anual dos PEDTICs a partir do ano de 2021, ano de publicação da Portaria PRODERJ/PRE nº 825/2021, que estabelece a periodicidade do instrumento de planejamento no art. 3º, caput e seu inc. I;

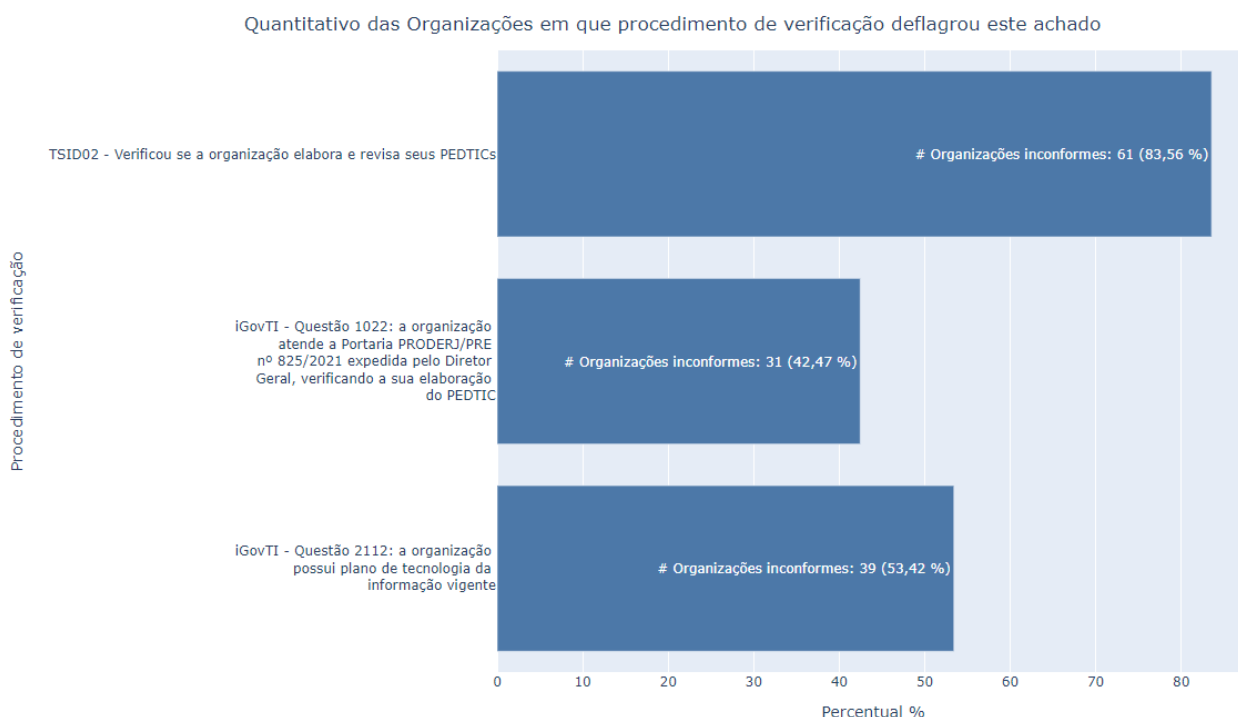
³³ Art. 2º - Deverão ser encaminhados pelos órgãos e entidades do Poder Executivo estadual seus PEDTIC's, de acordo com as portarias instituídas pelo Centro de Tecnologia de Informação e Comunicação do Estado do Rio de Janeiro (PRODERJ) e dentro do prazo estabelecido de entrega: dia 22 de dezembro do respectivo ano de elaboração do planejamento.

- Subitem “c” do item 1022 do Questionário de Governança e Gestão de TI: verifica se a organização atende à Portaria PRODERJ/PRE nº 825/2021 e se elabora o PEDTIC;
- Item 2112 do Questionário de Governança e Gestão de TI: verifica se a organização possui plano de tecnologia da informação vigente.

A identificação de respostas do tipo “Não adota”, ou “Adota em menor parte”, ou “Há decisão formal ou plano aprovado para adotá-lo” para a questão 1022 do Questionário de Governança e Gestão de TI, ou a identificação de resposta do tipo “Não” para o detalhamento “C” da questão 1022 foram consideradas situações incondizentes com o Anexo C da Portaria PRODERJ/PRE nº 825/2021.

Ademais, a ausência de elaboração ou revisão anual do PEDTIC, averiguada na análise da resposta ao item 06 do TSID02, com apuração do processo SEI que cuida do instrumento de planejamento em tela, foram situações igualmente consideradas inapropriadas.

Segue o resultado da aplicação dos procedimentos de verificação nas organizações do nível setorial do SETIC:



Verificou-se, após a realização dos procedimentos e da análise dos comentários dos gestores, que aproximadamente 42% das organizações respondentes não estão em

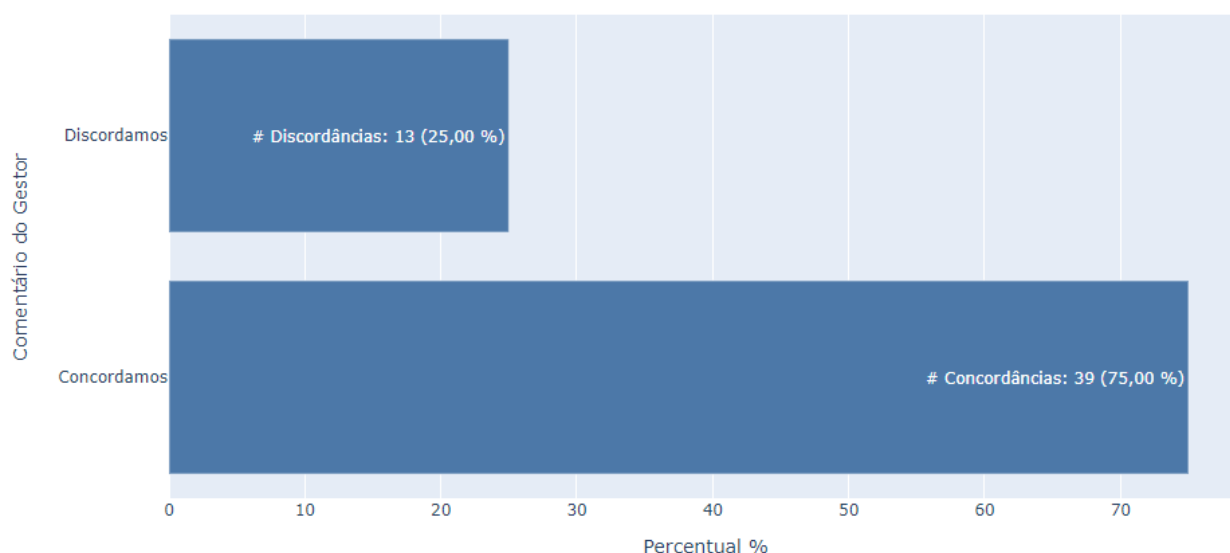
conformidade com a Portaria PRODERJ/PRE nº 825/2021, no que tange a elaboração do PEDTIC.

Além disso, cerca de 53% das organizações respondentes declararam não possuir plano de tecnologia da informação vigente.

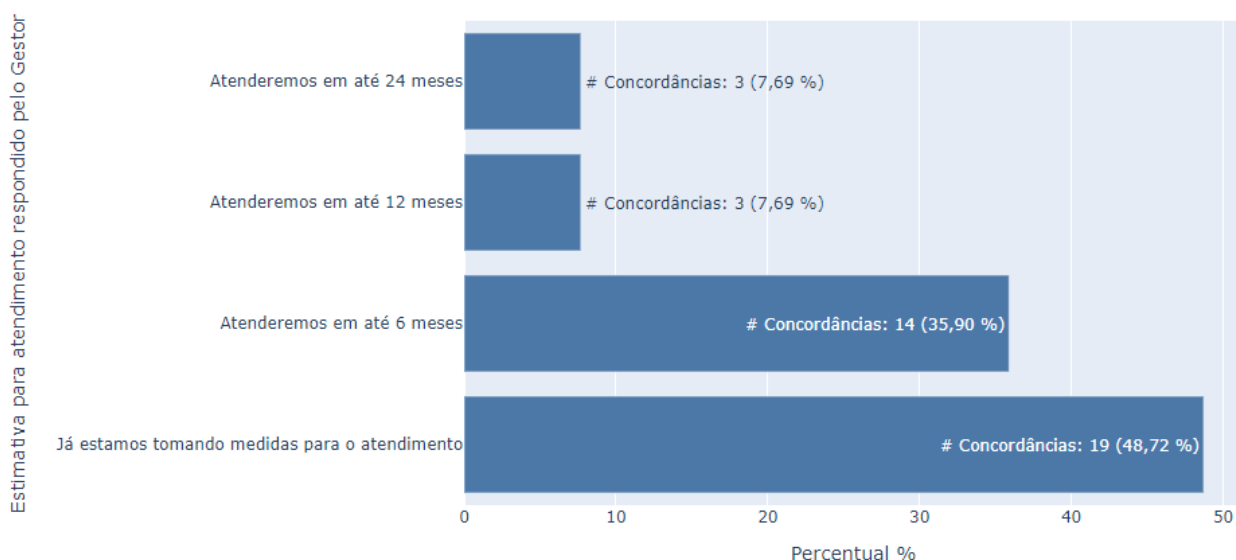
Por fim, assevera-se que praticamente 83% das organizações não elaboram ou revisam anualmente seus PEDTICs.

Dos Comentários do Gestor

Em relação ao comentário dos gestores, podemos notar que houve ampla concordância com o disposto na situação encontrada e no encaminhamento proposto, constituindo 75% das respostas para este achado, como apresentado na figura a seguir:



Ademais, considerando apenas os comentários que exprimem concordâncias, observa-se que a totalidade dos gestores estima atender as propostas de encaminhamento neste achado em até 24 meses, como apresentado na figura a seguir:



Dessa forma, constata-se a existência de oportunidades de melhoria quanto à elaboração e revisão do Plano Estratégico e Diretor de Tecnologia da Informação e Comunicação da organização.

À vista disto, será incluída **DETERMINAÇÃO** aos órgãos que compõem o NSTIC, na proposta de encaminhamento deste relatório, para que elaborem e enviem ao PRODERJ seu PEDTIC, nos termos da Portaria de Governança de TIC do Estado do Rio de Janeiro e/ou demais normas que venham a ser publicadas pelo PRODERJ, em conformidade aos prazos determinados.

4.3.2.4 Causas

- Não investigadas.

4.3.2.5 Efeitos

- Falta de alinhamento estratégico entre a TI e a organização;
- Falta de visibilidade e controle sobre os ativos e recursos de TI;
- Ausência de priorização das ações de TI;
- Realização de contratações, projetos e ações de TI não alinhados à estratégia, prioridades ou necessidades da organização;
- Baixo desempenho percebido da área de gestão de TI em atender necessidades e expectativas de usuários ou partes interessadas;

- Desperdício de recursos em contratações, projetos e ações de TI atrasados, abortados durante a execução ou com resultados aquém do esperado;
- Falha na entrega de resultados finalísticos à sociedade;
- Imprevisibilidade quanto às necessidades de TIC da Administração Pública Estadual.

4.3.2.6 Propostas de encaminhamento

- **Comunicação com Determinação** às organizações a seguir elencadas para que estabeleçam formalmente um processo estruturado, com participação de representantes dos setores da organização, aos moldes descritos na Portaria PRODERJ/PRE nº 825/2021, visando elaborar, manter e revisar periodicamente um Plano Estratégico e Diretor de Tecnologia da Informação, o qual deve contemplar minimamente:
 - objetivos, indicadores e metas de TI, alinhados aos objetivos de negócio;
 - identificação dos riscos que possam impactar no cumprimento dos objetivos estratégicos e das metas de TI;
 - projetos, aquisições e demais ações necessárias para o atingimento das metas fixadas e/ou para a mitigação de riscos de TI;
 - alocação de recursos (financeiros, humanos tecnológicos etc.) necessários para a execução do plano.

Organizações: AGENERSA, AGERIO, AGETRANSP, CEASA, CECIERJ, CEHAB, CENTRAL, CEPERJ, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FTMRJ, FUNARJ, IASERJ, IEEA, IO, IPEM/RJ, IRM, ITERJ, IVB, LOTERJ, PESAGRO, PGE, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEGOV, SEIC, SEPLAG, SEPM, SES, SETD, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

4.3.3. Achado 03 – Ausência de Comitê Permanente do PEDTIC

4.3.3.1 Critérios

- Constituição Federal de 1988, art. 37, *caput*, princípio da eficiência;
- Decreto Lei n.º 200/1967, art. 6º, inciso I;
- Decreto Estadual n.º 47.278/2020, art. 6º, I;
- Portaria PRODERJ/PRE n.º 825/2021, Anexo C, art. 5º;
- Norma Técnica ABNT NBR ISO/IEC 38.500/2018, princípio do desempenho e da conformidade;
- COBIT 2019, processos EDM01 – Configuração e manutenção da estrutura de governança garantida e APO01 - Estrutura de Gestão de TI Gerenciada.

4.3.3.2 Evidências

- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 1022 do Questionário de Governança e Gestão de TI³⁴, submetido pelo TSID03, para verificar a adoção da prática "a organização atende a Portaria PRODERJ/PRE nº 825/2021 expedida pelo Diretor Geral do SETIC (PRODERJ)", que verificou a instituição do Comitê Permanente do PEDTIC;
- Inexistência de normativo instituindo o Comitê Permanente de PEDTIC, verificada com base na análise das respostas ao item 04 do TSID02³⁵, que solicitou o normativo de instituição do Comitê Permanente do PEDTIC, conforme disposto no art. 5º do Anexo C da Portaria PRODERJ/PRE nº 825/2021.

4.3.3.3 Situação Encontrada

O Comitê Permanente do PEDTIC é a estrutura composta por participantes dos diversos setores da organização e que possui a finalidade de apoiar o Setor de TI com os dados e informações necessárias para a elaboração e revisão do PEDTIC.

A instituição de um comitê de tecnologia da informação propicia condições para que a alta administração monitore o desempenho da TI, com base no desdobramento dos objetivos institucionais em indicadores e metas; também tem o condão de aumentar

³⁴ Presente no Anexo 008 do relatório.

³⁵ Presente no Anexo 004 do relatório.

o alinhamento das contratações de bens e serviços de TI aos objetivos do órgão; além de mitigar o risco de se priorizar os investimentos em TI de forma equivocada.

Nesta toada, a Norma Técnica ABNT NBR ISO/IEC 38.500/2018 destaca os princípios do desempenho e da conformidade. Assim sendo, a norma indica que a TI deve ser adequada ao propósito de apoiar a organização, fornecendo serviços, níveis de serviço e qualidade de serviço, necessários para atender aos requisitos atuais e futuros do negócio, bem como realça que a TI cumpre com toda a legislação e regulamentos obrigatórios. Salientando, ainda, que as políticas e práticas são claramente definidas, implementadas e fiscalizadas.

O COBIT 2019 enfatiza a relevância de se estabelecer um comitê gestor de TI (ou equivalente) composto por executivos, áreas de negócio e governança de TI, visando rastrear o status de projetos, resolver conflitos de recursos e monitorar os níveis de qualidade e as melhorias dos serviços (APO01.04 – Atividade 6, com modificação).

Neste bojo, a obrigatoriedade de instituição de um Comitê de TI foi objeto de apreciação por esta Corte no escopo do processo de Auditoria de Conformidade sob n.º 212.981-7/2017. Neste feito, o Corpo Instrutivo expôs o seguinte:

A inexistência de um comitê para definir, priorizar e monitorar as principais contratações de bens e serviços de TI expõe a organização ao risco de realizar aquisições ou contratações que não atendam à necessidade da administração municipal. Esse cenário também favorece a indesejável situação de se ter a definição dos principais investimentos e ações de TI sem a garantia de envolvimento dos principais setores do órgão.

A instituição de um comitê de TI propicia condições para haver um maior alinhamento das contratações de bens e serviços de TI aos objetivos do órgão, além de mitigar o risco de se priorizar os investimentos em TI de forma equivocada.

Em decisão de 08/05/2018, a Sra. Conselheira Marianna Montebello Willeman, alinhou-se a este entendimento e posicionou-se da seguinte forma:

A falta de um organismo dentro da estrutura da Administração Municipal voltado para a definição de prioridades e metas eleva o risco de contratações malsucedidas, tendo decerto contribuído para o cenário descrito no relatório de auditoria, razão por que ratifico a determinação proposta pelo corpo técnico.

Ainda no corpo desta decisão, houve determinação visando promover a devida constituição do Comitê de Tecnologia da Informação pela Administração:

VII – pela COMUNICAÇÃO, nos termos do § 1º do art. 6º da Deliberação TCE-RJ n.º 204/96, ao atual Prefeito Municipal de Nova Friburgo, a fim de que:

a) cumpra as DETERMINAÇÕES a seguir, comprovando as medidas adotadas junto a este Tribunal:

[...]

3 - Instituir o Comitê de Tecnologia da Informação, com representantes das principais secretarias, com a responsabilidade de alinhar as ações de TI aos objetivos da Prefeitura e priorizar os investimentos (achado 3);

O Anexo C da Portaria PRODERJ/PRE n.º 825/2021 determina, em seu art. 5º, que cada órgão setorial do SETIC deverá criar um Comitê Permanente do PEDTIC com a função de assessorar o NSTIC/RJ fornecendo informações e dados que resultarão na elaboração e na revisão do PEDTIC, sendo composto por, no mínimo:

- a) O principal responsável do NSTIC/RJ como presidente do Comitê;
- b) Um representante da área de planejamento;
- c) Um representante da área de orçamento;
- d) Um representante da área de administração e patrimônio;
- e) Um representante da atividade fim do órgão/entidade; e
- f) Um representante designado pela Alta Administração do órgão/entidade.

Ademais, como forma de reforçar os ditames da Portaria PRODERJ/PRE n.º 825/2021 e seus anexos, o Governo do Estado do Rio de Janeiro editou o Decreto nº 48.754/2023, que determina que os órgãos e entidades do Poder Executivo Estadual elaborem e publiquem seus Comitês Permanentes do PEDTIC³⁶.

Esse novo normativo destaca o Acórdão TCE-RJ nº 15.302/2023-PLENV, que já havia detectado a ausência de criação de Comitê Permanente do PEDTIC nos órgãos setoriais do SETIC.

No presente trabalho, para verificar a existência e atuação do Comitê Permanente de PEDTIC da organização foram requisitados no item 04 do TSID02 o normativo de

³⁶ Art. 1º - Fica determinado que os órgãos e entidades do Poder Executivo estadual elaborem e publiquem seus Comitês Permanentes do PEDTIC no Diário Oficial do Estado do Rio de Janeiro, em até 15 (quinze) dias úteis, a contar da data da publicação deste Decreto. Assim como, publicar a relação dos servidores que compõem seu Nível Setorial de Tecnologia da Informação e Comunicação (NSTIC/RJ), indicando o principal responsável e seu suplente, no mesmo prazo.

instituição do Comitê Permanente do PEDTIC, conforme disposto no art. 5º do Anexo C da Portaria PRODERJ/PRE nº 825/2021, e no item 05 do mesmo documento as atas das reuniões do Comitê Permanente do PEDTIC.

Além disso, foi utilizado o Questionário de Governança e Gestão de TI, submetido por meio do TSID03, que possui itens de verificação para mapear a adoção das práticas de instituição do Comitê, sua publicação e reunião periódica.

Por fim, considerou-se, ainda, os esclarecimentos informados pelos jurisdicionados mediante a resposta ao TSID04, que solicitou os comentários do gestor, conforme descrito na seção 3.4 do relatório.

Os procedimentos de verificação para a conflagração deste achado são:

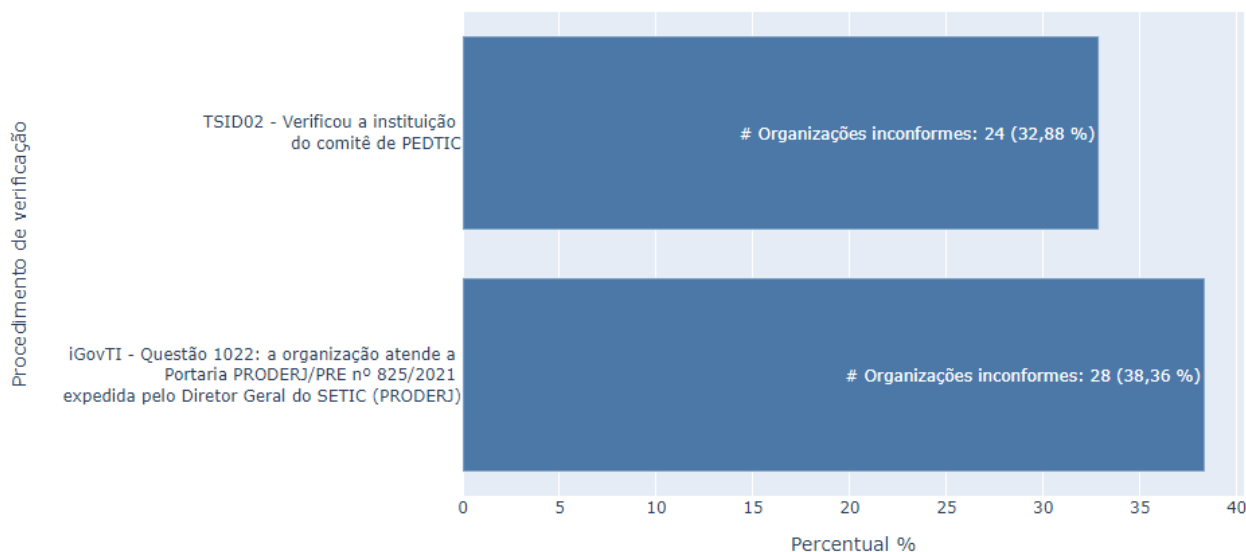
- Item 04 do TSID02: solicitou o normativo instituidor do Comitê Permanente de PEDTIC, conforme disposto no art. 5º do Anexo C da Portaria PRODERJ/PRE nº 825/2021;
- Subitem “a” do item 1022 do Questionário de Governança e Gestão de TI: verifica se a organização atende à Portaria PRODERJ/PRE nº 825/2021 e se instituiu o Comitê Permanente do PEDTIC.

A identificação de respostas do tipo “Não adota”, ou “Adota em menor parte”, ou “Há decisão formal ou plano aprovado para adotá-lo” para a questão 1022 do Questionário de Governança e Gestão de TI, ou a identificação de resposta do tipo “Não” para o detalhamento “A” da questão 1022 foram consideradas situações incondizentes com o Anexo C da Portaria PRODERJ/PRE nº 825/2021.

Ademais, a ausência do envio do normativo instituidor do Comitê Permanente de PEDTIC em resposta ao item 04 do TSID02, ou a resposta negativa ao mesmo item foram situações igualmente consideradas inapropriadas.

Segue o resultado da aplicação dos procedimentos de verificação nas organizações do nível setorial do SETIC:

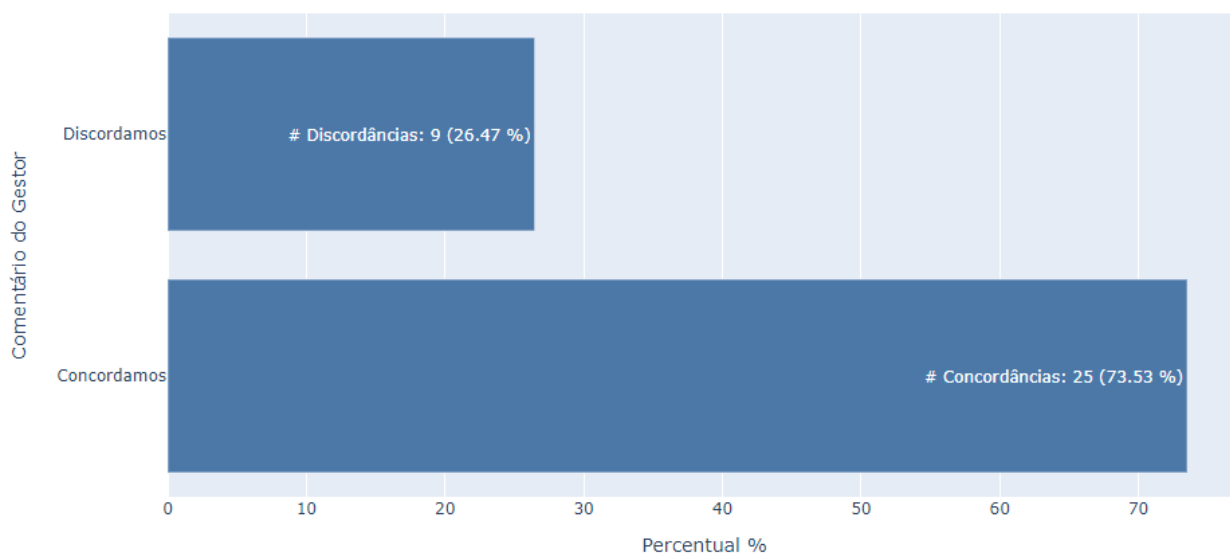
Quantitativo das Organizações em que procedimento de verificação deflagrou este achado



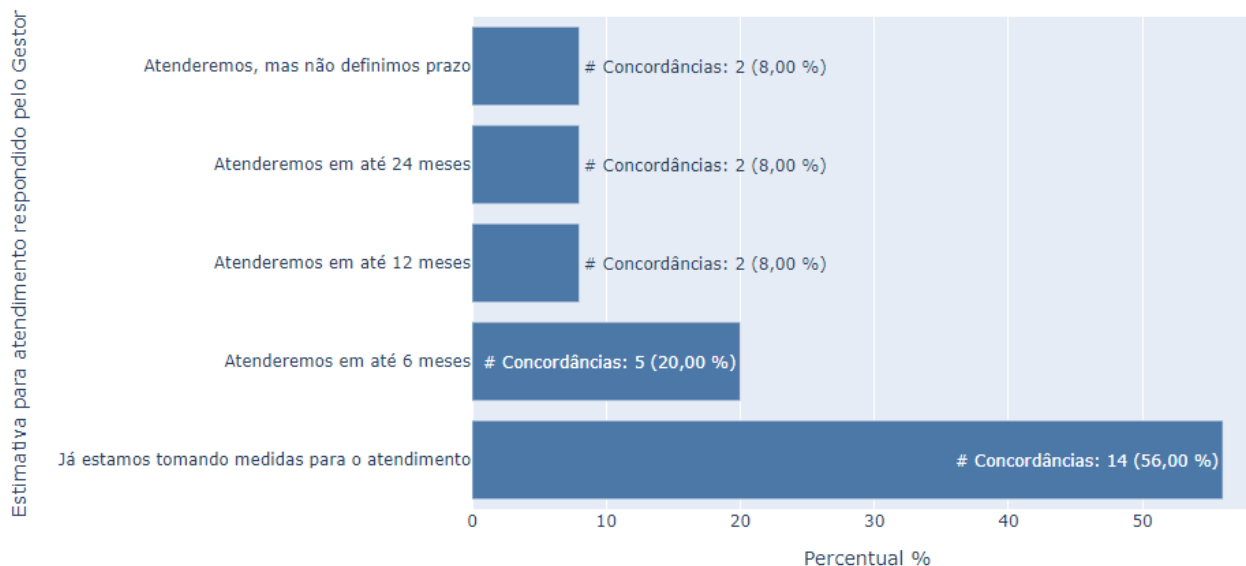
Verificou-se, após a realização dos procedimentos e da análise dos comentários dos gestores, que mais de 30% das organizações respondentes não estão em conformidade com a Portaria PRODERJ/PRE nº 825/2021.

Dos Comentários do Gestor

Em relação ao comentário dos gestores, podemos notar que houve ampla concordância com o disposto na situação encontrada e no encaminhamento proposto, constituindo aproximadamente 73,5% das respostas para este achado, como apresentado na figura a seguir:



Ademais, considerando apenas os comentários que exprimem concordâncias, vemos que a maior parte dos gestores estimam atender as propostas de encaminhamento neste achado em até 24 meses, constituindo aproximadamente 92% dos comentários de consentimento, como apresentado na figura a seguir:



Dessa forma, constata-se a existência de oportunidades de melhoria quanto à estrutura que elabora e revisa o Plano Estratégico e Diretor de Tecnologia da Informação e Comunicação da organização

À vista disto, será incluída **DETERMINAÇÃO** aos órgãos que compõem o NSTIC, na proposta de encaminhamento deste relatório, para que instituem seu Comitê Permanente de Elaboração do PEDTIC, nos termos da Portaria de Governança de TIC do Estado do Rio de Janeiro e/ou demais normas que venham a ser publicadas pelo PRODERJ, em conformidade aos prazos determinados.

4.3.3.4 Causas

- Não investigadas.

4.3.3.5 Efeitos

- Falta de apoio à elaboração e revisão do planejamento de TIC da organização;
- Falta de controle sobre o processo de elaboração e monitoramento do PEDTIC;
- Planejamento centrado no Setor de TI da organização;

- Setor de TI não gera valor para a organização.

4.3.3.6 Propostas de encaminhamento

- **Comunicação com Determinação** às organizações a seguir elencadas para que instituem o Comitê Permanente do PEDTIC com representantes dos setores da organização a fim de planejar, elaborar, revisar e monitorar o instrumento de Planejamento Estratégico e Diretor de Tecnologia da Informação – PEDTIC;

Organizações: AGETRANS, CEASA, CODERTE, CODIN, DETRO, DRM, EMATER, FAETEC, FIA/RJ, FIPERJ, FLXIII, FS, FTMRJ, GVG, IEEA, IO, IRM, LOTERJ, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SECEC, SEDEC, SEELJE, SEGOV, SEIC, SEPM, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

4.3.4. Achado 04 – Práticas de gestão de serviço de TI incipientes

4.3.4.1 Critérios

- Decreto-Lei nº 200/67, art. 6º, V, princípio do controle;
- Norma Técnica ABNT NBR ISO/IEC 20000-1/2020 e 20000-2/2021, item 8.2.4 – Gerenciamento de catálogo de serviço, item 8.2.5 – Gerenciamento de Ativo, item 8.2.6 – Gerenciamento de configuração, item 8.3.3 - Gerenciamento de nível de serviço, item 8.6.1 - Gerenciamento de incidentes e item 8.7.2 - Gerenciamento de continuidade de serviço;
- ITIL 4, item 5.2.5 - Gerenciamento de incidentes, item 5.2.6 - Gerenciamento de ativos de TI, item 5.2.10 Gerenciamento do catálogo de serviços, item 5.2.11 – Gerenciamento de configurações de serviço, item 5.2.15 - Gerenciamento de nível de serviço;
- Acórdão TCU nº 380/2011-Plenário, item 9.1.6, 9.1.7;
- Acórdão TCU nº 2612/2011-Plenário, item 9.1.7, 9.1.8
- Acórdão TCU nº 1221/2014-Plenário, item 9.12.

4.3.4.2 Evidências

- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 2121 do Questionário de Governança e Gestão de TI³⁷, submetido pelo TSID03, para verificar a adoção da prática "a organização executa processo de gestão do catálogo de serviços";
- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 2123 do Questionário de Governança e Gestão de TI³⁸, submetido pelo TSID03, para verificar a adoção da prática "a organização executa processo de gestão de configuração e ativos (de serviços de tecnologia da informação)";
- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 2124 do Questionário de Governança e Gestão de TI³⁹, submetido pelo TSID03, para verificar a adoção da prática "a organização executa processo de gestão de incidentes de serviços de tecnologia da informação";
- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 2142 do Questionário de Governança e Gestão de TI⁴⁰, submetido pelo TSID03, para verificar a adoção da prática "a organização executa processo de gestão da continuidade dos serviços de tecnologia da informação".

4.3.4.3 Situação Encontrada

Serviços⁴¹ são o principal instrumento que as organizações utilizam para gerar valor para si e para seus usuários. Nesse contexto, os órgãos públicos materializam a política pública por meio da prestação de serviços públicos à sociedade. Atualmente a maioria

³⁷ Presente no Anexo 008 do relatório.

³⁸ Presente no Anexo 008 do relatório.

³⁹ Presente no Anexo 008 do relatório.

⁴⁰ Presente no Anexo 008 do relatório.

⁴¹ Serviço – meios de entregar valor para o cliente ao facilitar os resultados que o cliente deseja alcançar. ABNT NBR ISO/IEC 20000-1:2020, item 3.2.15.

dos serviços são dependentes da TI, o que explicita a importância e o potencial de benefícios resultantes do desenvolvimento e melhoria na gestão de serviços de TI.

A gestão de serviços⁴² é um conjunto especializado de capacidades organizacionais utilizadas para gerar valor à organização na forma de serviços. Dentre os artefatos existentes nesta seara destaca-se o Acordo de Nível de Serviço – ANS⁴³, documento que formaliza os requisitos e desempenho esperado pelos consumidores do serviço durante sua utilização.

Segundo o ITIL 4, framework que descreve as boas práticas de gestão de serviços de TI, existem práticas que devem ser adotadas e implantadas para um eficaz gerenciamento dos serviços de TI, dentre as quais, ressalta-se:

- Práticas de Gestão de Catálogo de Serviços;
- Práticas de Gestão de Configuração e Ativos de Serviços de TI;
- Práticas de Gestão de Incidentes de Serviços de TI;
- Práticas de Gestão de Nível de Serviço;
- Práticas da Continuidade dos Serviços de TI.

Para mensurar e avaliar a capacidade da organização em gerenciar os serviços de tecnologia da informação oferecidos pelo seu Setor de TI, foi utilizado o Questionário de Governança e Gestão de TI, submetido por meio do TSID03, que possui itens de verificação acerca da adoção das melhores práticas de gestão de serviços por parte da organização.

Por fim, considerou-se, ainda, os esclarecimentos informados pelos jurisdicionados mediante a resposta ao TSID04, que solicitou os comentários do gestor, conforme descrito na seção 3.4 do relatório.

As questões presentes no Questionário de Governança e Gestão de TI que foram verificadas para a conflagração deste achado são:

- 2121: "a organização executa processo de gestão do catálogo de serviços";
- 2123: "a organização executa processo de gestão de configuração e ativos (de serviços de tecnologia da informação)";

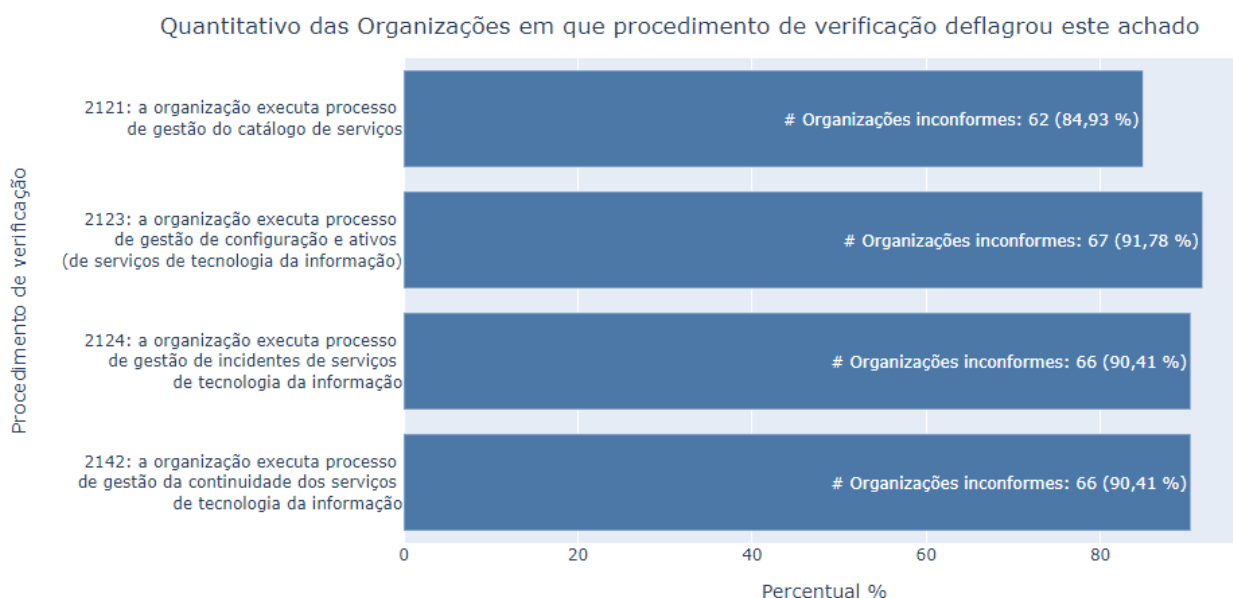
⁴² Gestão de serviço - conjunto de capacidades e processos para dirigir e controlar as atividades e recursos da organização para planejamento, desenho, transição, entrega e melhoria de serviços para entregar valor. ABNT NBR ISO/IEC 20000-1:2020, item 3.2.22.

⁴³ Acordo de nível de serviço (ANS) – acordo documentado entre a organização e o cliente que identifica os serviços e seu desempenho acordado. ABNT NBR ISO/IEC 20000-1:2020, item 3.2.20.

- 2124: "a organização executa processo de gestão de incidentes de serviços de tecnologia da informação";
- 2142: "a organização executa processo de gestão da continuidade dos serviços de tecnologia da informação".

A identificação de respostas do tipo "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" para as questões supracitadas foram consideradas situações incondizentes com as boas práticas preconizadas no ITIL 4.

Segue o resultado da aplicação dos procedimentos de verificação nas organizações do nível setorial do SETIC:



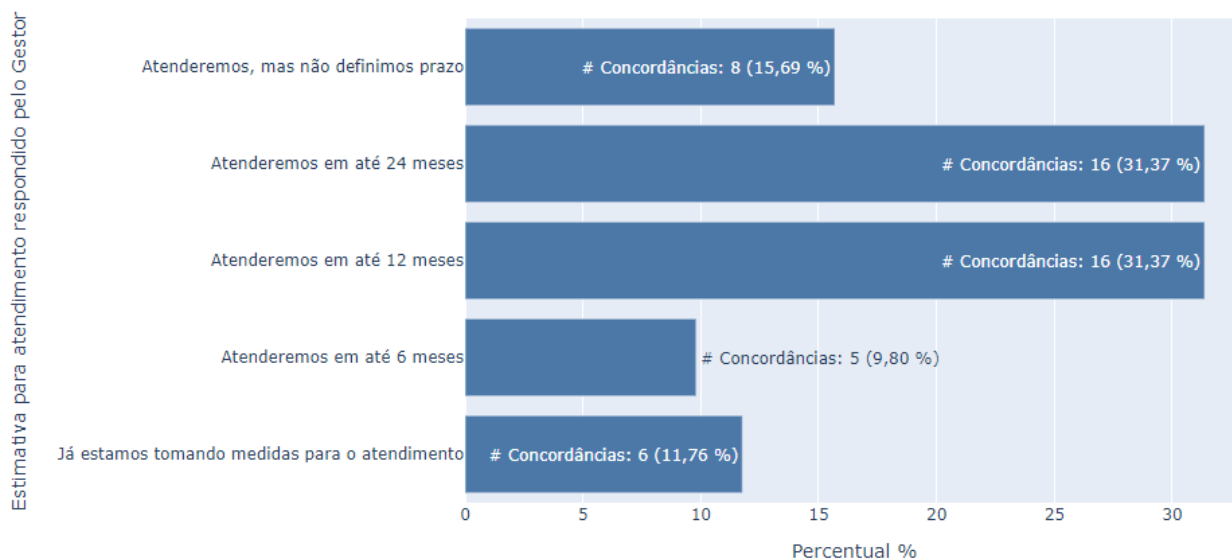
Verificou-se, após a realização dos procedimentos e da análise dos comentários dos gestores, que mais de 80% das organizações respondentes possuem práticas imaturas de gestão de serviço de TI.

Dos Comentários do Gestor

Em relação ao comentário dos gestores, podemos notar que houve plena concordância com o disposto na situação encontrada e no encaminhamento proposto.

Ademais, considerando apenas os comentários que exprimem concordâncias, vemos que a maior parte dos gestores estimam atender as propostas de

encaminhamento neste achado em até 24 meses, constituindo aproximadamente 84% dos comentários de anuência, como apresentado na figura a seguir:



Dessa forma, constata-se a existência de oportunidades de melhoria na adoção das melhores práticas para gestão de serviços de TI.

À vista disto, será incluída **RECOMENDAÇÃO** aos órgãos que compõem o NSTIC, na proposta de encaminhamento deste relatório, para que estruturam a gestão de serviços de TI, observando as boas práticas presentes na Norma Técnica ABNT NBR ISO/IEC 20000-1/2020 e 20000-2/2021, bem como no ITIL 4 e COBIT 2019.

4.3.4.4 Causas

- Não investigadas.

4.3.4.5 Efeitos

- Falta de controle sobre os riscos, custos, qualidade e desempenho dos serviços de TI, afetando a confiabilidade e a segurança da informação;
- Desperdício de recursos, tempo e dinheiro em iniciativas de TI que não agregam valor ou não atendem às necessidades dos usuários e clientes;
- Falta de transparência acerca das atividades desempenhadas pela TI;
- Falta de controle no cumprimento dos acordos de nível serviços de TI;
- Falhas e interrupções recorrentes nos serviços de TI prestados pela organização;

- Demora na recuperação de falhas nos serviços de TI;
- Falta de conhecimento acerca dos erros, problemas e incidentes mais frequentes nos serviços de TI da organização.

4.3.4.6 Propostas de encaminhamento

- **Comunicação com Recomendação** às organizações a seguir arroladas para que, observando as boas práticas de gestão de serviços de TI elencadas no item 8.2.4 – Gerenciamento de catálogo de serviço da Norma Técnica ABNT NBR ISO/IEC 20000-1/2020 e 20000-2/2021, item 5.2.10 - *Service catalogue management* (Gerenciamento de catálogo de serviço – tradução livre) do ITIL 4 e APO09 – *Managed Service Agreements* (Acordos de serviços gerenciados – tradução livre) do COBIT 2019:
 - elaborem e documentem seu processo de gestão de catálogo de serviços de TI, definindo indicadores e metas que permitam monitorar sua execução e propiciar sua melhoria contínua, e atribua um dono responsável ao processo para garantir sua eficácia e eficiência;
 - elaborem catálogo dos serviços de TI prestados pela área de tecnologia da informação da organização, contendo, ao menos, as descrições de cada um dos serviços, seus nomes, metas de níveis de serviço, forma de acesso e perfil do solicitante, em linguagem clara e objetiva, assegurando que ele seja de fácil acesso, atualizado periodicamente e amplamente disponível para seus usuários;

Organizações: AGENERSA, AGETRANSP, CEASA, CECIERJ, CEHAB, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, FAETEC, FAPERJ, FIA/RJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, IEEA, INEA, IO, IPEM/RJ, IRM, ISP, ITERJ, IVB, JUCERJA, LOTERJ, PESAGRO, PGE, PROCON, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV, SEPLAG, SEPM, SERGB, SETD, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

- **Comunicação com Recomendação** às organizações a seguir arroladas para que, observando as boas práticas de gestão de serviços de TI elencadas no item 8.2.5 - Gerenciamento de ativos e 8.2.6 – Gerenciamento de configuração da Norma Técnica ABNT NBR ISO/IEC 20000-1/2020 e 20000-2/2021, itens 5.2.6 - *IT asset management* (Gerenciamento de ativos de TI – tradução livre) e 5.2.11 *Service configuration management* (Gerenciamento de ativos de TI – tradução livre) do ITIL4:
 - elaborem e documentem seu processo de gestão de configuração e ativos de TI, definindo indicadores e metas que permitam monitorar sua execução e propiciar sua melhoria contínua, e atribua um dono responsável ao processo para garantir sua eficácia e eficiência;
 - estabeleçam base de dados consolidada que contenha registro dos ativos e itens de configuração que são mapeados e gerenciados pela organização, preferencialmente sob uma solução de TI, assegurando que seja permitido analisar o histórico das informações e que os dados sejam atualizados periódica e automaticamente;

Organizações: AGENERSA, AGERIO, AGETRANSP, CEASA, CECIERJ, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IEEA, INEA, IO, IPEM/RJ, IRM, ISP, ITERJ, IVB, LOTERJ, PESAGRO, PGE, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV, SEIC, SEPLAG, SEPM, SERGB, SES, SETD, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

- **Comunicação com Recomendação** às organizações a seguir arroladas para que, observando as boas práticas de gestão de serviços de TI elencadas no item 8.6.1 - Gerenciamento de incidente da Norma Técnica ABNT NBR ISO/IEC 20000-1/2020 e 20000-2/2021, item 5.2.5 - *Incident management* (Gerenciamento de incidentes – tradução livre) do ITIL 4 e DSS02 – *Managed Service Requests and Incident* (Requisições de serviço e incidentes gerenciados – tradução livre) do COBIT 2019:

- elaborem e documentem seu processo de gestão de incidentes de TI, definindo indicadores e metas que permitam monitorar sua execução e propiciar sua melhoria contínua, e atribua um dono responsável ao processo para garantir sua eficácia e eficiência;
- estabeleçam base de dados consolidada que contenha registro dos incidentes de TI e que permita que eles sejam identificados, registrados, classificados e resolvidos, preferencialmente sob uma solução informatizada;
- elaborem base de conhecimento de erros mais frequentes e conhecidos;

Organizações: AGENERSA, AGETRANSP, CEASA, CECIERJ, CEHAB, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IEEA, INEA, IO, IPER/RJ, IRM, ISP, ITERJ, IVB, LOTERJ, PESAGRO, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV, SEIC, SEPLAG, SEPM, SERGB, SES, SETD, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

- **Comunicação com Recomendação** às organizações a seguir arroladas para que, observando as boas práticas de gestão de serviços de TI elencadas no item 8.7.2 - Gerenciamento de continuidade de serviço da Norma Técnica ABNT NBR ISO/IEC 20000-1/2020 e 20000-2/2021, item 5.2.12 - *Service continuity management* (Gerenciamento de continuidade de serviços – tradução livre) do ITIL 4 e DSS04 – *Managed Continuity* (Continuidade gerenciada – tradução livre) do COBIT 2019:
 - elaborem e documentem seu processo de gestão de continuidade de serviços de TI, definindo indicadores e metas que permitam monitorar sua execução e propiciar sua melhoria contínua, e atribua um dono responsável ao processo para garantir sua eficácia e eficiência;
 - elaborem plano de continuidade dos serviços de TI, definindo os riscos que foram identificados, avaliados e registrados pela análise de impacto ao negócio (BIA), procedimentos a serem implementados no evento de uma

interrupção significativa e procedimentos a serem executados para o retorno às condições normais de trabalho;

Organizações: AGENERSA, AGETRANSP, CEASA, CECIERJ, CEHAB, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IEEA, INEA, IO, IPER/RJ, IRM, ITERJ, IVB, JUCERJA, LOTERJ, PESAGRO, PGE, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV, SEPLAG, SEPM, SERGB, SES, SETD, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

4.3.5. Achado 05 – Práticas de gestão de segurança da informação incipientes

4.3.5.1 Critérios

- Decreto-Lei nº 200/67, art. 6º, V, princípio do controle;
- Instrução Normativa PRODERJ nº 02/2022, art. 9º;
- Instrução Normativa PRODERJ nº 02/2022, art. 11 e incisos;
- Norma Técnica ABNT NBR ISO/IEC 27002/2022:
 - Controle 5.1 - Política de Segurança da Informação (PSI);
 - Controle 8.7 – Proteção contra *malware*;
 - Controle 8.13 - Backup das informações;
 - Controle 8.16 - Atividades de monitoramento;
- Controles CIS v8:
 - Controle 8 – Gestão de registros de auditoria;
 - Controle 10 – Defesas contra *malware*;
 - Controle 11 - Recuperação de dados;
 - Controle 13 – Monitoramento e defesa da Rede;
- Acórdão TCE-RJ nº 10.168/2023-Plenário, item 1.8;
- Acórdão TCE-RJ nº 59.337/2023-Plenário, item 3.3;
- Processo TCE-RJ nº 212.981-7/2017, Decisão Plenária de 08/05/2018, item VII, a), 2.

4.3.5.2 Evidências

- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 2151 do Questionário de Governança e Gestão de TI⁴⁴, submetido pelo TSID03, para verificar a adoção da prática "a organização dispõe de uma política de segurança da informação";
- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 2153 do Questionário de Governança e Gestão de TI⁴⁵, submetido pelo TSID03, para verificar a adoção da prática "a organização possui um gestor institucional de segurança da informação";
- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 2154 do Questionário de Governança e Gestão de TI⁴⁶, submetido pelo TSID03, para verificar a adoção da prática "a organização possui um responsável pelo tratamento e resposta a incidentes";
- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 1024 do Questionário de Governança e Gestão de TI⁴⁷, submetido pelo TSID03, para verificar a adoção da prática "a organização atende a Instrução Normativa PRODERJ/PRE nº 02/2022 expedida pelo Diretor Geral do SETIC (PRODERJ)";
- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 2166 do Questionário de Governança e Gestão de TI⁴⁸, submetido pelo TSID03, para verificar a adoção da prática "a organização executa atividades de gestão da segurança dos recursos de processamento da informação, inclusive dos recursos de computação em nuvem".

4.3.5.3 Situação Encontrada

⁴⁴ Presente no Anexo 008 do relatório.

⁴⁵ Presente no Anexo 008 do relatório.

⁴⁶ Presente no Anexo 008 do relatório.

⁴⁷ Presente no Anexo 008 do relatório.

⁴⁸ Presente no Anexo 008 do relatório.

A segurança da informação é um tema de suma relevância no contexto das organizações que empregam esforços em prol da transformação digital. Em nosso país, faz-se necessário considerar os riscos envolvidos no manuseio das informações digitalizadas, visto que quase a metade dos dados vazados no mundo são dados brasileiros, conforme estudo⁴⁹ apontado pela empresa norte americana Tenable.

Em outro estudo⁵⁰ recente realizado pela Unit 42, grupo de pesquisa da Palo Alto Networks, mostra-se que o Brasil é o país mais atacado por “ransomware”⁵¹ na América Latina pelo segundo ano consecutivo, com um aumento de 51% em relação ao ano passado. Ainda, uma pesquisa⁵² elaborada pela Sophos constatou que “o Brasil lidera o *ranking* mundial de pagamento de resgates, com 55% das empresas entrevistadas no país admitindo o rendimento à extorsão em troca de sistemas descriptografados.”

Nesse cenário, sobleva-se a importância da Norma Técnica ABNT NBR ISO/IEC 27002:2022 que tem como objetivo agrupar um conjunto de controles e boas práticas para apoiar a implementação de um Sistema de Gestão de Segurança da Informação (SGSI) nas organizações. Ela pode ser usada como um documento de orientação para determinar e implementar os controles de segurança comumente aceitos no mercado.

Tal dispositivo foi projetado para organizações de todos os tipos e tamanhos, incluindo setor público e privado, comercial e sem fins lucrativos, que coletam, tratam, armazenam, transmitem e descartam informações de diversas formas, incluindo eletrônica, física e verbal, como, por exemplo, conversas e apresentações.

De acordo com a norma supracitada, a segurança da informação é alcançada por meio da implementação de um conjunto adequado de controles, que inclui: políticas, regras, processos, procedimentos, estruturas organizacionais e funções de *hardware* e *software*.

⁴⁹ Disponível em: <<https://www.hardware.com.br/noticias/2023-05/quase-metade-dos-dados-vazados-no-mundo-sao-brasileiros-indica-estudo.html>>. Acesso em: 26 jun 2023.

⁵⁰ Disponível em: <<https://www.cisoadvisor.com.br/brasil-e-o-pais-mais-atacado-por-ransomware-na-al-pelo-2o-ano/>>. Acesso em: 26 jun 2023

⁵¹ Ransomware é um *software* malicioso que pode bloquear o computador da vítima e depois exigir um valor em dinheiro pelo resgate, geralmente por meio de moedas virtuais que dificultem o seu rastreamento. Maiores informações sobre o assunto podem ser encontradas na cartilha de segurança cert.br (Centro de Estudos, Resposta e Tratamento de Incidentes de Segurança no Brasil) em: <<https://cartilha.cert.br/ransomware/>>. Acesso em: 27 jun 2023

⁵² Disponível em: <https://www.securityreport.com.br/brasil-lidera-pagamento-de-resgate-de-ransomwre/#.ZF0dFaRv_qs>. Acesso em: 26 jun 2023

Outra fonte de moderação da segurança da informação são os Controles CIS v8⁵³. Essa publicação reflete o conhecimento combinado de especialistas da área, como times de respostas, analistas de ameaças, pesquisadores de vulnerabilidades, fabricantes de ferramentas, provedores de soluções, formuladores de políticas e auditores, em organizações públicas e privadas, de diversos setores como defesa, finanças, transporte e academia.

No âmbito do controle externo, os Controles CIS v8 já foram utilizados pelo TCU em fiscalização sobre procedimentos de *back-up* na administração pública federal⁵⁴.

Sobre o aspecto da atuação desta Corte de Contas na temática de Segurança da Informação, ressalta-se que a ausência de uma PSI já foi debatida em outros processos⁵⁵. Em uma auditoria de conformidade sobre a adequação dos municípios jurisdicionados à Lei Geral de Proteção dos Dados (LGPD) ⁵⁶, o Corpo Instrutivo destacou a ausência de uma PSI em diversos municípios. Em decisão unânime, o Plenário acompanhou o Corpo Instrutivo e Parquet de Contas, conforme voto abaixo:

Por COMUNICAÇÃO aos atuais prefeitos dos municípios elencados a seguir, nos termos do art. 26 do Regimento Interno deste Tribunal, conferindo-lhe ciência acerca do inteiro teor dos presentes autos e para que adote providências quanto à seguintes **determinações**:

(...)

1.8. **Elaborar a Política de Segurança da Informação** contendo, ao menos, um subconjunto das seguintes características: orientação e apoio da direção do órgão sobre a segurança da informação, alinhando-se de acordo com os requisitos de negócio e com as leis e regulamentações relevantes; declarações acerca dos objetivos e princípios a serem usados para orientar todas as atividades relativas à segurança da informação; atribuição de papéis e responsabilidades e um processo para tratamento dos desvios e exceções; tópicos específicos como controle de acesso aos sistemas, classificação e tratamento da informação, segurança física e lógica do ambiente, backup de dados e controles criptográficos. (ACHADO 08).

⁵³ <https://www.cisecurity.org/controls/v8>. Acessado em 18/11/2023

⁵⁴ <https://pesquisa.apps.tcu.gov.br/redireciona/acordao-completo/ACORDAO-COMPLETO-2473503>. Acessado em 18/11/2023

⁵⁵ **Referência:** Acórdão TCE-RJ nº 10.168/2023 -Plenária de 30/01/2023, Processo 206.972-5/2022 – Item 1.8, Acórdão TCE-RJ nº 14.109/2021 - Plenária de 08/05/2018, Processo TCE-RJ nº 212.981-7/2017, Acórdão TCE-RJ nº 142.036/2022 - Plenária de 12/09/2022, Processo TCE-RJ nº 238.096-8/2019.

⁵⁶ **Referência:** Acórdão TCE-RJ nº 10.168/2023 -Plenária de 30/01/2023, Processo 206.972-5/2022 – Item 1.8.

(grifos e negritos nossos)

Em outra decisão desta Corte de Contas, o Plenário decidiu da seguinte forma⁵⁷:

VII – pela COMUNICAÇÃO, nos termos do § 1º do art. 6º da Deliberação TCE-RJ nº 204/96, ao atual Prefeito Municipal de Nova Friburgo, a fim de que:

a) cumpra as **DETERMINAÇÕES** a seguir, comprovando as medidas adotadas junto a este Tribunal:

(...)

2 - **Elaborar e divulgar a Política de Segurança da Informação** da administração municipal, consoante o previsto no item 5.1.1 da Norma NBR ISO/IEC 27002:2005 (achado 2).

(grifos nossos)

Dessa forma, considerando o conjunto reiterado de decisões sobre a necessidade de criação de uma PSI, esta Corte de Contas demonstra a importância desse artefato para as instituições públicas. Sua ausência pode ensejar em sistemas desprotegidos, onde a confidencialidade, integridade e disponibilidade das informações não são garantidas.

No contexto do SETIC, a temática em tela é tratada pela Instrução Normativa PRODERJ nº 02/2022 e seu Anexo Único. Tal normativo regulamenta os procedimentos de segurança da informação a serem adotados pelos Órgãos Setoriais do SETIC. Insta salientar que é prerrogativa do Diretor Geral do SETIC a normatização dos aspectos de segurança da informação nos órgãos setoriais, conforme preconiza o art. 5º, inciso XVIII, alínea c, do Decreto nº 47.278/2020⁵⁸.

A instrução normativa em tela estabelece os papéis do Gestor de Segurança da Informação e do Responsável pelo Tratamento e Resposta a Incidentes.

Nesse sentido, o art. 17 e seus incisos trazem as competências do Gestor de Segurança da Informação, *in verbis*:

Art. 17 - Compete ao Gestor de Segurança da Informação dos órgãos e entidades:

⁵⁷ Processo TCE-RJ nº 212.981-7/2017, decisão de 08/05/2018.

⁵⁸ Art. 5º - Compete ao nível de Direção Geral, representado pelo PRODERJ:

(...)

XVIII - disciplinar, por meio de atos, regulamentos e instruções normativas: (...)

c) a segurança das informações sob a responsabilidade da administração estadual;

- I - elaborar e atualizar periodicamente os procedimentos de segurança da informação do órgão/entidade que seja responsável;
- II - implementar e monitorar permanentemente os mecanismos e procedimentos relacionados à segurança da informação, com o intuito de preservar a integridade, a confidencialidade e a privacidade dos dados sob a guarda e responsabilidade dos órgãos e entidades;
- III - promover a cultura de segurança da informação no âmbito de atuação do órgão ou entidade elaborador;
- IV - acompanhar eventos e danos decorrentes de incidentes e eventos de segurança da informação;
- V - compartilhar com os demais órgãos e entidades da Administração Pública Estadual, os eventos de segurança, após ocorrência, para fins de prevenção, bem como as eventuais soluções, para fins de replicação de conhecimentos e experiências;
- VI - propor recursos necessários às ações de segurança da informação, no âmbito de atuação do seu órgão ou entidade; e
- VII - indicar os responsáveis pelo tratamento de resposta a incidentes no âmbito de atuação do órgão ou entidade elaborador.

Já o artigo 18 dispõe sobre as atribuições do Responsável pelo Tratamento e Resposta a Incidentes, *in verbis*:

Art. 18 - Compete ao Responsável pelo Tratamento e Resposta a Incidentes:

- I - monitorar os recursos de TIC, detectar e realizar as análises dos incidentes de segurança da informação;
- II - reportar ao Encarregado pelo Tratamento de Dados Pessoais os incidentes envolvendo tais dados;
- III - identificar vulnerabilidades;
- IV - receber e propor respostas a notificações relacionadas a incidentes de segurança da informação; e
- V - coordenar e executar atividades de tratamento e resposta a eventos de segurança da informação.

Diante das relevantes funções desempenhadas por esses dois atores, a norma dispõe, no artigo 11, inciso VI, alíneas a e b, que os órgãos estaduais devem definir o Gestor de Segurança da Informação e o Responsável pelo Tratamento e Resposta a Incidentes, respectivamente.

Ademais, com vistas a assegurar a atuação dos órgãos estaduais em segurança da informação, o artigo 9º do regulamento em tela obriga tais organizações a “manter

procedimentos de segurança da informação, com normas claras, objetivas, revisadas e divulgadas regularmente, com base nas diretrizes estabelecidas neste instrumento e nos normativos do órgão de Direção Geral do SETIC”.

Sobre o aspecto dos procedimentos de segurança da informação, o Anexo Único confere um manual de tais condutas, pautando-se em normas e documentos de referência nesse tema como a ABNT NBR ISO/IEC 27001:2013, ABNT NBR ISO/IEC 27002:2013, LGPD e outros.

Nesse diapasão, o conjunto de procedimentos aborda o controle de acesso, o *backup*, a gestão de ativos, o tratamento de incidentes e outros controles relevantes e presentes na ABNT NBR ISO/IEC 27002:2022 e nos Controles CIS v8.

No presente trabalho, para mensurar e avaliar a capacidade da organização em gerenciar a segurança da informação, foi utilizado o Questionário de Governança e Gestão de TI, submetido por meio do TSID03, que possui itens de verificação acerca da adoção das melhores práticas de gestão de segurança da informação por parte da organização.

Por fim, considerou-se, ainda, os esclarecimentos informados pelos jurisdicionados mediante a resposta ao TSID04, que solicitou os comentários do gestor, conforme descrito na seção 3.4 do relatório.

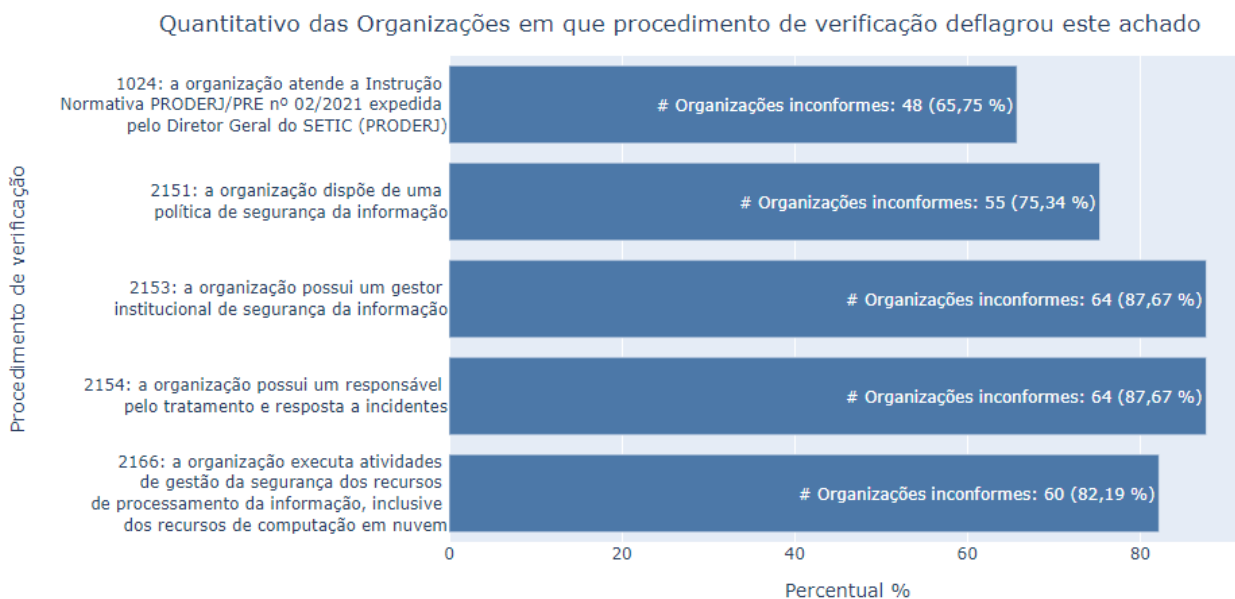
As questões presentes no Questionário de Governança e Gestão de TI que foram verificadas para a conflagração deste achado são:

- 2151: "a organização dispõe de uma política de segurança da informação";
- 2153: "a organização possui um gestor institucional de segurança da informação";
- 2154: "a organização possui um responsável pelo tratamento e resposta a incidentes";
- 1024: "a organização atende a Instrução Normativa PRODERJ/PRE nº 02/2022 expedida pelo Diretor Geral do SETIC (PRODERJ)";
- 2166: "a organização executa atividades de gestão da segurança dos recursos de processamento da informação, inclusive dos recursos de computação em nuvem".

A identificação de respostas do tipo "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" para as questões supracitadas

foram consideradas situações incondizentes com as boas práticas preconizadas na ABNT NBR ISO/IEC 27002:2022 e nos Controles CIS v8, bem como com os dispositivos estabelecidos na Instrução Normativa PRODERJ/PRE nº 02/2022.

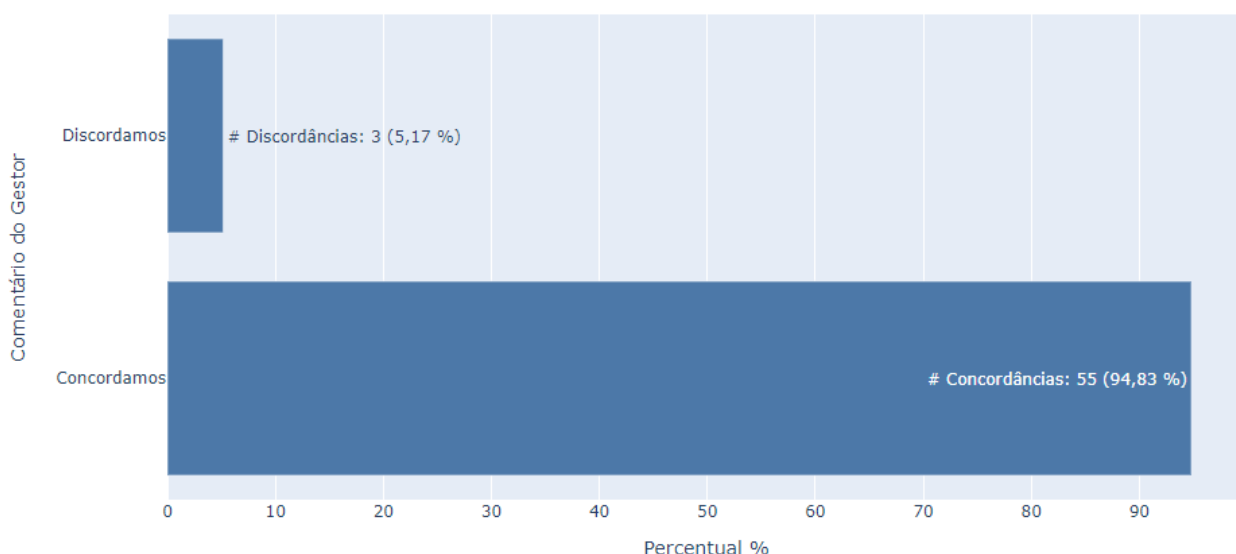
Segue o resultado da aplicação dos procedimentos de verificação nas organizações do nível setorial do SETIC:



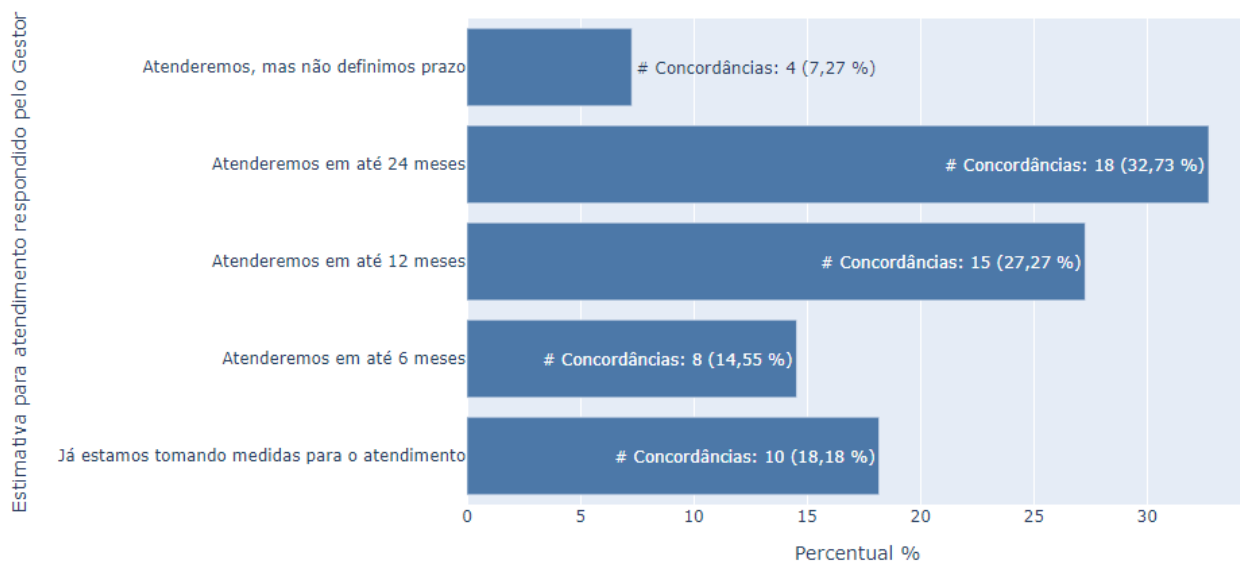
Verificou-se, após a realização dos procedimentos e da análise dos comentários dos gestores, que mais de 60% das organizações respondentes não estão em conformidade com a Instrução Normativa PRODERJ/PRE nº 02/2022. Além disso, mais de 65% das organizações respondentes apresentam imaturidade nas práticas de segurança da informação.

Dos Comentários do Gestor

Em relação ao comentário dos gestores, podemos notar que houve ampla concordância com o disposto na situação encontrada e no encaminhamento proposto, constituindo aproximadamente 94,8% das respostas para este achado, como apresentado na figura a seguir:



Ademais, considerando apenas os comentários que exprimem concordâncias, vemos que a maior parte dos gestores estimam atender as propostas de encaminhamento neste achado em até 24 meses, constituindo aproximadamente 93% dos comentários de consentimento, como apresentado na figura a seguir:



Dessa forma, constata-se a existência de oportunidades de melhoria na adoção das melhores práticas para gestão de segurança da informação.

À vista disto, será incluída **DETERMINAÇÃO e RECOMENDAÇÃO** aos órgãos que compõem o NSTIC, na proposta de encaminhamento deste relatório, para que estruturem a gestão de segurança da informação, observando as boas práticas

presentes na Norma Técnica ABNT NBR ISO 27002/2022, bem como os procedimentos dispostos na Instrução Normativa PRODERJ/PRE nº 02/2022.

4.3.5.4 Causas

- Não investigadas.

4.3.5.5 Efeitos

- Violação da confidencialidade, integridade e disponibilidade dos dados e sistemas, resultando em perda de credibilidade, reputação e confiança;
- Exposição a riscos legais, regulatórios e contratuais, podendo acarretar multas, sanções e processos judiciais;
- Comprometimento da continuidade dos negócios, afetando a capacidade de entrega de valor e de atendimento às expectativas dos clientes e usuários;
- Uso inadequado de recursos computacionais.

4.3.5.6 Propostas de encaminhamento

- **Comunicação com Determinação** às organizações a seguir arroladas para que:
 - elaborem, aprovem e publiquem a Política de Segurança da Informação (PSI), alinhada à Instrução Normativa PRODERJ/PRE nº 02/2022, e adotem as boas práticas estabelecidas na Norma Técnica NBR ISO/IEC 27002/2022, dispondo, ao menos, de princípios, diretrizes, procedimentos, responsabilidades, competências e outros controles que julgarem necessários para garantir de forma razoável a segurança da informação de sua organização;
 - elaborem e mantenham procedimentos de segurança da informação, com normas claras, objetivas, revisadas e divulgadas regularmente, com base nas diretrizes estabelecidas na Instrução Normativa PRODERJ nº 02/2022, acompanhada de seu Anexo, e nos normativos do órgão de Direção Geral do Sistema Estadual de Tecnologia da Informação e Comunicação - SETIC;

Organizações: AGENERSA, AGETRANSP, CEASA, CECIERJ, CEHAB, CENTRAL, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IEEA, INEA, IO, IPEM/RJ, IRM, ITERJ, IVB, LOTERJ, PESAGRO, PGE, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEPLAG, SEPM, SERGB, SES, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

- **Comunicação com Determinação** às organizações a seguir arroladas para que conforme preceitua o art. 11, inc. VI, alínea a, da Instrução Normativa PRODERJ nº 02/2022 e o disposto no controle 5.2 - Papéis e responsabilidades pela segurança da informação - da Norma Técnica NBR ISO/IEC 27002/2022:
 - designem formalmente um Gestor de Segurança da Informação dentre os servidores públicos civis ou militares ocupantes de cargos efetivos, desde que lotados no órgão ou entidade e com formação ou capacitação técnica compatível às suas atribuições, na forma do § 1º do art. 17 da Instrução Normativa PRODERJ nº 02/2022, com, no mínimo, as competências arroladas nos incisos do art. 17 do mesmo normativo;

Organizações: AGENERSA, AGETRANSP, CEASA, CECIERJ, CEHAB, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IEEA, INEA, IO, IPEM/RJ, IRM, ISP, ITERJ, IVB, JUCERJA, LOTERJ, PESAGRO, PGE, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV, SEPLAG, SEPM, SERGB, SES, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

- **Comunicação com Determinação** às organizações a seguir arroladas para que conforme preceitua o art. 11, inc. VI, alínea b, da Instrução Normativa PRODERJ nº 02/2022 e disposto no controle 5.2 - Papéis e responsabilidades pela segurança da informação - da Norma Técnica NBR ISO/IEC 27002/2022:

- designem formalmente um Responsável pelo Tratamento e Resposta a Incidentes dentre os servidores públicos civis ou militares ocupantes de cargos efetivos, desde que lotados no órgão ou entidade e com formação ou capacitação técnica compatível às suas atribuições, na forma do § 1º do art. 18 da Instrução Normativa PRODERJ nº 02/2022, com, no mínimo, as competências arroladas nos incisos do art. 18 do mesmo normativo;

Organizações: AGENERSA, AGETRANSP, CEASA, CECIERJ, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IEEA, INEA, IO, IPER/RJ, IRM, ISP, ITERJ, IVB, JUCERJA, LOTERJ, PESAGRO, PGE, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV, SEPM, SERGB, SES, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

- **Comunicação com Recomendação** às organizações a seguir arroladas para que considerem adotar nos seus procedimentos de segurança da informação, conforme elencado no art. 9º da Instrução Normativa PRODERJ nº 02/2022, as atividades a seguir:
 - mantenham, monitorem e analisem logs de auditoria dos ativos de software, de hardware e de rede críticos para o negócio;
 - implementem defesas contra malware e outras ameaças cibernéticas;
 - implementem cópias regulares de segurança (backup) das informações em meio digital, incluindo a realização periódica de testes de recuperação das informações.

Organizações: AGERIO, AGETRANSP, CEASA, CECIERJ, CEHAB, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, IEEA, INEA, IPER/RJ, IRM, ITERJ, IVB, LOTERJ, PESAGRO, PGE, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA,

SECC, SECEC, SEDSODH, SEEDUC, SEELJE, SEGOV, SEIC, SEPLAG, SEPM, SERGB, SES, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

4.3.6. Achado 06 – Gestão de recursos humanos de TI inadequada

4.3.6.1 Critérios

- Constituição Federal de 1988, art. 37, princípio da impessoalidade, da moralidade, da eficiência, e inciso V;
- Lei Federal nº 14.133/2021, art. 7º, caput;
- Lei Federal nº 14.204/2021, art. 9º e 10;
- Decreto Federal nº 10.829/2021, art. 15 e 16;
- Decreto Federal nº 10.024/2019, art. 16, § 3º;
- Portaria SEGES/ME nº 8.678/2021, art. 14 e seus incisos;
- Resolução CNJ nº 240/2016, art. 3º, XI, e 5º, V e VI;
- Resolução CNJ nº 347/2020, art. 27 e seus incisos;
- COBIT 2019, APO07 – Recursos Humanos Gerenciados, prática APO07.01 - Adquirir e manter pessoal adequado e apropriado, prática APO07.02 – Identificar pessoal chave de TI; APO07.03 - Manter as habilidades e competências dos recursos humanos;
- ITIL 4, item 5.1.14 – Gerenciamento de força de trabalho e talentos;
- Referencial Básico de Governança Organizacional para organizações pública e outros entes jurisdicionados ao TCU, 3ª Edição, princípios e diretrizes de governança para o setor público;
- Norma Técnica ABNT ISO/IEC 38.500/18, Item 4.1, princípio da conformidade;
- Acórdão TCE-RJ nº 053.123/2023-PLEN (Processo TCE-RJ nº 202.186/23);
- Acórdão nº 140/2005-TCU-Plenário, item 9.4;
- Acórdão nº 786/2006-TCU-Plenário, item 9.8;
- Acórdão nº 1603/2008-TCU-Plenário, item 9.1.2;
- Acórdão nº 2471/2008-TCU-Plenário, item 9.4.5;
- Acórdão nº 380/2011-TCU-Plenário, item 9.1.2;
- Acórdão nº 1233/2012-TCU-Plenário, item 9.13.1;

- Acórdão nº 1200/2014-TCU-Plenário, item 9.1;
- Acórdão n.º 3.023/2013-TCU-Plenário, item 9.1.1.4;
- Acórdão n.º 2.212/2015-TCU-Plenário, item 9.1.4.

4.3.6.2 Evidências

- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 2212 do Questionário de Governança e Gestão de TI⁵⁹, submetido pelo TSID03, para verificar a adoção da prática "os perfis profissionais desejados para cada ocupação ou grupo de ocupações de colaboradores da organização estão definidos e documentados";
- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 2221 do Questionário de Governança e Gestão de TI⁶⁰, submetido pelo TSID03, para verificar a adoção da prática "a escolha dos gestores ocorre segundo perfis profissionais previamente definidos e documentados";
- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 2231 do Questionário de Governança e Gestão de TI⁶¹, submetido pelo TSID03, para verificar a adoção da prática "as lacunas de competências dos colaboradores e gestores da organização são identificadas e documentadas";
- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 2232 do Questionário de Governança e Gestão de TI⁶², submetido pelo TSID03, para verificar a adoção da prática "as lacunas de competências dos colaboradores e gestores da organização são tratadas";
- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 2251 do Questionário de Governança e Gestão

⁵⁹ Presente no Anexo 008 do relatório.

⁶⁰ Presente no Anexo 008 do relatório.

⁶¹ Presente no Anexo 008 do relatório.

⁶² Presente no Anexo 008 do relatório.

- de TI⁶³, submetido pelo TSID03, para verificar a adoção da prática "a organização possui em sua estrutura cargos específicos para tecnologia da informação";
- Quadro geral⁶⁴ consolidado por meio das informações enviadas em atendimento ao item 03 do TSID02, verificando-se a ausência de pessoal com vínculo permanente no exercício de atividades de planejamento, coordenação, supervisão e controle da TI;
 - Quadro geral⁶⁵ consolidado por meio das informações enviadas em atendimento ao item 03 do TSID02, verificando-se a ausência de pessoal com vínculo permanente no exercício das atividades do Setor de TI;

4.3.6.3 Situação Encontrada

A fim de assegurar que a TI agregue valor à organização, julga-se importante que sejam avaliados um dos recursos organizacionais mais importantes, os recursos humanos.

O Tribunal de Contas da União tem realizado uma série de fiscalizações⁶⁶ que abordaram a estrutura de recursos humanos nos setores de TI na Administração Pública, externando assim a importância ao tema dado pela Colenda Corte de Contas Federal. Segue entendimento do relator disposto no longínquo Acórdão nº 140/2005-TCU-Plenário:

90. A meu ver, a carência de recursos humanos é o fator mais crítico na desestruturação da área de informática, como ficou demonstrado no caso do Ministério da Agricultura, que chegou ao ano de 1998 com apenas dois técnicos em sua lotação (item 10 retro). É a falta de pessoal que desencadeia a paralisia do setor, levando a uma série de outros problemas como a existência de sistemas sem manutenção, a demora em substituir equipamentos obsoletos, etc.

91. É certo que há amparo em lei para que se busque atenuar as deficiências de pessoal por meio da terceirização de diversas atividades, como o desenvolvimento de sistemas e o suporte ao usuário, entre outras. Lembre-se, contudo, que, antes de se desenvolver os sistemas, é necessário especificá-los; antes de se licitar a prestação de serviços de informática, é necessário elaborar

⁶³ Presente no Anexo 008 do relatório.

⁶⁴ Presente na pasta Achado 06 – Pessoal do Anexo 012 do relatório.

⁶⁵ Presente na pasta Achado 06 – Pessoal do Anexo 012 do relatório.

⁶⁶ Acórdãos do Plenário TCU nº 140/2005, nº 786/2006, nº 1603/2008, nº 2471/2008, nº 380/2011, nº 1233/2012, nº 1200/2014 e nº 2326/2017

um projeto básico que atenda aos interesses da Administração; antes de se dar por executado um contrato, é necessário que se tenha realizado seu acompanhamento e fiscalização; e, antes que todas essas tarefas se iniciem, é necessário formular um planejamento estratégico, que oriente as ações do setor.

92. Existe, pois, um núcleo de atividades de informática que são estratégicas: ou porque lidam com informações privilegiadas, ou porque tratam da fiscalização dos contratos, ou porque delas depende o funcionamento do próprio setor e das demais unidades que utilizam seus serviços, ou porque envolvem a tomada de decisão sobre a realização de despesas de vulto na aquisição de bens e contratação de serviços. Quando essas atividades não são regularmente executadas, as chances de serem causados prejuízos à Administração aumentam consideravelmente. Portanto, não é razoável que esses encargos sejam exercidos por servidores sem qualificação ou, dado o conflito de interesses, sejam “delegados” a pessoal terceirizado em razão das deficiências no quadro do órgão público.

(grifo nosso)

Do exercício de não-efetivos em atividades de gestão de TI

Nesse sentido, a Corte Federal vem reconhecendo a necessidade de as organizações aprimorarem a política de pessoal dos setores de TI com a finalidade de selecionar e manter profissionais capacitados no seu quadro permanente de pessoal⁶⁷ para o exercício das atividades específicas à gestão de TI, entre elas o planejamento, a coordenação, a supervisão e o controle, conforme § 7º do art. 10 do Decreto-Lei nº 200/1967.

Ademais, o COBIT 2019, *framework* de boas práticas de Governança e Gestão de Tecnologia da Informação, elenca no seu processo APO07 – *Managed Human*

⁶⁷ Acórdão TCU nº 2471/2008-Plenário, item 9.4.5:

9.4.5. adote as medidas necessárias para prover os setores de informática dos órgãos e entidades da Administração Pública Federal da estrutura organizacional e de quadro permanente de pessoal que sejam suficientes para realizar, de forma independente das empresas prestadoras de serviços, o planejamento, a definição, a coordenação, a supervisão e o controle das atividades de informática, com a finalidade de garantir a autoridade e o controle da Administração sobre o funcionamento daqueles setores. Deve ser avaliada a conveniência e a oportunidade da criação de carreira específica, semelhante ao ocorrido com as carreiras de Especialista em Meio Ambiente e a de Analista de Infra-Estrutura; (grifo nosso)

⁶⁸ Acórdão TCU nº 1200/2014-Plenário, itens 9.1:

9.1. informar aos órgãos governantes superiores, [...], indicam a necessidade de reformulação da política de pessoal de TI no que concerne à:

9.1.1. criação de cargos específicos da área de TI, distribuídos em carreira, de forma a propiciar a oportunidade de crescimento profissional;

9.1.2. atribuição das funções gerenciais exclusivamente a servidores ocupantes de cargos efetivos de TI;

Resources (Recursos humanos gerenciados – tradução livre) uma série de boas práticas que devem ser perseguidas pelas organizações a fim de prover uma abordagem estruturada para assegurar uma contratação, seleção, planejamento, avaliação e desenvolvimento ideais dos recursos humanos.

A prática APO07.01 - *Acquire and maintain adequate and appropriate staffing* (Adquirir e manter pessoal adequado e apropriado – tradução livre) preconiza que a organização deve realizar avaliações regulares dos requisitos de pessoal, de forma a garantir que haja recursos humanos suficientes para apoiar os objetivos e metas de negócio da instituição. Segundo a prática APO07.02 – *Identify key IT personnel* (Identificar pessoal chave de TI – tradução livre), a organização deve identificar o pessoal chave de TI, minimizando a dependência de um único indivíduo desempenhando uma função de trabalho crítica através da captura de conhecimento (documentação), compartilhamento de conhecimento, planejamento sucessório, equipe reserva, treinamento cruzado e iniciativas de rotação de tarefas, entre outras atividades.

Cabe destacar a adoção destas práticas para minimizar a dependência da organização de agentes externos do seu quadro permanente de pessoal, como as prestadoras de serviços contratadas ou cargos exclusivamente comissionados.

Decorre das boas práticas de governança do setor público que seja estabelecido uma governança de pessoas, definindo mecanismos de avaliação, direcionamento e monitoramento da gestão de pessoas para garantir que o capital humano agregue valor ao negócio da organização.

O Referencial Básico de Governança Organizacional do TCU destaca que a boa governança é um direito do cidadão e que para alcançá-la cabe às organizações atenderem uma série de diretrizes, tais como:

- d) aprimorar a capacidade da liderança da organização, garantindo que seus membros tenham habilidade, conhecimentos e experiências necessários ao desempenho de suas funções; avaliando o desempenho deles como indivíduos e como grupo; e equilibrando, na composição da liderança, continuidade e renovação;
- e) desenvolver continuamente a capacidade da organização, assegurando a eficácia e eficiência da gestão dos recursos organizacionais, como a gestão e a sustentabilidade do orçamento, das pessoas, das contratações e da tecnologia e segurança da informação;

o) editar e revisar atos normativos, pautando-se pelas boas práticas regulatórias e pela legitimidade, estabilidade e coerência do ordenamento jurídico e realizando consultas públicas, sempre que conveniente
(Referencial Básico de Governança Organizacional para organizações pública e outros entes jurisdicionados ao TCU. Capítulo 4. Princípios e Diretrizes)
(grifo nosso)

Alinhando-se às práticas apresentadas no COBIT e às boas práticas de governança do setor público, tem-se o entendimento disposto em Acórdãos⁶⁹ do TCU sobre a necessidade das atividades de planejamento, coordenação, supervisão e controle de informática serem exercidas por servidores do quadro permanente da organização.

Nesse diapasão, julga-se imprescindível que a Administração disponha de um quadro permanente de pessoal de TI suficiente e qualificado para atender as necessidades e demandas dos diversos setores, atentando-se para que as atividades gerenciais sejam exercidas por pessoal do quadro próprio.

Da definição de perfis profissionais ou competências às ocupações de TI

De maneira análoga, em que pese o provimento dos cargos em comissão ou funções de confiança dos gestores ser de natureza de livre provimento, entende-se que possam ser definidos um conjunto de diretrizes, processos e/ou mecanismos de controle que visem assegurar a adoção dos princípios da boa governança⁷⁰, dentre eles integridade e transparência, e da Administração Pública, tais como moralidade, impessoalidade, legitimidade e eficiência.

Portanto, julga-se necessário definir formalmente os perfis (requisitos) necessários para o exercício das ocupações de gestão e operação de TI, independentemente dos vínculos dos profissionais de TI, cargos efetivos ou cargos em comissão.

Nessa linha, a Norma Técnica ABNT ISO/IEC 38.500/2018, que fornece princípios, definições e um modelo para as estruturas de governança avaliarem, direcionarem e monitorarem o uso da TI em suas organizações, apresenta o princípio da

⁶⁹ Acórdão TCU nº 786/2006-Plenário, item 9.8; Acórdão TCU nº 2471/2008-Plenário, item 9.4.5; Acórdão TCU nº 1330/2008-Plenário, item 9.1.7; Acórdão nº 380/2011-Plenário, item 9.2.3; Acórdão nº 1200/2014-Plenário, item 9.1.2.

⁷⁰ Referencial Básico de Governança Organizacional para organizações pública e outros entes jurisdicionados ao TCU, 3ª Edição, 2020. Princípios de governança para o setor público, página 44.

conformidade que explicita a necessidade de formalizar as políticas e práticas da organização:

“o uso da TI atende a todas as leis e regulamentos obrigatórios. políticas e práticas são claramente definidas, implementadas e aplicadas.”

ABNT ISO/IEC 38.500/2018. Item 4.1. Princípio da conformidade.

(grifo nosso)

São descritas também orientações e práticas requeridas para implementar os princípios elencados na norma. Dentre essas:

- Convém que as estruturas de governança avaliem a competência dos responsáveis pelas tomadas de decisões relacionadas à TI.
- Convém que as estruturas de governança avaliem regularmente a conformidade interna da organização com o seu quadro de referência (*framework*) de governança da TI.
- Convém que as estruturas de governança direcionem que todas as ações relacionadas à TI sejam éticas.

Entendimento postulado também pelo COBIT 2019 em seu processo APO07⁷¹ – *Managed Human Resources* (Recursos humanos gerenciados – tradução livre), que provê uma abordagem estruturada para assegurar a aquisição, seleção, planejamento, avaliação e desenvolvimento ideais dos recursos humanos com o objetivo de otimizar suas capacidades a fim de atender aos objetivos institucionais.

A prática APO07.03 - *Maintain the skills and competencies of personnel* (Manter as habilidades e competências dos recursos humanos – tradução livre) destaca a necessidade de definir e gerenciar as habilidades e competências necessárias dos recursos humanos, além de avaliar e monitorar se as pessoas mantêm as competências necessárias para cumprir os papéis estabelecidos para elas. Caso lacunas (*gaps*) sejam encontradas, a organização deve prover capacitação suficiente para que essa limitação seja superada.

⁷¹ COBIT 2019, APO07 — *Managed Human Resources*.

Description: Provide a structured approach to ensure optimal recruitment/acquisition, planning, evaluation and development of human resources (both internal and external).

Purpose: Optimize human resources capabilities to meet enterprise objectives

Essa gestão por competências é abordada por diversos instrumentos na administração pública como o Decreto Federal nº 10.024/2019⁷², a Portaria SEGES/ME nº 8.678/2021⁷³, a Resolução CNJ nº 347/2020⁷⁴ e Lei Federal nº 14.133/2021⁷⁵

De forma similar, a necessidade da administração pública em fundamentar os processos de recrutamento e seleção (internos e externos) em perfis de competências, inclusive os relativos a cargos/funções de livre provimento de natureza técnica ou gerencial, e assegurar concorrência e transparência nos processos já foi regulamentado na administração pública federal direta, autárquica e fundacional pela Lei Federal nº 14.204/2021⁷⁶, regulamentada pelo Decreto Federal nº 10.829/2021, que dispõe sobre os critérios, o perfil profissional e os procedimentos gerais a serem observados para a ocupação dos cargos em comissão do grupo Cargos Comissionados Executivos - CCE e das Funções Comissionadas Executivas - FCE.

Pauta essa que vem também sendo discutida em âmbito do Legislativo Federal, como pode-se verificar no Projeto de Lei nº 3.769/2019 do Senado Federal, em que se motiva:

⁷² Art. 16 § 3º Os órgãos e as entidades de que trata o § 1º do art. 1º estabelecerão planos de capacitação que contenham iniciativas de treinamento para a formação e a atualização técnica de pregoeiros, membros da equipe de apoio e demais agentes encarregados da instrução do processo licitatório, a serem implementadas com base em gestão por competências.

⁷³ Art. 14. Compete ao órgão ou entidade, quanto à gestão por competências do processo de contratações públicas:
I - assegurar a aderência às normas, regulamentações e padrões estabelecidos pelo órgão central do Sistema de Serviços Gerais - Siscg, quanto às competências para os agentes públicos que desempenham papéis ligados à governança, à gestão e à fiscalização das contratações;

II - garantir que a escolha dos ocupantes de funções-chave, funções de confiança ou cargos em comissão, na área de contratações, seja fundamentada nos perfis de competências definidos conforme o inciso I, observando os princípios da transparência, da eficiência e do interesse público, bem como os requisitos definidos no art. 7º da Lei nº 14.133, de 2021; e

III - elencar, no Plano de Desenvolvimento de Pessoas - PDP, nos termos do Decreto nº 9.991, de 28 de agosto de 2019, ações de desenvolvimento dos dirigentes e demais agentes que atuam no processo de contratação, contemplando aspectos técnicos, gerenciais e comportamentais desejáveis ao bom desempenho de suas funções.

⁷⁴ Art. 27. (...) os órgãos do Poder Judiciário deverão:

I – definir as funções-chave ligadas à governança e à gestão de

contratações, incluindo os principais agentes do processo de contratações, de acordo com os processos de trabalho estabelecidos e a estrutura de cada órgão;

II – estabelecer modelo de competências para os ocupantes das funções chave previstas no inciso I; e

III – realizar a escolha dos ocupantes de funções-chave fundamentados nos perfis de competências definidos no modelo de que trata o inciso II, observando os princípios da transparência, da motivação, da eficiência e do interesse público.

⁷⁵ Art. 7º Caberá à autoridade máxima do órgão ou da entidade, ou a quem as normas de organização administrativa indicarem, promover gestão por competências (...)

⁷⁶ Art. 9º São critérios gerais para a ocupação de cargos em comissão e de funções de confiança na administração pública federal direta, autárquica e fundacional:

(...)

II – perfil profissional ou formação acadêmica compatível com o cargo ou com a função para a qual tenha sido indicado;

Para evitar que cargos comissionados e funções de confiança sejam utilizados sem o devido retorno de um serviço de qualidade para o órgão, a administração deve formalizar os níveis de capacitação, experiência, formação acadêmica ou especialização do cargo ou função.

Caso os ocupantes dos cargos comissionados e funções de confiança não apresentem os requisitos necessários para cumprir suas atividades, cabe ao órgão promover a capacitação gerencial do servidor (efetivo ou não) e sua qualificação para o exercício de atividades de direção e assessoramento.

(grifo nosso)

Além disso, esse tema já foi alvo de atenção do Tribunal de Contas da União, através do Acórdão TCU nº 3.023/2013-Plenário.

Isto posto, consolida-se o entendimento de que para haver uma boa governança pública é necessária uma efetiva governança de pessoas que defina controles capazes de mitigar riscos e otimizar o atendimento das competências da organização, gerando assim valor à sociedade.

No presente trabalho, para mapear o quadro geral do Setor de TI das organizações auditadas, foi solicitado no item 03 do TSID02 a relação do corpo técnico de TI da organização, contendo informações como tipo de vínculo do colaborador e se exerce cargo de gestão nas suas atribuições.

Ademais, para mensurar e avaliar a capacidade da organização em gerenciar os recursos humanos de tecnologia da informação foi utilizado o Questionário de Governança e Gestão de TI, submetido por meio do TSID03, que possui itens de verificação acerca da adoção das melhores práticas de gestão de pessoas por parte da organização

Por fim, considerou-se, ainda, os esclarecimentos informados pelos jurisdicionados mediante a resposta ao TSID04, que solicitou os comentários do gestor, conforme descrito na seção 3.4 do relatório.

Os procedimentos de verificação para a conflagração deste achado são:

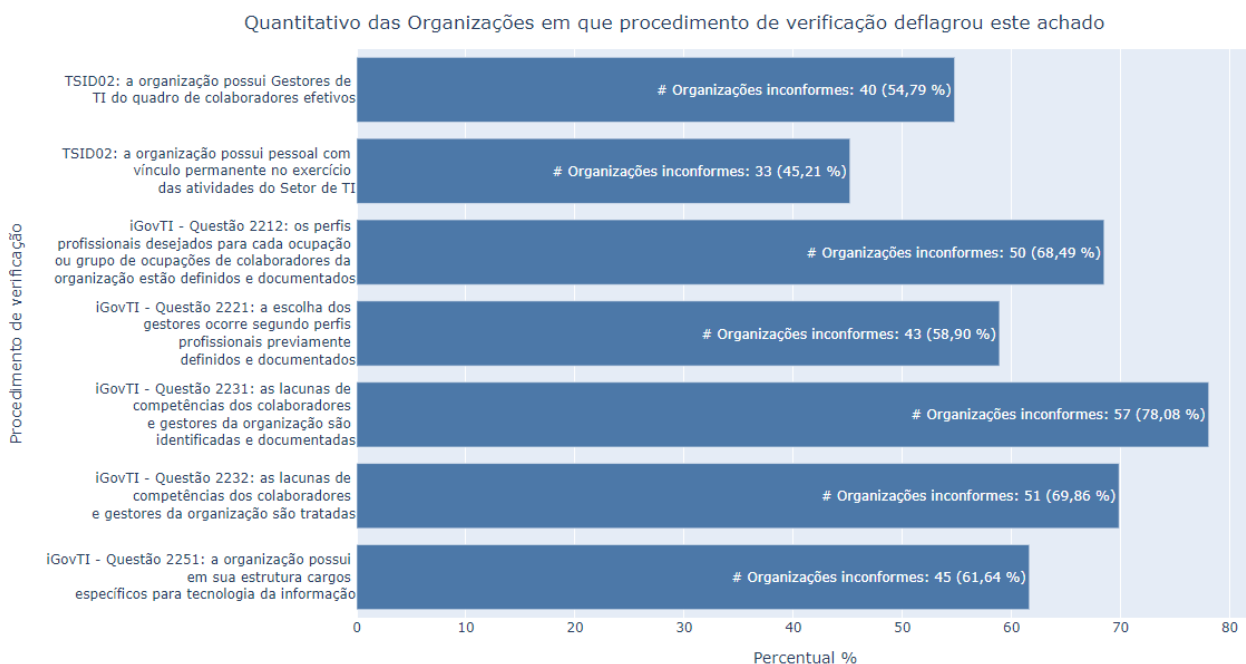
- Item 03 do TSID02: verifica se a organização possui Gestores de TI do quadro de colaboradores efetivos;
- Item 03 do TSID02: verifica se a organização possui pessoal com vínculo permanente no exercício das atividades do Setor de TI;

- Item 2212 do Questionário de Governança e Gestão de TI: verifica se os perfis profissionais desejados para cada ocupação ou grupo de ocupações de colaboradores da organização estão definidos e documentados;
- Item 2221 do Questionário de Governança e Gestão de TI: verifica se a escolha dos gestores ocorre segundo perfis profissionais previamente definidos e documentados;
- Item 2231 do Questionário de Governança e Gestão de TI: verifica se as lacunas de competências dos colaboradores e gestores da organização são identificadas e documentadas;
- Item 2232 do Questionário de Governança e Gestão de TI: verifica se as lacunas de competências dos colaboradores e gestores da organização são tratadas;
- Item 2251 do Questionário de Governança e Gestão de TI: verifica se a organização possui em sua estrutura cargos específicos para tecnologia da informação.

A identificação de respostas do tipo "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" para as questões 2212, 2221, 2231 e 2232 do Questionário de Governança e Gestão de foram consideradas situações incondizentes com uma gestão de recursos humanos de TI adequada. Já a identificação de respostas do tipo "Não" para a questão 2251 do Questionário de Governança e Gestão de foram situações igualmente consideradas inapropriadas.

Ademais, a ausência de gestores de TI advindos do quadro de colaboradores efetivos das organizações, ou a ausência de pessoal com vínculo permanente no setor de TI aferidas a partir da resposta ao item 03 do TSID02 foram situações classificadas da mesma forma.

Segue o resultado da aplicação dos procedimentos de verificação nas organizações do nível setorial do SETIC:



Verificou-se, após a realização dos procedimentos e da análise dos comentários dos gestores, que mais de 50% das organizações respondentes não possuem Gestores de TI do quadro de colaboradores efetivos. Ademais, nota-se que cerca de 45% das organizações não possuem pessoal do quadro efetivo atuando no Setor de TI.

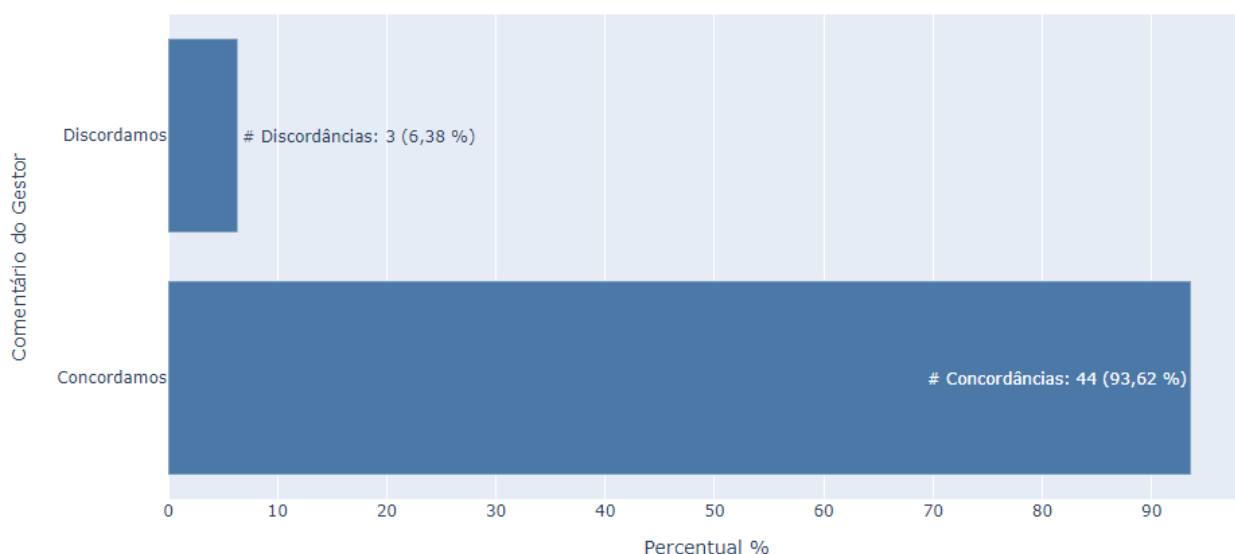
Mais ainda, aproximadamente 70% das organizações respondentes não possuem definição e nem documentação dos perfis profissionais e cerca de 60% não realiza escolhas de seus gestores baseadas nesses perfis.

Outro aspecto relevante retratado na figura, levantou-se que aproximadamente 65% das organizações respondentes não realizam gestão por competências, não identificando lacunas de competências e nem tratando tais carências.

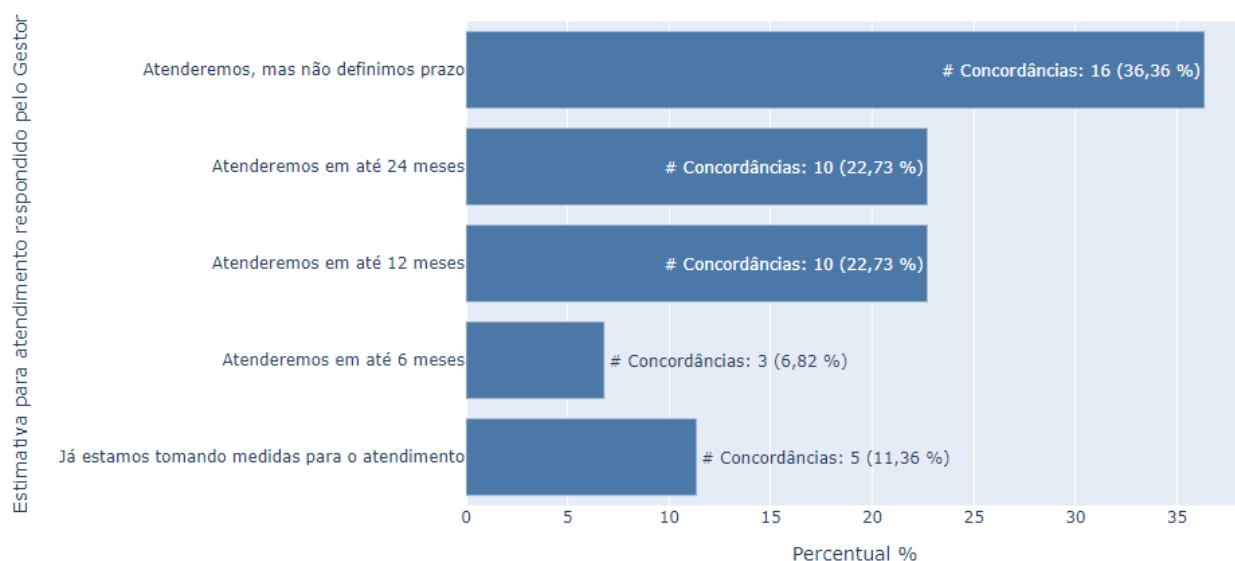
Por fim, a figura expõe que mais de 60% das organizações respondentes não possuem cargos específicos de TI.

Dos Comentários do Gestor

Em relação ao comentário dos gestores, podemos notar que houve ampla concordância com o disposto na situação encontrada e no encaminhamento proposto, constituindo aproximadamente 93,6% das respostas para este achado, como apresentado na figura a seguir:



Ademais, considerando apenas os comentários que exprimem concordâncias, vemos que a maior parte dos gestores estimam atender as propostas de encaminhamento neste achado em até 24 meses, constituindo aproximadamente 63,6% dos comentários de consentimento, como apresentado na figura a seguir:



Dessa forma, constata-se a existência de oportunidades de melhoria na adoção das melhores práticas para gestão de recursos humanos de TI.

À vista disto, será incluída **RECOMENDAÇÃO** aos órgãos que compõem o NSTIC, na proposta de encaminhamento deste relatório, para que estruturam a gestão de recursos humanos de TI, observando as boas práticas presentes na Norma Técnica ABNT NBR ISO 38.500/2018, bem como no COBIT 2019.

4.3.6.4 Causas

- Não investigadas.

4.3.6.5 Efeitos

- Ineficácia e ineficiência na prestação dos serviços de tecnologia da informação;
- Descontinuidade da gestão de tecnologia da informação;
- Excesso de carga de trabalho dos efetivos para planejamento, coordenação, fiscalização e controle das atividades de TI;
- Dependência da organização de agentes alheios ao quadro para execução de atividades críticas para o negócio.

4.3.6.6 Propostas de encaminhamento

- **Comunicação com Recomendação** às organizações a seguir arroladas para que, atendendo às boas práticas e princípios de governança do setor público, assim como às boas práticas de governança e gestão de TI elencados na Norma Técnica ABNT ISO/IEC 38.500/2018 e no APO07 – Managed Human Resources (Recursos humanos gerenciados – tradução livre) do COBIT 2019:
 - Edite e publique ato que defina perfis profissionais mínimos para provimento das ocupações de gestão de TI da organização, elencando seus requisitos, atribuições e responsabilidades, atentando para a necessidade de que sejam revisados periodicamente;
 - Elabore processo formal de recrutamento baseado nos perfis definidos;
 - Defina e gerencie as habilidades e competências necessárias para os recursos humanos de TI, verificando regularmente se o pessoal possui as competências para cumprir suas funções com base em sua capacitação, treinamento e/ou experiência;
 - Assegure que essas competências estejam sendo mantidas, utilizando programas de qualificação e certificação quando apropriado;

- Forneça aos colaboradores aprendizado contínuo e oportunidades para manterem seus conhecimentos, habilidades e competências em um nível necessário para alcançar os objetivos da área de TI da organização;

Organizações: AGENERSA, AGETRANSP, CEASA, CECIERJ, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IASERJ, IEEA, INEA, IO, IPER/RJ, IRM, ITERJ, IVB, JUCERJA, LOTERJ, PESAGRO, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SEAS, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV, SEPLAG, SEPM, SERGB, SES, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

- **Comunicação com Recomendação** às organizações a seguir arroladas para que, atendendo às boas práticas e princípios de governança do setor público, assim como às boas práticas de governança e gestão de TI elencados no APO07 – Managed Human Resources (Recursos humanos gerenciados – tradução livre) do COBIT 2019:
 - elaborem estudos a fim de avaliar a estrutura de recursos humanos dos setores de TI, verificando, se as atividades ligadas ao planejamento estratégico de TI, à coordenação, à fiscalização e ao controle das ações do setor são executadas por servidores do quadro permanente de pessoal, com vistas a promover ajustes no quadro funcional e a minimizar a dependência a agentes externos da Administração em papéis sensíveis da área de TI.

Organizações: AGENERSA, AGETRANSP, CASERJ, CEASA, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GVG, IASERJ, IEEA, IRM, ISP, ITERJ, IVB, LOTERJ, PESAGRO, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAPPA, SEAS, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV,

SEPLAG, SEPM, SERGB, SES, SETD, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO.

4.3.7. Achado 07 – Contratações de TI não aderentes com os dispositivos da Instrução Normativa PRODERJ/PRE nº 01/2021

4.3.7.1 Critérios

- Decreto Estadual nº 47.278/2020, art. 5º, inc. XVIII, alínea d;
- Decreto Estadual nº 47.278/2020, art. 6º, inc. I;
- Decreto Estadual nº 47.278/2020, art. 7º;
- Instrução Normativa PRODERJ/PRE nº 01/2021, art. 4º, caput e § 1º;
- Instrução Normativa PRODERJ/PRE nº 01/2021, art. 5º;
- Instrução Normativa PRODERJ/PRE nº 01/2021, art. 8º, parágrafo único, e art. 9º, parágrafo único.

4.3.7.2 Evidências

- Resposta⁷⁷ ao item 08 do TSID02 em que foi solicitado os processos de contratação de bens e serviços de TIC aos jurisdicionados;
- Exame⁷⁸ analítico do quadro de processos que não tiveram tramitação ao PRODERJ pelo Sistema SEI do Estado do Rio de Janeiro;
- Resposta "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" ao item 1023 do Questionário de Governança e Gestão de TI⁷⁹, submetido pelo TSID03, para verificar o atendimento da Instrução Normativa nº 01/2021 pelas organizações.

4.3.7.3 Situação Encontrada

Por efeito do Decreto Estadual n.º 47.278/2020 e pela necessidade de nortear e padronizar as soluções de TIC do Estado do Rio de Janeiro, além de oferecer

⁷⁷ Presente no Anexo 004 do relatório.

⁷⁸ Presente na pasta "Achado 07 – Contratações" do Anexo 012 do relatório.

⁷⁹ Presente no Anexo 008 do relatório.

vantajosidade e economicidade à Administração Pública pelo ganho de escala nas contratações públicas, o PRODERJ, Diretor Geral SETIC, recebeu a incumbência de realizar os procedimentos de contratação das soluções de TIC para atendimento das necessidades dos órgãos estaduais, preferencialmente, por ata de registro de preços - ARP.

Insta salientar que é prerrogativa do Diretor Geral do SETIC a normatização dos aspectos de contratação de soluções de TI nos órgãos setoriais, conforme preconiza o art. 5º, inciso XVIII, alínea d, do Decreto nº 47.278/2020⁸⁰. Ademais configura atribuição dos órgãos setoriais do SETIC o cumprimento das diretrizes técnicas e procedimentais estabelecidas pelo nível de Direção Geral do SETIC, conforme estabelece o art. 6º, inciso I, do Decreto nº 47.278/2020⁸¹.

Nesse sentido, o Decreto supracitado, em seu art. 7º⁸², vincula os órgãos estaduais a enviarem suas solicitações de contratação de TI à autarquia para assinatura e anuência.

Para regulamentar esse trâmite, a temática das Contratações de TI é tratada pela Instrução Normativa PRODERJ/PRE nº 01/2021. Tal normativo estabelece os procedimentos a serem adotados pelos órgãos setoriais do SETIC para a contratação e celebração de acordos que envolvam tecnologia da informação e comunicação, assim como para o envio dos procedimentos de prorrogação de instrumentos contratuais desses objetos para análise do PRODERJ.

Na norma, existem dispositivos que são de observância mandatória aos órgãos setoriais do SETIC como o encaminhamento de suas solicitações de contratação de

⁸⁰ Art. 5º - Compete ao nível de Direção Geral, representado pelo PRODERJ:

(...)

XVIII - disciplinar, por meio de atos, regulamentos e instruções normativas:

(...)

d) as contratações, acordos e aditivos às soluções de TIC;

⁸¹ Art. 6º - Compete ao nível Setorial, representado pelas Assessorias de Informática, ou setores equivalentes, de todos os órgãos da administração direta e indireta do estado do Rio de Janeiro:

I - cumprir as diretrizes técnicas e procedimentais estabelecidas pelo nível de Direção Geral, em termos da política de TIC do Governo do Estado do Rio de Janeiro;

⁸² Art. 7º Os processos de contratação e aditivos contratuais na área de Tecnologia da Informação e Comunicação - TIC só poderão seguir para deflagração da fase externa ou, no caso de contratação direta ou aditivos, para assinatura do respectivo instrumento após o envio e anuência do PRODERJ.

solução de TIC ao PRODERJ⁸³, a elaboração de Documento de Oficialização de Demanda⁸⁴, a presença da contratação no PEDTIC vigente do órgão⁸⁵ e a confecção de Estudo Técnico Preliminar quando da adesão à ata de registro de preços do PRODERJ⁸⁶, entre outros.

No presente trabalho, para mensurar e avaliar a aderência das contratações de TI dos órgãos setoriais à Instrução Normativa PRODERJ/PRE nº 01/2021 foi solicitado no item 08 do TSID02 a relação de processos de contratação que envolviam serviços ou produtos de TIC realizados pela organização a partir de 2021.

Uma vez coletadas as informações foram padronizadas e consolidadas num registro único com vistas a guiar a análise da Equipe. Nessa etapa foram informados cerca de 773 processos de contratação diferentes por 67 organizações do nível setorial do SETIC. A partir desse universo foi realizada uma seleção dos processos de forma que foram considerados apenas aqueles que se iniciavam com o prefixo “SEI-”.

Da amostra foram realizadas consultas no Sistema SEI do ERJ e extraídos os seus conteúdos contendo as tramitações processuais e as peças instruídas, resultando em um total de 684 processos analisados.

Considerou-se na análise dos processos SEI das contratações de TIC das organizações a faculdade disposta no § 2º do art. 1º da norma, definindo-se, assim, um valor de alçada de R\$ 35.200,00 para obrigatoriedade ao normativo.

Por fim, para verificação de cumprimento da norma analisou-se nos processos consultados quais tinham um valor de contratação acima do valor de alçada, que iniciaram a partir de 26/02/2021, data de vigência da norma, e que não tiveram qualquer tramitação ou comunicação ao órgão Diretor Geral do SETIC.

Da análise realizada verificou-se que 29 órgãos enviaram seus processos de contratação ao órgão Diretor Geral do SETIC, quais sejam: AGENERSA, AGETRANSP,

⁸³ Art. 4º - Os órgãos e entidades integrantes da Administração Direta e Indireta do Poder Executivo do estado do Rio de Janeiro que pretenderem realizar contratação de solução de TIC deverão encaminhar a solicitação à Presidência do PRODERJ por meio do Sistema Eletrônico de Informação - SEI/RJ com o assunto “Solicitação SACTI-RJ”.

⁸⁴ Art. 4º, § 1º - O processo encaminhado com a solicitação deverá ser, obrigatoriamente, instruído com o Documento de Oficialização de Demanda e demais documentos relacionados à pesquisa preliminar de preços.

⁸⁵ Art. 5º Todas as contratações de soluções de TIC pretendidas pelos órgãos e entidades da Administração Pública Estadual, na forma desta Instrução Normativa, deverão estar planejadas no respectivo PEDTIC, em atendimento à regulamentação expedida pelo órgão de Direção Geral de TIC, e indicadas no Plano Anual de Contratações, de acordo com o art. 10, inciso I do Decreto nº 46.642/2019.

⁸⁶ Art. 8º, Parágrafo Único - Cabe ao solicitante finalizar o planejamento da contratação e a instrução processual para aderir à Ata de Registro de Preços, com a elaboração do Estudo Técnico Preliminar e do Termo de Referência, além da realização de ampla pesquisa de preço, nos termos da legislação.

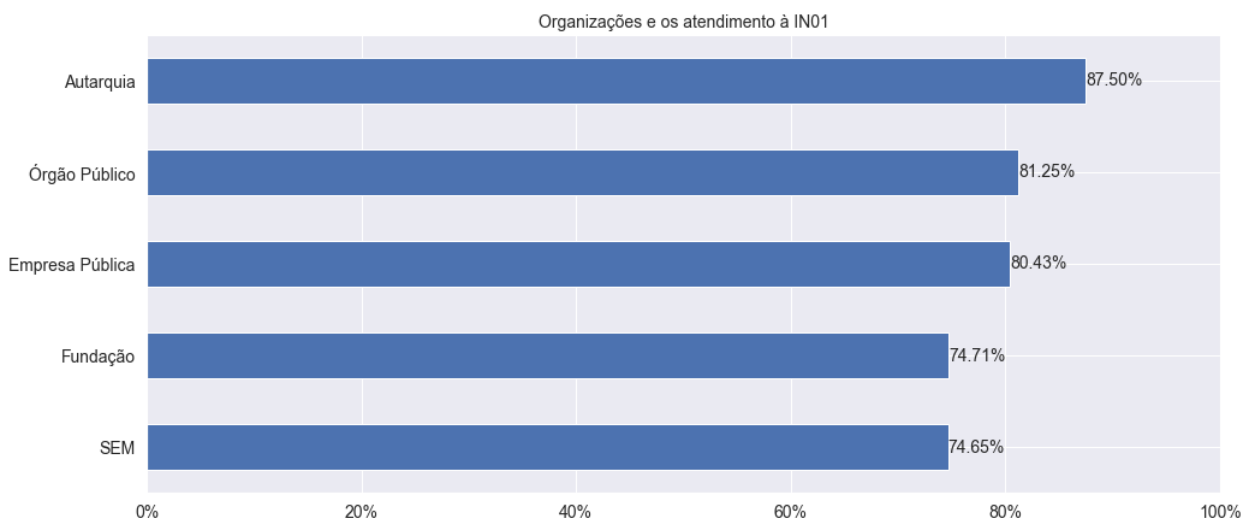
CEHAB, CGE, CODIN, DRM, FAPERJ, FIA, FIPERJ, Fundação Leão XIII, FMIS, FTM, FUNARJ, IRM, ISP, LOTERJ, RIOPREVIDÊNCIA, RIOTRILHOS, SEAP, SEAPPA, SEAS, SECEC, SECTI, SEDEC, SEELJE, SEPLAG, SETRAB, SETRANS e SUDERJ.

Num quadro geral observou-se que dos 684 processos analisados não houve envio ou notificação ao PRODERJ em 138 deles, denotando, assim, um quadro de aproximadamente 80% de cumprimento a esse aspecto do normativo. Foram verificadas 38 organizações que descumpriram a IN01 ao não submeter ao menos um processo de contratação de bens e/ou serviços de TIC para anuência do PRODERJ. O montante dos processos de contratação que descumpriram a esse aspecto chegam a R\$ 443.622.768,19.

Sintetiza-se:

	Nº de processos conformes	Nº de processos desconformes	% de atendimento à IN01	Valor que não teve anuência do PRODERJ
Órgãos do nível setorial do SETIC	546	138	79,82%	R\$ 443.622.768,19

Segmentando o quadro acima pelas classificações de cada organização, observa-se que o grau de atendimento verificado é, em média, menor nas sociedades de economia mista (SEM) e fundações, entidades da Administração Indireta.



	Quantidade média de processos conformes	Quantidade média de processos desconformes	% média de atendimento à IN01	Valor médio de processo que não teve anuência do PRODERJ
Autarquia	8.0000	1.1428	87.50%	R\$ 1.69 M
Órgão Público	8.4782	1.9565	81.25%	R\$ 12.87 M
Empresa Pública	7.4000	1.8000	80.43%	R\$ 0.61 M
Fundação	7.9375	2.6875	74.71%	R\$ 5.23 M
SEM	8.8333	3.0000	74.65%	R\$ 0.78 M

Seguem as organizações que menos atenderam a esse aspecto da Instrução Normativa PRODERJ/PRE nº 01/2021, o de envio das solicitações de contratação de TIC ao Diretor Geral do SETIC:

	Quantidade de processos conformes	Quantidade de processos desconformes	% de atendimento à IN01	Valor que não teve anuência do PRODERJ
UERJ	7.00	13.00	35.00%	R\$ 36,686,680.00
DETRO	2.00	3.00	40.00%	R\$ 2,119,058.21
DEGASE	2.00	3.00	40.00%	R\$ 4,690,651.11
PGE	11.00	12.00	47.83%	R\$ 11,372,670.72
ITERJ	2.00	2.00	50.00%	R\$ 572,000.00
SEEDUC	9.00	9.00	50.00%	R\$191,022,405.08
CECERJ	4.00	4.00	50.00%	R\$ 13,490,530.42
FS	19.00	17.00	52.78%	R\$ 22,813,334.85
UENF	4.00	3.00	57.14%	R\$ 1,552,743.35
SEPOL	9.00	6.00	60.00%	R\$ 32,306,171.67

Ao aferir a adequação normativa quanto aos valores dos processos de contratação, verifica-se um quadro mais prejudicado, uma vez que do montante total de R\$ 1.400.529.457,52 declarados nos processos de contratação analisados, cerca de R\$ 443.622.768,19 não tiveram a anuência do órgão Diretor Geral, resultando num cenário

em que 31.68% dos montantes contratados pelos órgãos setoriais foram realizados sem a supervisão do coordenador do Sistema.

Destaque-se que durante a análise empreendida verificaram-se nos autos de processos de órgãos participantes de atas de registro de preço gerenciadas pelo PRODERJ situações que não continham comunicações ou notificações ao Diretor Geral, conforme indicado, a seguir, nas orientações expressas no Portal SETIC.

Atas

ORIENTAÇÕES

2023 2022

Procedimentos para adesão à ATA:

As contratações por órgãos participantes dos PLS, devem ser realizadas diretamente com a empresa fornecedora, conforme previsto nos Planos de Suprimentos vinculados aos processos licitatórios, e notificado ao PRODERJ, ainda no início das tratativas com a empresa, por meio do e-mail gcd.atas@proderj.rj.gov.br, informando nº da ATA, nº ID dos itens, quantidade e nº SEI do processo de contratação.

Em que pese a orientação proposta pelo PRODERJ, a qual indica aos órgãos participantes da Ata que o informem apenas por e-mail da sua utilização e consumo, reputa-se cabível pelo princípio do controle e da transparência que haja também registro nos autos do processo SEI das respectivas contratações.

Dessa forma, será sugerida recomendação ao Diretor Geral para que edite sua orientação aos órgãos participantes de forma que esses comuniquem suas contratações resultantes das atas de registro de preço não apenas por e-mail, mas também pelo Sistema SEI.

Para mapear a aderência ao normativo buscou-se, ainda, utilizar do Questionário de Governança e Gestão de TI, submetido por meio do TSID03, que possui itens de verificação acerca da adoção dos normativos expedidos pelo Diretor Geral do SETIC.

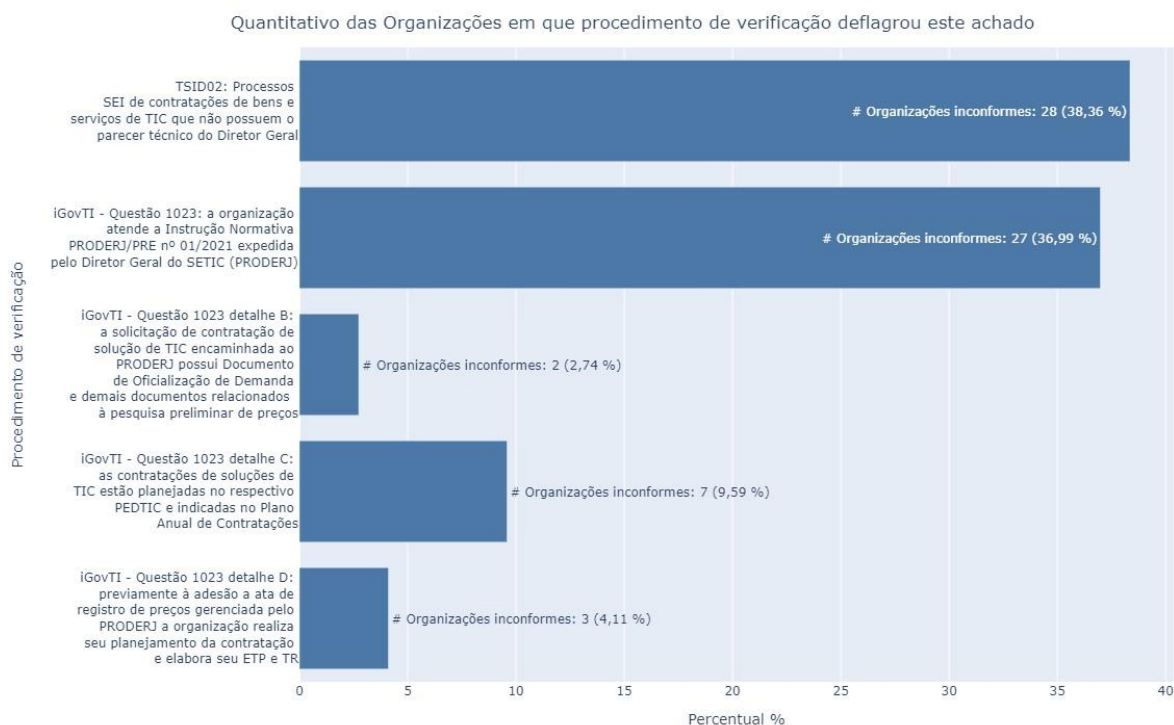
As questões presentes no Questionário de Governança e Gestão de TI que foram verificadas para a conflagração deste achado são:

- Subitem “b” do item 1023 do Questionário de Governança e Gestão de TI: verifica se a organização atende à IN01/2021 e se a solicitação de contratação de solução de TIC encaminhada ao PRODERJ possui Documento de Oficialização de Demanda e demais documentos relacionados à pesquisa preliminar de preços;

- Subitem “c” do item 1023 do Questionário de Governança e Gestão de TI: verifica se a organização atende à IN01/2021 e se as contratações de soluções de TIC estão planejadas no respectivo PEDTIC e indicadas no Plano Anual de Contratações;
- Subitem “d” do item 1023 do Questionário de Governança e Gestão de TI: verifica se a organização atende à IN01/2021 e se previamente à adesão a ata de registro de preços gerenciada pelo PRODERJ a organização realiza seu planejamento da contratação e elabora seu Estudo Técnico Preliminar – ETP e Termo de Referência - TR;

A identificação de respostas do tipo "Não adota", ou "Adota em menor parte", ou "Há decisão formal ou plano aprovado para adotá-lo" para as questões supracitadas foram consideradas não atendimentos à Instrução Normativa PRODERJ/PRE nº 01/2021.

Segue o resultado da aplicação dos procedimentos de verificação nas organizações do nível setorial do SETIC:

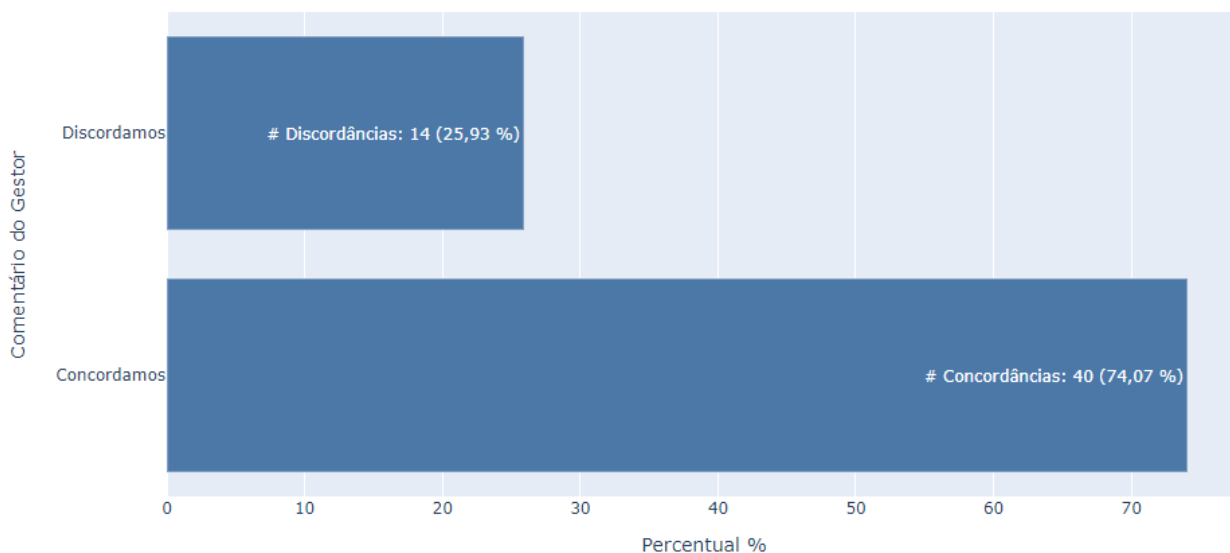


Verificou-se, após a realização dos procedimentos e da análise dos comentários dos gestores, que cerca de 38% das organizações possuem processos de contratação de TIC sem a anuência do Diretor Geral do SETIC.

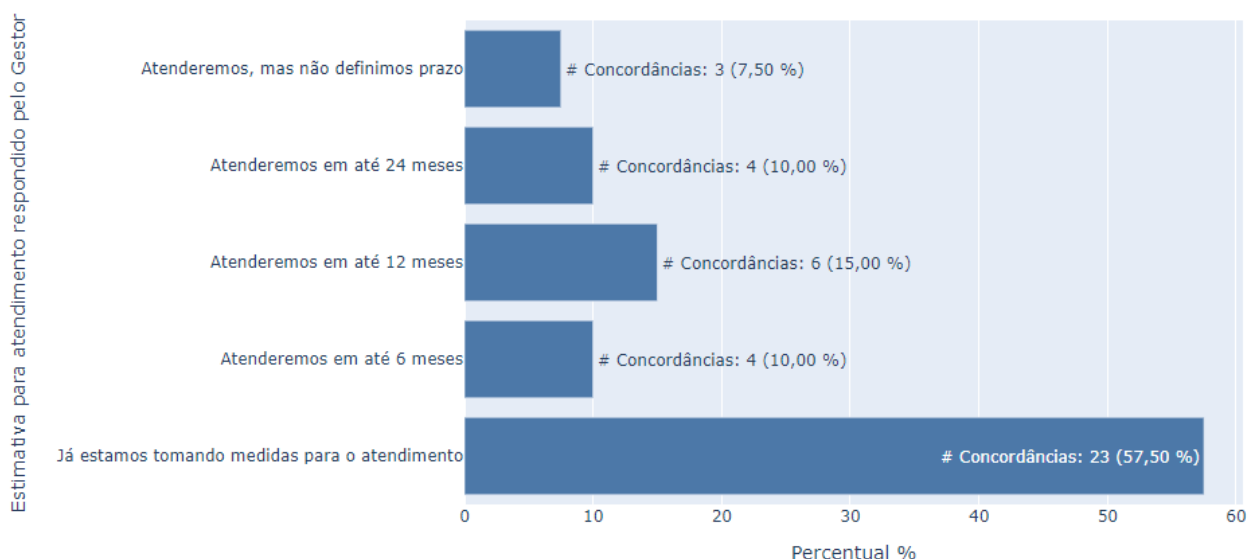
Além disso, de 33 organizações que declararam atender parcial ou totalmente à IN01/2021, duas (6% delas) informaram não encaminhar ao PRODERJ os documentos de planejamento necessários quando da solicitação de contratação de TIC, sete (21% delas) informaram que as contratações não constam no PEDTIC e no seu PAC, por fim, três (9% delas) informaram não realizar o planejamento da contratação previamente à adesão à Ata de Registro de Preço.

Dos Comentários do Gestor

Em relação ao comentário dos gestores, podemos notar que houve ampla concordância com o disposto na situação encontrada e no encaminhamento proposto, constituindo aproximadamente 74% das respostas para este achado, como apresentado na figura a seguir:



Ademais, considerando apenas os comentários que exprimem concordâncias, vemos que a maior parte dos gestores estimam atender as propostas de encaminhamento neste achado em até 24 meses, constituindo aproximadamente 92,5% dos comentários de consentimento, como apresentado na figura a seguir:



Dessa forma, constata-se desajuste à Instrução Normativa PRODERJ/PRE nº 01/2021 quanto ao não envio dos processos de contratação de TIC para anuência do PRODERJ por parte de órgãos pertencentes ao nível setorial do SETIC e quanto aos itens verificados pelo item 1023 do Questionário de Governança e Gestão de TI, quais sejam: não encaminhar ao PRODERJ os documentos de planejamento necessários quando da solicitação de contratação de TIC; as contratações não constam no PEDTIC e no seu PAC; e não realizar o planejamento da contratação previamente à adesão à Ata de Registro de Preço.

Assim, será sugerida **DETERMINAÇÃO** para que nos próximos processos de contratação das organizações remetam suas solicitações ao PRODERJ e atendam aos dispositivos elencados na IN01/2021.

4.3.7.4 Causas

- Não investigadas.

4.3.7.5 Efeitos

- Perda no ganho de escala pelas contratações descentralizadas no âmbito estadual;

- Contratações de TI sem o planejamento de uma organização especialista no tema;
- Ausência de priorização das necessidades de contratação das organizações em âmbito estadual.

4.3.7.6 Propostas de Encaminhamento

- **Comunicação com Determinação** às organizações elencadas abaixo para que nos próximos processos de contratação de objetos de TIC remetam suas solicitações de contratação e/ou renovação ao Diretor Geral do PRODERJ para que recebam sua anuência, conforme disposto no art. 4º da Instrução Normativa PRODERJ/PRE nº 01/2021 c/c art. 7º do Decreto Estadual nº 47.278/2020;

Organizações: CECIERJ, CENTRAL, CEPERJ, CODERTE, DEGASE, DER/RJ, DETRAN, DETRO, EMATER, EMOP, FAETEC, FS, FSC, INEA, IPEM/RJ, ITERJ, IVB, PGE, PROCON, RJPREV, SEDSODH, SEGOV, SEPM, SERGB, SES, SETUR, UENF, UERJ

- **Comunicação com Determinação** às organizações elencadas abaixo para que nos próximos processos de contratação de objetos de TIC atendam integralmente aos dispositivos elencados na Instrução Normativa PRODERJ/PRE nº 01/2021, atentando-se para:
 - a solicitação de contratação de TIC deverá ser instruída com o Documento de Oficialização de Demanda e demais documentos relacionados à pesquisa preliminar de preços;
 - as contratações de soluções de TIC deverão estar planejadas no respectivo PEDTIC e indicadas no Plano Anual de Contratações;
 - realizar o planejamento da contratação previamente à adesão à Ata de Registro de Preço.

Organizações: AGETRANSP, CEASA, CENTRAL, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRO, DRM, EMATER, FAETEC, FAPERJ, FS, FSC, IEEA, INEA, IRM, ITERJ, IVB, LOTERJ, PROCON, RIOTRILH, RJPREV, SEAPPA,

SECEC, SEDEC, SEDSODH, SEELJE, SEIC, SEPM, SETRAB, SETRANS, SETUR, SUDERJ, UENF, UERJ.

- **Comunicação com Recomendação** ao PRODERJ para que, pelo princípio da transparência e controle, edite sua orientação aos órgãos participantes das atas de registro de preço de forma que esses comuniquem a formalização dos contratos das aquisições resultantes das ARP não apenas por e-mail, mas também se registre nos autos do processo administrativo SEI.

4.3.8. Achado 08 – Portais institucionais em produção sem análise de vulnerabilidades pelo Diretor Geral do SETIC

4.3.8.1 Critérios

- Decreto Estadual nº 47.278/2020, art. 5º, inciso XVIII, alínea i);
- Instrução Normativa PRODERJ/PRE nº 03/2022, art. 15, § 1º e § 2º;
- Controles CIS v8, Controle 7 - Gestão contínua de vulnerabilidades.

4.3.8.2 Evidências

- Resposta do PRODERJ ao item 10⁸⁷ do TSID03, que solicitou a relação dos sites e portais que estão sob administração do PRODERJ, contendo informações da data da última análise de vulnerabilidades realizada no portal entre outras;
- Resposta do PRODERJ ao item 11⁸⁸ do TSID03, que solicitou os relatórios das últimas análises de vulnerabilidade relacionadas na resposta ao item 10 do TSID03;
- Resposta do PRODERJ ao item 12⁸⁹ do TSID03, que solicitou as minutas dos contratos de prestação de serviço para os modelos de administração de portais hospedados no PRODERJ.

⁸⁷ Presente no Anexo 004 do relatório.

⁸⁸ Presente no Anexo 004 do relatório.

⁸⁹ Presente no Anexo 004 do relatório.

4.3.8.3 Situação Encontrada

Por efeito do Decreto Estadual nº 47.278/2020 e pela necessidade de nortear e padronizar as soluções de TIC do Estado do Rio de Janeiro, além de oferecer vantajosidade e economicidade à Administração Pública, o PRODERJ, Diretor Geral SETIC, recebeu a incumbência de se tornar o agente fornecedor de serviços e infraestrutura em geral de TIC para toda administração pública.

Ademais, insta salientar que é prerrogativa do Diretor Geral do SETIC a normatização de temas considerados relevantes para a padronização, a integração ou a economia de recursos para o Governo do Estado na área de TIC, conforme preconiza o art. 5º, inciso XVIII, alínea i), do Decreto Estadual nº 47.278/2020⁹⁰. Ademais configura atribuição dos órgãos setoriais do SETIC o cumprimento das diretrizes técnicas e procedimentais estabelecidas pelo nível de Direção Geral do SETIC, conforme estabelece o art. 6º, inciso I, do Decreto Estadual nº 47.278/2020⁹¹.

Nesse sentido, o PRODERJ elaborou a Instrução Normativa PRODERJ/PRE nº 03/2022. Tal normativo estabelece os procedimentos e recomendações a serem adotados pelos órgãos e entidades da Administração Direta e Indireta do Poder Executivo do Estado do Rio de Janeiro para desenvolvimento, migração, sustentação e segurança de sites e portais de internet hospedados no PRODERJ.

Na norma, são definidos três modelos de administração de *site* ou portal com hospedagem no PRODERJ: Administração Total do PRODERJ, Administração Parcial do PRODERJ e Administração do Cliente.

No modelo de Administração Total do PRODERJ, art. 2º, inc. XVI, alínea a), “o PRODERJ desenvolve e sustenta tanto o site ou portal quanto a hospedagem nos ambientes de homologação e produção”.

No modelo de Administração Parcial do PRODERJ, art. 2º, inc. XVI, alínea b), “o PRODERJ desenvolve o *site* ou portal, gerencia a hospedagem e o ambiente de

⁹⁰ Art. 5º - Compete ao nível de Direção Geral, representado pelo PRODERJ:

(...)

XVIII - disciplinar, por meio de atos, regulamentos e instruções normativas:

(...)

d) as contratações, acordos e aditivos às soluções de TIC;

⁹¹ Art. 6º - Compete ao nível Setorial, representado pelas Assessorias de Informática, ou setores equivalentes, de todos os órgãos da administração direta e indireta do estado do Rio de Janeiro:

I - cumprir as diretrizes técnicas e procedimentais estabelecidas pelo nível de Direção Geral, em termos da política de TIC do Governo do Estado do Rio de Janeiro;

produção, cabendo ao órgão ou entidade realizar a sustentação por meio do Sistema de Gestão de Conteúdo (*Content Management System*) ou do ambiente de homologação”.

No modelo de Administração do Cliente, art. 2º, inc. XVI, alínea c), “os ambientes de homologação e produção estão sob total responsabilidade do órgão ou entidade, cabendo ao PRODERJ somente o gerenciamento da hospedagem dos servidores”.

Sobre um outro aspecto, a referida Instrução Normativa trata da análise de vulnerabilidade a ser desempenhada nos *sites* e/ou portais hospedados.

Em seu art. 15, § 1º, o regramento em tela estabelece que o PRODERJ realiza “a análise de risco e escaneamento de vulnerabilidades da infraestrutura dos sites ou portais dos órgãos e entidades hospedados na Autarquia, nos modelos de administração “total” e “parcial” do PRODERJ”.

Além disso, o § 2º do mesmo artigo dispõe que “novos sites ou portais só poderão entrar em produção no PRODERJ após a análise de vulnerabilidade”.

Desse modo, cabe ao órgão ou à entidade a análise de vulnerabilidade no caso do modelo de administração “cliente”, conforme ilustra a Matriz de Responsabilidade do referido modelo no Anexo Único da norma.

A análise de vulnerabilidades faz parte do Controle 07 do Controles CIS v8 - Gestão contínua de vulnerabilidades. Tal conjunto de boas práticas em Segurança da Informação afirma que as empresas que não avaliam sua infraestrutura em busca de vulnerabilidades e nem corrigem prontamente as falhas descobertas possuem uma probabilidade significativa de ter seus ativos corporativos comprometidos.

Nesse sentido, o Controle 07 estabelece as seguintes medidas de segurança dentre outras:

- 7.1 Estabelecer e manter um processo de gestão de vulnerabilidade;
- 7.5 Realizar varreduras automatizadas de vulnerabilidade em ativos corporativos interno;
- 7.6 Realizar varreduras automatizadas de vulnerabilidade em ativos corporativos expostos externamente.

No presente trabalho, para mensurar e avaliar a aderência dos portais e/ou *sites* dos órgãos do Estado à Instrução Normativa PRODERJ/PRE nº 03/2022 foi solicitado, no item 10 do TSID03 do PRODERJ, a relação dos sites e portais que estão sob

administração da autarquia, contendo informações da data da última análise de vulnerabilidades realizada no portal entre outras.

Outrossim, o item 11 do mesmo TSID03 do PRODERJ solicitou os relatórios das últimas análises de vulnerabilidade relacionadas na resposta ao item 10 do mesmo TSID.

Ainda sobre esse aspecto, o item 12 do mesmo TSID03 do PRODERJ solicitou as minutas dos contratos de prestação de serviço para os modelos de administração dispostos no inciso XVI, do Art. 2º, da Instrução Normativa PRODERJ/PRE nº 03/2022.

Em resposta ao item 10 do TSID03, o PRODERJ informa: “não localizamos relatórios individuais de vulnerabilidade por site ou portal”.

Já em relação ao item 11 do TSID03, informa: “Em relação ao ID 11 conforme disposto no §1º, do Art. 15, da Instrução Normativa PRODERJ/PRE nº 03/2022 inserimos o arquivo Relatório Vulnerabilidades (60778962) que é um consolidado dos relatórios de vulnerabilidades”.

Analisando o conteúdo da resposta ao item 11 do TSID03, não foi possível identificar relatório de vulnerabilidade que se relaciona com os portais elencados na resposta ao item 10 do TSID03.

Por último, ao analisar a resposta ao item 12 do TSID03, não se encontram cláusulas que disponham sobre as obrigações estabelecidas na Instrução Normativa PRODERJ/PRE nº 03/2022 tanto do PRODERJ, quanto da organização cliente.

Uma vez que a referida norma não especifica detalhadamente os requisitos de uma análise de vulnerabilidade minimamente aceitável pela autarquia, faz-se necessário cláusulas no instrumento contratual a fim de trazer maior esclarecimento às partes.

Desta forma, conclui-se que o PRODERJ não realiza análise de vulnerabilidade nos sites e/ou portais dos órgãos e entidades hospedados na Autarquia, nos modelos de administração “total” e “parcial” e nem requisita que aqueles no modelo “cliente” o realizem.

[Dos Comentários do Gestor](#)

Com base na análise dos pontos supracitados, foi submetido ao PRODERJ o relatório preliminar com a situação encontrada e proposta de encaminhamento para oferta de comentários do gestor⁹². Em sua resposta⁹³, a autarquia informa:

Em resposta ao achado 1, após analisados os apontamentos, informamos que conforme a Instrução Normativa PRODERJ/PRE nº 03/2022, art. 15, § 2º os novos sites ou portais só entram produção no PRODERJ após a análise de vulnerabilidade. Informamos, ainda, que iremos considerar os apontamentos do TCE no Anexo II - RELATÓRIO PRELIMINAR nos futuros monitoramentos.

Sobre esse aspecto, insta consignar que o achado 01 presente no Relatório Preliminar do PRODERJ corresponde a este achado 08. Assim, como o PRODERJ informa que irá considerar os apontamentos do achado em seus procedimentos internos, reputamos, a concordância do jurisdicionado com a situação encontrada e as propostas de encaminhamento.

Diante de tal situação, será proposta **DETERMINAÇÃO** para que o PRODERJ elabore um procedimento de avaliação de vulnerabilidade periódico para gerar o relatório de vulnerabilidade do *site* e/ou portal que se encontre no modelo de Administração Total e Parcial, mantendo o registro dessa avaliação de forma perene, bem como para que o PRODERJ exija daqueles que se enquadrem no modelo cliente o relatório de análise de vulnerabilidade.

Ademais, será proposta **RECOMENDAÇÃO** para que o PRODERJ detalhe melhor as obrigações do PRODERJ e do cliente em relação ao portal hospedado, abarcando os requisitos para a análise de vulnerabilidade, no instrumento contratual.

4.3.8.4 Causas

- Não investigadas.

4.3.8.5 Efeitos

- Risco de violação da confidencialidade, integridade e disponibilidade dos dados e sistemas, resultando em perda de credibilidade, reputação e confiança;

⁹² Conforme TSID05 presente no Anexo 003.

⁹³ Comentários do gestor presente na resposta ao TSID05 encontrado no Anexo 004.

- Risco de violação ou adulteração de dados, que pode afetar a integridade e a veracidade das informações armazenadas ou transmitidas pelo portal;
- Risco de repúdio de transação, que pode impedir que uma parte envolvida em uma operação realizada pelo portal possa comprovar a sua autoria ou participação;
- Risco de ataques de negação de serviço, que podem sobrecarregar ou interromper o funcionamento do portal;
- Exposição a riscos legais, regulatórios e contratuais, podendo acarretar multas, sanções e processos judiciais.

4.3.8.6 Propostas de Encaminhamento

- **Comunicação com Determinação** para que o PRODERJ, com fulcro no art. 15, § 1º, art. 15, § 2º, e da matriz de responsabilidades constante do Anexo Único, todos da Instrução Normativa PRODERJ/PRE nº 03/2022, bem como das boas práticas constantes no Controles CIS v8, Controle 7 - Gestão contínua de vulnerabilidades:
 - elabore um procedimento de avaliação de vulnerabilidade periódico para gerar o relatório de vulnerabilidade do *site* e/ou portal que se encontre no modelo de Administração Total e Parcial, mantendo o registro dessa avaliação de forma perene;
 - exija dos clientes que mantêm portais e/ou *sites* no modelo de Administração Cliente relatórios de análise de vulnerabilidade de forma periódica, mantendo o registro dessa avaliação de forma perene, analisando a criticidade das eventuais vulnerabilidades e cobrando as devidas ações de correção dos clientes.
- **Comunicação com Recomendação** para que o PRODERJ detalhe as obrigações do PRODERJ e do cliente em relação ao portal hospedado, abarcando os requisitos para a análise de vulnerabilidade, no instrumento contratual.

4.3.9. Achado 09 - Portais institucionais em produção sem proteção de dados na comunicação com o usuário

4.3.9.1 Critérios

- Decreto Estadual nº 47.278/2020, art. 5º, inciso XVIII, alínea i);
- Instrução Normativa PRODERJ/PRE nº 03/2022, art. 11, caput, § 3º e § 4º;
- Controles CIS v8, Controle 3 – Proteção de dados.

4.3.9.2 Evidências

- Resposta⁹⁴ do PRODERJ ao item 10 do TSID03, que solicitou a relação dos *sites* e portais que estão sob administração do PRODERJ, contendo informações da data da última análise de vulnerabilidades realizada no portal entre outras;
- Resposta⁹⁵ do PRODERJ ao item 11 do TSID03, que solicitou os relatórios das últimas análises de vulnerabilidade relacionadas na resposta ao item 10 do TSID03;
- Relatórios⁹⁶ do resultado dos testes realizados com a ferramenta TOP – Site do NIC.br para verificação de adoção dos padrões técnicos internacionais de segurança.

4.3.9.3 Situação Encontrada

Outro ponto abordado na Instrução Normativa PRODERJ/PRE nº 03/2022, art. 11, é a obrigatoriedade de criptografar a comunicação dos *sites* e/ou portais hospedados no PRODERJ.

O mesmo artigo da norma estabelece que o órgão ou entidade deverá fornecer, obrigatoriamente, o certificado *Secure Sockets Layer* (SSL) compatível com a tecnologia adotada pelo *site* ou portal.

⁹⁴ Presente no Anexo 004 do relatório.

⁹⁵ Presente no Anexo 004 do relatório.

⁹⁶ Presente na pasta “Achado 09 – Portais” do Anexo 012 do relatório.

Em relação aos certificados, os §3º e §4º estabelecem que o “nome no certificado deve corresponder ao *Fully Qualified Domain Name* (Nome de Domínio Completamente Qualificado) do site ou portal” e que o “certificado deverá ser válido e não poderá estar expirado”, respectivamente.

Tais dispositivos vão de encontro ao Controle 03 dos Controles CIS v8 – Proteção de dados – que cita: “A adoção da criptografia de dados, tanto em trânsito quanto em repouso, pode fornecer mitigação contra o comprometimento dos dados e, ainda mais importante, é um requisito regulatório para a maioria dos dados controlados”.

Insta salientar que a comunicação segura e criptografada entre usuários e *sites* e/ou portais existentes na rede mundial de computadores ocorre por meio do *Hyper Text Transfer Protocol Secure* (HTTPS), que utiliza o SSL e sua dinâmica de certificados para criptografar as conexões entre os navegadores dos usuários e os servidores das hospedagens de *sites*.

Assim, verifica-se a necessidade de averiguar o uso do HTTPS nos *sites* e/ou portais hospedados no PRODERJ para verificar sua aderência com os ditames do art. 11 da Instrução Normativa PRODERJ/PRE nº 03/2022.

No presente trabalho, para mensurar e avaliar a conformidade supracitada foi solicitada, no item 10 do TSID03 do PRODERJ, a relação dos *sites* e portais que estão sob administração da autarquia, contendo informações da data da última análise de vulnerabilidades realizada no portal entre outras.

De posse dessa informação, a Equipe de Auditoria conduziu testes de verificação de aspectos de segurança da informação com auxílio da ferramenta *online* TOP – Teste os Padrões⁹⁷. De acordo com sua página eletrônica:

A ferramenta de testes TOP foi adaptada pelo NIC.br⁹⁸ utilizando como base o site Internet.nl, que é uma iniciativa da holandesa Internet Standards Platform. A Internet Society também recomenda a utilização do Internet.nl para testar como os servidores web, de e-mail e os serviços de acesso à Internet atendem aos padrões abertos mais recentes de Internet. O objetivo é aumentar o uso dos

⁹⁷ <https://top.nic.br/>. Acessado em 06/12/2023.

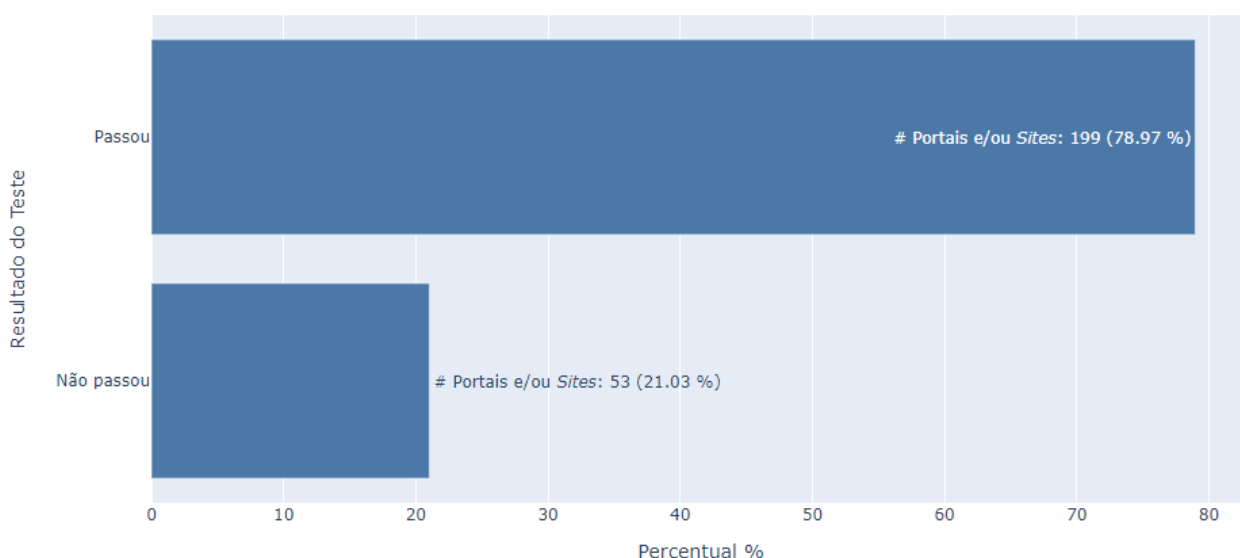
⁹⁸ Núcleo de Informação e Coordenação do Ponto BR - NIC.br – foi criado para implementar as decisões e os projetos do Comitê Gestor da Internet no Brasil (CGI.br), organização responsável por coordenar e integrar as iniciativas e serviços da Internet no país.

padrões modernos de Internet para tornar a Internet mais acessível, segura e confiável para todos.

Dentre os testes oferecidos, utilizou-se o Teste TOP - Site⁹⁹, que testa o uso do HTTPS em um *site*, dentre outros padrões de Internet. Após a condução do teste, a ferramenta TOP gera um relatório que descreve a aderência do *site* e/ou portal aos padrões testados.

Dentre as informações apresentadas, o relatório informa a existência de HTTPS pelo *site* e/ou portal e a validade da cadeia de confiança para o certificado SSL do *site* e/ou portal.

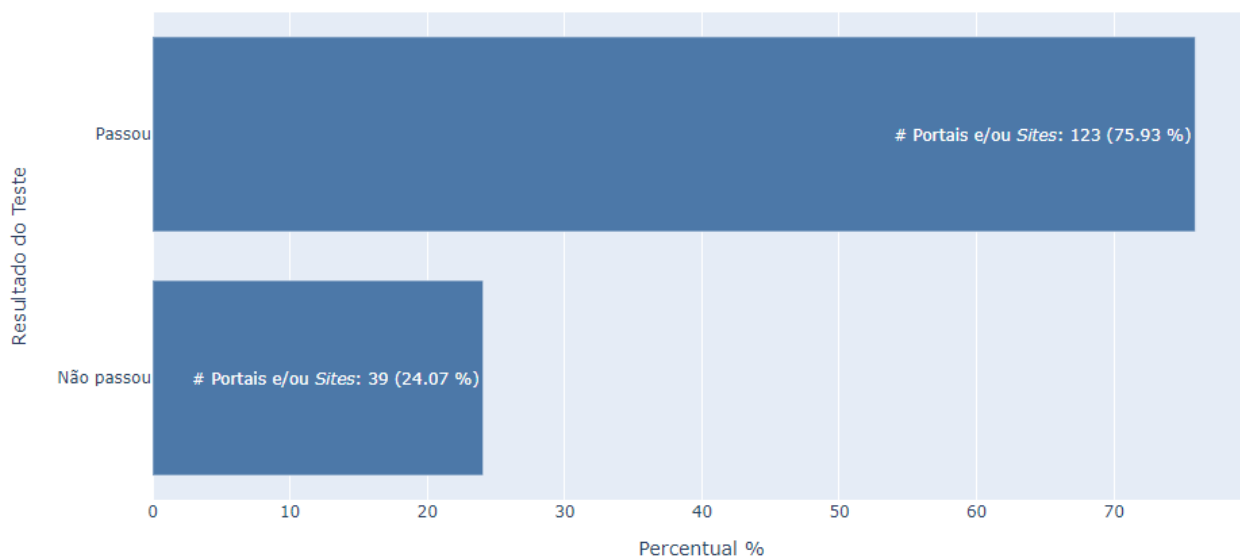
Assim, os relatórios gerados pelo Teste TOP - Site para *sites* e/ou portais relacionados no item 10 do TSID03 do PRODERJ, sob todos os modelos de administração, apontam que 21% dos portais e/ou *sites* não fazem o uso de HTTPS em suas comunicações com os usuários, conforme ilustra a figura a seguir que sintetiza os resultados dos relatórios:



Analogamente, se considerarmos apenas os *sites* e/ou portais que estão sob o regime de Administração Total do PRODERJ, os relatórios gerados pelo Teste TOP - Site apontam que 24% dos portais e/ou *sites* nesse regime não fazem o uso de HTTPS

⁹⁹ <https://top.nic.br/test-site/>. Acessado em 06/12/2023.

em suas comunicações com os usuários, conforme ilustra a figura a seguir que sintetiza os resultados dos relatórios:



Em que pese 76% dos *sites* e/ou portais terem passado no teste de uso do protocolo HTTPS em suas conexões, é necessário estabelecer por completo a utilização do HTTPS nas comunicações entre os usuários e os *sites* e/ou portais do Estado do Rio de Janeiro.

Com base na análise dos pontos supracitados, foi submetido ao PRODERJ o relatório preliminar com a situação encontrada e proposta de encaminhamento para oferta de comentários do gestor¹⁰⁰. Em sua resposta¹⁰¹, a autarquia informa:

Em relação ao achado 2, após analisados os apontamentos trazidos o PRODERJ posiciona Ofício - NI 880 (65308703) SEI SEI-430002/001688/2023 / pg. 1 se de acordo com as recomendações formuladas, que visam ao atendimento dos normativos estabelecidos pela Autarquia.

Sobre esse aspecto, insta consignar que o achado 02 presente no Relatório Preliminar do PRODERJ corresponde a este achado 09. Assim, reputamos, pois, a concordância do jurisdicionado com a situação encontrada e as propostas de encaminhamento.

Diante de tal situação, será proposta **DETERMINAÇÃO** para que o PRODERJ promova a comunicação criptografada entre os portais hospedados e o usuário,

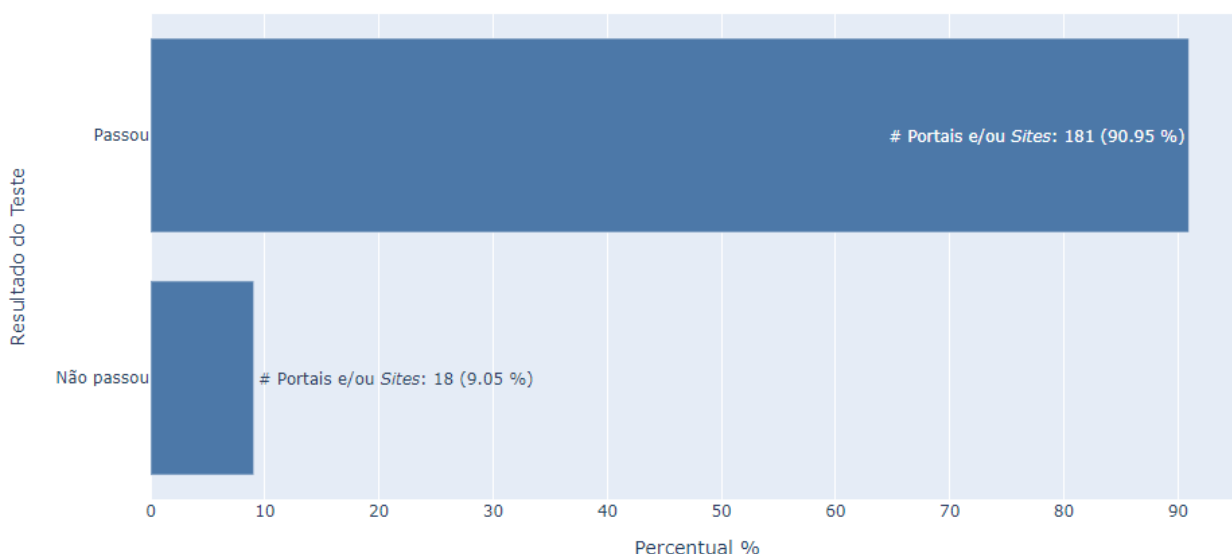
¹⁰⁰ Conforme TSID05 presente no Anexo 003.

¹⁰¹ Comentários do gestor presente na resposta ao TSID05 encontrado no Anexo 004.

especialmente com uso do HTTPS, fazendo tal aspecto constar em sua análise de vulnerabilidades.

Ainda analisando os relatórios gerados pelo Teste TOP - *Site* para *sites* e/ou portais relacionados no item 10 do TSID03 do PRODERJ, colacionou-se a validade da cadeia de confiança para o certificado SSL dos *sites* e/ou portais.

Tal procedimento aponta que 9% dos portais e/ou *sites* apresentam certificados inválidos em suas comunicações com os usuários, conforme ilustra a figura a seguir, que sintetiza os resultados dos relatórios:



Em que pese 91% dos *sites* e/ou portais terem passado no teste de conformidade de seus certificados, é necessário estabelecer por completo o uso dos certificados SSL válidos nas comunicações entre os usuários e os *sites* e/ou portais do Estado do Rio de Janeiro.

Tal informação também constou no achado 02 do relatório preliminar do PRODERJ. Assim, conforme exposto anteriormente, reputamos a concordância do jurisdicionado com a situação encontrada neste achado e as propostas de encaminhamento.

Diante de tal situação, será proposta **DETERMINAÇÃO** para que o PRODERJ promova a comunicação criptografada entre os portais hospedados e o usuário, especialmente com uso de certificados válidos, fazendo tal aspecto constar em sua análise de vulnerabilidades.

4.3.9.4 Causas

- Não investigadas.

4.3.9.5 Efeitos

- Perda de confiança por parte dos usuários ao acessar um portal com riscos de segurança;
- Risco de violação ou adulteração de dados, que pode afetar a integridade e a veracidade das informações armazenadas ou transmitidas pelo portal;
- Risco de repúdio de transação, que pode impedir que uma parte envolvida em uma operação realizada pelo portal possa comprovar a sua autoria ou participação;
- Exposição a riscos legais, regulatórios e contratuais, podendo acarretar multas, sanções e processos judiciais.

4.3.9.6 Propostas de Encaminhamento

- **Comunicação com Determinação** para que o PRODERTJ, com fulcro no art. 11, caput, no § 3º e no § 4º, todos da Instrução Normativa PRODERTJ/PRE nº 03/2022, bem como nas boas práticas constantes no Controles CIS v8, Controle 3 – Proteção de dados, promova a comunicação criptografada entre os portais hospedados e o usuário, especialmente através do uso de HTTPS e certificados válidos, fazendo tais aspectos constar em sua análise de vulnerabilidades.

4.3.10. Achado 10 – Atraso na análise e emissão de parecer das solicitações de contratação de TIC dos órgãos do nível setorial do SETIC

4.3.10.1 Critérios

- Decreto Estadual nº 47.278/2020, art. 5º, inciso XVII, XVIII, alínea d);
- Decreto Estadual nº 47.278/2020, art. 6º, inciso I e III, art. 7º;

- Instrução Normativa PRODERJ/PRE nº 01/2021, art. 6º, §2º.

4.3.10.2 Evidências

- Resposta¹⁰² ao item 08 do TSID02 enviado às organizações integrantes do nível setorial do SETIC em que foi solicitado os processos de contratação de bens e serviços de TIC;
- Extratos¹⁰³ dos processos SEI de contratação de bens e serviços de TIC realizados por órgãos do nível setorial do SETIC que tiveram tramitação pelo PRODERJ e manifestação intempestiva dos setores técnicos.

4.3.10.3 Situação Encontrada

O Decreto Estadual nº 47.278/2020, que reestrutura a organização do Sistema Estadual de Tecnologia da Informação e Comunicação - SETIC, no art. 5º, inciso XVII, atribui ao Diretor Geral do Sistema a competência de realizar os procedimentos de contratação das soluções de TIC com finalidade de atender as necessidades dos órgãos e entidades da Administração Pública.

Nesse contexto, a norma dispõe no art. 5º, XVIII, alínea d), que cabe ao Diretor Geral disciplinar por meio de atos, regulamentos e instruções normativas as contratações, acordos e aditivos às soluções de TIC das organizações da Administração e no art. 7º estabelece que os processos de contratação de TIC só poderão seguir para a fase externa ou, no caso de contratação direta ou aditivos, para assinatura do respectivo instrumento, após o envio e anuência do PRODERJ.

Para regulamentar o processo para contratações de TIC no âmbito do Poder Executivo o PRODERJ editou a Instrução Normativa PRODERJ/PRE nº 01/2021 (IN01) em 26 de fevereiro de 2021 que esclarece em seu art. 4º que os órgãos e entidades integrantes da Administração Direta e Indireta do Poder Executivo que pretenderem realizar contratação de solução de TIC deverão encaminhar solicitação à Presidência do PRODERJ.

¹⁰² Presente no Anexo 004 do relatório.

¹⁰³ Presente na pasta "Achado 10 – Atraso" do Anexo 012.

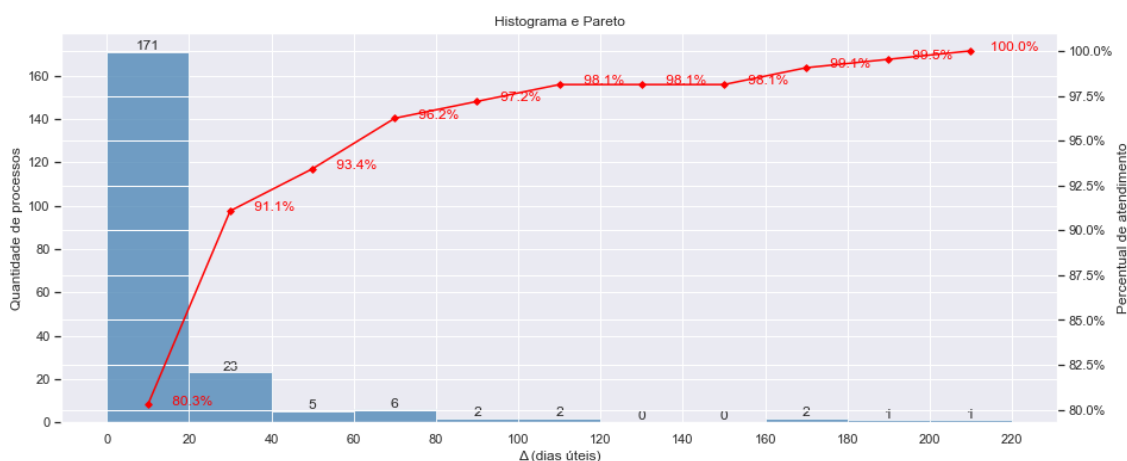
Após o envio da solicitação, o PRODERJ deverá analisar¹⁰⁴ a possibilidade e viabilidade da contratação nos termos demandados e emitir um parecer técnico no prazo¹⁰⁵ de 20 dias úteis, prorrogáveis pela Presidência, após justificativa da área técnica, por mais 20 dias úteis.

Para avaliar a adequação do prazo de elaboração do parecer técnico pelo PRODERJ foram analisados os processos de contratação informados pelos órgãos do nível setorial do SETIC em resposta ao item 08 do TSID02, iniciados a partir da vigência da IN e que tiveram tramitação ao PRODERJ.

Desse conjunto de processos supracitados, considerando o fluxo de tramitação em que a demanda era recebida pela Presidência, analisada pela área técnica da organização, devolvida à Presidência e enviada ao solicitante, foram observadas as datas de entrada e saída ao PRODERJ.

Nesse procedimento foram avaliados 147 processos SEI diferentes e 212 fluxos de tramitação, uma vez que em cada processo poderia constar mais de uma solicitação ao Diretor Geral.

Dessa visão analítica observa-se um quadro que cerca de 80% das tramitações foram realizadas no prazo inicial de 20 dias úteis:



Sintetiza-se:

Média (du)	Mediana (du)	Máximo (du)
------------	--------------	-------------

¹⁰⁴ Instrução Normativa PRODERJ/PRE nº 01/2021, art. 6º, *caput* - A Presidência do PRODERJ, após o recebimento da solicitação, encaminhará à área técnica da Autarquia, para análise e emissão de parecer acerca da viabilidade e possibilidade da contratação nos termos pretendidos.

¹⁰⁵ Conforme disposto no §2º do art. 6º da Instrução Normativa PRODERJ/PRE nº 01/2021.

Prazos em dias úteis (du) dos fluxos de tramitações analisados	16.36 dias úteis	7 dias úteis	210 dias úteis
---	------------------	--------------	----------------

Constata-se que existem casos na amostra que extrapolam o prazo limite definido na norma. Segmentando os dados pelo ano em que os processos deram entrada no PRODERJ, observa-se que há uma redução gradual no tempo de tramitação dos processos de contratação quando sob sua tutela, segue:

	# tramitações	Média (du)	Mediana (du)	Máximo (du)	% atendimento do prazo
2021	45	26.58 dias úteis	12 dias úteis	187 dias úteis	71.11%
2022	109	16.40 dias úteis	6 dias úteis	210 dias úteis	79.82%
2023	58	8.34 dias úteis	5.5 dias úteis	40 dias úteis	91.38%

Ressalte-se que o cenário apresentado acima trata apenas os casos em que o fluxo de tramitação teve sua recepção pela Presidência da entidade, passagens pelos setores técnicos e resposta ao órgão demandante pela Presidência.

Não considera os casos em que uma solicitação foi recebida e está pendente de resposta por setores do Diretor Geral, como no Processo SEI-080001/012290/2023, em que a Secretaria Estadual de Saúde (SES) solicita ao PRODERJ a contratação de ativos de rede. Neste caso, o primeiro atendimento ocorre no prazo devido (20 dias úteis), o órgão por motivação própria recorre do parecer exarado pelo Diretor Geral e solicita novo exame da solicitação, que foi recebida dia 18/10/2023, mas ainda não teve resposta proferida.

No mesmo contexto ocorreu o Processo SEI-080001/003991/2022 em que, no dia 31/10/2023, a Secretaria Estadual de Saúde (SES) solicita ao PRODERJ, pela segunda vez, após negativa, a possibilidade de se autorizar uma contratação de caráter excepcional à IN01 que ainda está pendente de resposta.

Outros casos que ocorreram ao longo do ano de 2023 e que podem ser apresentados são os do Processo SEI-240002/000983/2022, SEI-080007/017976/2022 e SEI-150015/000652/2021.

Quanto ao primeiro, houve, no dia 06/03/2023, uma prévia consulta ao PRODERJ, como órgão gerenciador da Ata de Registro de Preço para realização de reajuste contratual entre o contratante, PROCON, e a contratada. A resposta à organização ocorreu no dia 05/04/2023, 23 dias úteis depois.

Em relação ao segundo, houve, no dia 05/05/2023, uma solicitação feita pela Fundação Saúde (FS) para contratação de serviços de TI, que, pela ausência de Ata de Registro de Preço vigente para o objeto, elaborou-se parecer permitindo a exceção e consequente condução do processo de contratação pela solicitante. A resposta à organização ocorreu no dia 23/06/2023, 35 dias úteis depois.

Por fim, no terceiro processo, houve, no dia 23/05/2023, uma solicitação de renovação contratual feita pela contratante, Imprensa Oficial (IO), e a contratada, PRODERJ. Após análise e manifestação da área responsável pelo atendimento à demanda, a resposta foi remetida no dia 18/07/2023, 40 dias úteis depois.

Consolida-se:

Processo SEI	Data entrada no PRODERJ	Data saída do PRODERJ	Δ (dias úteis)
SEI-240002/000983/2022	06/03/2023	05/04/2023	23
SEI-080007/017976/2022	05/05/2023	23/06/2023	35
SEI-150015/000652/2021	23/05/2023	18/07/2023	40
SEI-080001/012290/2023	18/10/2023	12/12/2023 (presente data)	37
SEI-080001/003991/2022	31/10/2023	12/12/2023 (presente data)	28

Em que pese a diversidade de solicitações recebidas, os esforços empreendidos pela organização e a melhoria apresentada ao longo do período de 2021 a 2023, ainda ocorrem descumprimentos ao prazo estipulado no §2º, art. 6º da Instrução Normativa PRODER/PRE nº 01/2021.

A não tempestividade do atendimento às solicitações realizadas ao Diretor Geral geram atrasos nos processos de contratação das organizações do nível setorial do SETIC e causam a perda de confiança na estrutura do Sistema.

Dos Comentários do Gestor

Com base na análise dos pontos supracitados, foi submetido ao PRODERJ o relatório preliminar com a situação encontrada e proposta de encaminhamento para oferta de comentários do gestor¹⁰⁶. Em sua resposta¹⁰⁷, a autarquia informa:

No tocante ao achado 3, informamos que alguns processos de solicitações de contratações de TIC não são devidamente instruídos com os documentos necessários para viabilização da emissão de parecer técnico desta Autarquia, tais como: Documento de Oficialização de Demanda - DOD, Documento de Formalização de Demanda - DFD, Estudo Técnico Preliminar - ETP, ou Termo de Referência - TR.

Diante desse cenário, é preciso recorrer ao órgão ou entidade solicitante para que este vício seja sanado, protelando o tempo para o atendimento integral da demanda pleiteada.

Salientamos que nos casos apresentados no presente achado, estamos mitigando tais problemas de prazos com o controle mensal de SEI com mais de 30 dias sem resposta; o qual é repassado para as Vice-Presidências com vistas à realização das providências cabíveis para a resolução efetiva destes processos.

Por fim, informamos que os apontamentos do TCE no Anexo - Relatório Individual Preliminar serão considerados nos próximos monitoramentos.

Sobre esse aspecto, insta consignar que o achado 03 presente no Relatório Preliminar do PRODERJ corresponde a este achado 10. Assim, como o jurisdicionado informa que estão mitigando os problemas relatados no achado e que considerarão tais apontamentos em seu controle interno de prazos do SEI, reputamos, a concordância do jurisdicionado com a situação encontrada e as propostas de encaminhamento.

Dessa forma, será proposta **DETERMINAÇÃO** ao PRODERJ para que estabeleça um controle interno adequado e tempestivo para monitorar os prazos de atendimento às demandas resultantes da Instrução Normativa PRODERJ/PRE nº 01/2021.

¹⁰⁶ Conforme TSID05 presente no Anexo 003.

¹⁰⁷ Comentários do gestor presente na resposta ao TSID05 encontrado no Anexo 004.

4.3.10.4 Causas

- Não investigadas.

4.3.10.5 Efeitos

- Redução na eficiência do processo de elaboração das atas de registro de preço;
- Atraso no prazo de conclusão das atas de registro de preço;
- Perda de confiança em sua atuação como integrador de soluções de TIC do Poder Executivo do ERJ.

4.3.10.6 Propostas de Encaminhamento

- **Comunicação com Determinação** para que o PRODERJ, com fulcro no Decreto Estadual n.º 47.278/2020, art. 5º, inciso XVII, XVIII, alínea d) e art. 7º, estabeleça controle interno adequado e tempestivo para monitorar os prazos de atendimento às solicitações que tratem de contratações de bens e serviços de TIC, conforme disposto no §2º, art. 6º da Instrução Normativa PRODERJ/PRE nº 01/2021.

5. COMENTÁRIOS DO GESTOR

Como parte dos procedimentos de uma auditoria com contornos operacionais, os achados foram separados num relatório preliminar e encaminhados para que o jurisdicionado, junto com sua equipe, tivesse a oportunidade de analisar a situação encontrada, critérios e propostas de encaminhamentos dispostas pela Equipe de Auditoria e apresentasse suas considerações e esclarecimentos a fim de contribuir para a melhoria da eficácia e efetividade dos resultados da fiscalização.

Para tanto, foi encaminhado o TSID04 aos órgãos integrantes do nível setorial do SETIC e o TSID05 ao PRODERJ com relatórios preliminares individualizados contendo seus respectivos achados.

Os comentários foram divididos, analisados e sintetizados de acordo com os achados encontrados.

5.1. Achado 01 - Estrutura organizacional do Setor de TI inadequada

Em relação ao achado 01 sobre a estrutura organizacional do setor de TI, as organizações declararam uma ampla concordância (cerca de 85%) com o disposto na situação encontrada e com o encaminhamento proposto pela Equipe no relatório preliminar.

Dos que concordaram, aproximadamente 74% desses estimam atender às propostas de encaminhamento num prazo de até 24 meses.

Dos que discordaram, as principais alegações estão relacionadas a se o setor de TI está vinculado à Alta Administração ou não. Os jurisdicionados consideram que a subordinação da área de TI à alta gestão é adequada.

5.2. Achado 02 - Ausência de elaboração ou revisão do PEDTIC

Em relação ao achado 02 sobre a ausência de elaboração ou revisão do PEDTIC pelas organizações do nível setorial do SETIC, as organizações declararam uma ampla concordância (cerca de 75%) com o disposto na situação encontrada e com o encaminhamento proposto pela Equipe no relatório preliminar.

Dos que concordaram, todos estimam atender às propostas num prazo de até 24 meses e a ampla maioria deste grupo (aproximadamente 85%) espera atender no curto prazo de até 6 meses.

Dos que discordaram, as principais alegações são que as organizações já elaboraram seus PEDTICs e foram fornecidos esclarecimentos e informações acerca de onde se encontram.

5.3. Achado 03 - Ausência de Comitê Permanente do PEDTIC

Em relação ao achado 03 sobre a ausência de Comitê Permanente do PEDTIC das organizações do nível setorial do SETIC, as organizações declararam uma ampla concordância (cerca de 74%) com o disposto na situação encontrada e com o encaminhamento proposto pela Equipe no relatório preliminar.

Dos que concordaram, 92% estimam atender às propostas num prazo de até 24 meses e a ampla maioria (aproximadamente 76%) espera atender no curto prazo de até 6 meses.

Dos que discordaram, os argumentos foram que já possuem órgãos próprios com atribuições equivalentes às previstas no PEDTIC. Além disso, alguns desses órgãos apresentaram informações que apontam a existência desses comitês.

5.4. Achado 04 - Práticas de gestão de serviço de TI incipientes

Em relação ao achado 04 sobre a incipiência na adoção de práticas de gestão de serviços de TI pelas organizações do nível setorial do SETIC, as organizações declararam uma unânime concordância com o disposto na situação encontrada e com o encaminhamento proposto pela Equipe no relatório preliminar.

Dos que concordaram, aproximadamente 84% estimam atender às propostas num prazo de até 24 meses e uma menor parte (aproximadamente 21%) espera atender no curto prazo de até 6 meses.

5.5. Achado 05 - Práticas de gestão de segurança da informação incipientes

Em relação ao achado 05 sobre a incipiência na adoção de práticas de gestão de segurança da informação pelas organizações do nível setorial do SETIC, as organizações declararam uma ampla concordância (cerca de 94%) com o disposto na

situação encontrada e com o encaminhamento proposto pela Equipe no relatório preliminar.

Dos que concordaram, aproximadamente 93% estimam atender às propostas num prazo de até 24 meses e uma menor parte (aproximadamente 33%) espera atender no curto prazo de até 6 meses.

Dos que discordaram, os argumentos foram que a responsabilidade pela segurança da informação seria das organizações que prestam apoio e suporte de TI para eles, como seria o caso da INEA com a SEAS e da SECC com a Vice Governadoria.

5.6. Achado 06 - Gestão de recursos humanos de TI inadequada

Em relação ao achado 06 sobre a inadequação das práticas de gestão de recursos humanos de TI pelas organizações do nível setorial do SETIC, as organizações declararam uma ampla concordância (cerca de 94%) com o disposto na situação encontrada e com o encaminhamento proposto pela Equipe no relatório preliminar.

Dos que concordaram, aproximadamente 64% estimam atender às propostas num prazo de até 24 meses e uma pequena parte (aproximadamente 18%) espera atender no curto prazo de até 6 meses.

Dos que discordaram, os argumentos foram que não têm em sua estrutura cargos específicos para tecnologia da informação, mas que mesmo assim possuem profissionais de TI trabalhando na organização. Outros aspectos informados foram de que a organização realiza anualmente seu mapeamento de necessidades de capacitação.

5.7. Achado 07 - Contratações de TI não aderentes com os dispositivos da Instrução Normativa PRODERJ/PRE nº 01/2021

Em relação ao achado 07 sobre a ausência da anuência do PRODERJ nos processos de contratação de TIC das organizações do nível setorial do SETIC, as organizações declararam uma ampla concordância (cerca de 74%) com o disposto na situação encontrada e com o encaminhamento proposto pela Equipe no relatório preliminar.

Dos que concordaram, a maioria (57%) declarou já estar tomando medidas para atender aos encaminhamentos e aproximadamente 92% estimam atender às propostas em um prazo de até 24 meses.

Dos que discordaram, os argumentos trazidos à auditoria foram que tais organizações atendem ao normativo, tendo sido apresentados esclarecimentos e informações, como outros processos SEI, para suportar suas alegações.

5.8. Achado 08 - Portais institucionais em produção sem análise de vulnerabilidades pelo Diretor Geral do SETIC

Em relação ao achado 08, o PRODERJ informa que após analisados os apontamentos irão considerar os encaminhamentos propostos pela Equipe em seus futuros monitoramentos.

5.9. Achado 09 - Portais institucionais em produção sem proteção de dados na comunicação com o usuário

Em relação ao achado 09, o PRODERJ informa que, após analisados os apontamentos, estão de acordo com as recomendações propostas pela Equipe.

5.10. Achado 10 - Atraso na análise e emissão de parecer das solicitações de contratação de TIC dos órgãos do nível setorial do SETIC

Em relação ao achado 10, o PRODERJ informa que alguns processos de solicitações de contratações de TIC não são devidamente instruídos com os documentos de planejamento necessários para viabilização da emissão de parecer técnico desta Autarquia.

Dessa forma, seria preciso recorrer ao órgão ou entidade solicitante para que este vício seja sanado, protelando o tempo para o atendimento integral da demanda pleiteada.

Informa ainda que possui um controle mensal de processos SEI com vistas à realização das providências cabíveis para a resolução efetiva destes processos.

Por fim, informa que os apontamentos serão considerados nos próximos monitoramentos.

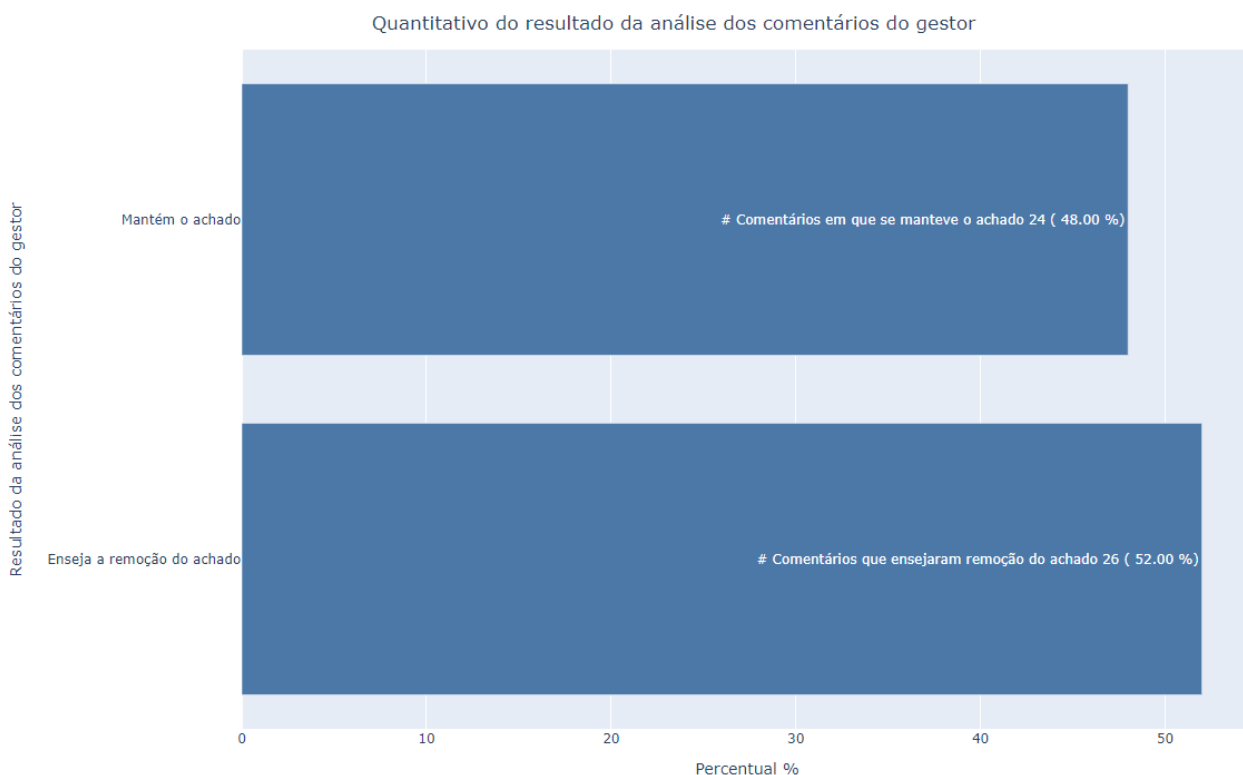
6. ANÁLISE DA EQUIPE

Conforme exposto na seção anterior do presente relatório, os achados foram separados em um relatório preliminar e encaminhados para que o jurisdicionado pudesse ter a oportunidade de tecer seus comentários acerca da situação encontrada e dos encaminhamentos propostos pela equipe de auditoria.

As considerações das organizações que integram o nível setorial do SETIC foram analisadas pela Equipe de Auditoria e o resultado individual das avaliações encontram-se nos relatórios individuais finais dos jurisdicionados, presentes no Anexo “012 – Relatórios individualizados dos jurisdicionados”.

De forma geral os jurisdicionados concordaram com as recomendações e determinações propostas pela equipe de auditoria, fazendo algumas ressalvas e apresentando contrapontos, conforme pode ser observado na seção anterior (comentários do gestor).

Em relação às divergências encontradas, essas foram analisadas pela equipe e, caso aceitas, ensejaram a remoção do achado para aquela organização. A figura a seguir apresenta o quantitativo dos comentários de discordância em que a análise resultou em remoção do achado:



Nesse sentido, nota-se que 52% dos comentários de discordância ensejaram a remoção do achado. Esses comentários ofereceram novas informações que não foram remetidas anteriormente nas respostas aos TSIDs. Podemos citar, como exemplo, a instituição do Comitê Permanente do PEDTIC pela organização após a averiguação desta equipe de auditoria por meio do TSID02.

7. CONSIDERAÇÕES FINAIS

O presente relatório trata de Auditoria de Conformidade com aspectos operacionais realizada no âmbito dos 75 órgãos integrantes do SETIC, com o objetivo de verificar os aspectos das políticas de Governança e Gestão de TI enquanto norteadores das contratações de Tecnologia da Informação do Executivo Estadual no âmbito do SETIC, analisando, de forma subsidiária, a regularidade das contratações enquanto reflexo de tais políticas.

As análises apontaram um cenário de baixa adesão dos órgãos setoriais do SETIC aos normativos expedidos pelo PRODERJ, como órgão Diretor Geral do Sistema, e um nível incipiente na adoção das boas práticas de governança e gestão de TI.

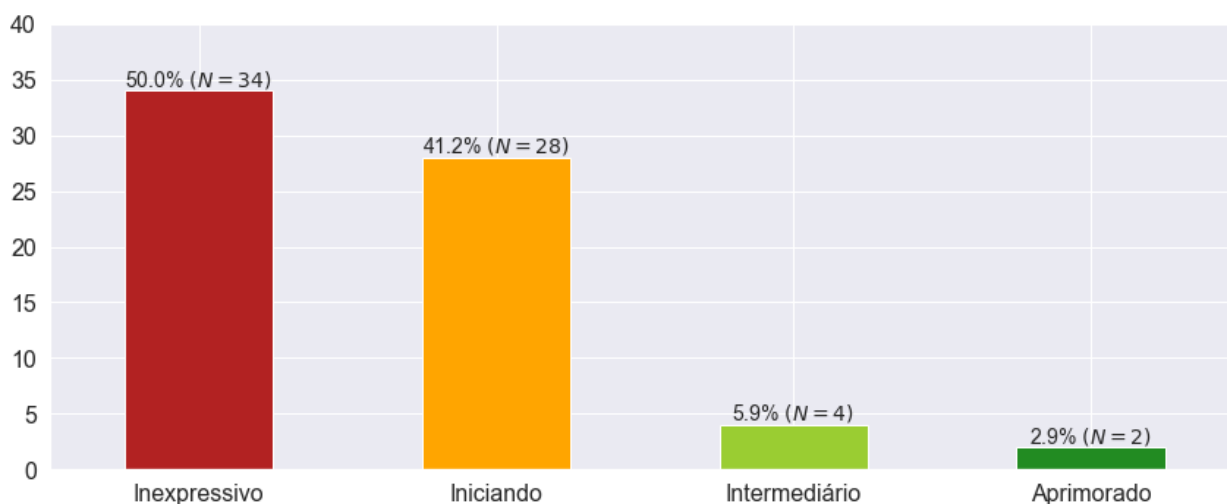


Figura 3 - Níveis de maturidade em práticas de governança e gestão de TI pelos órgãos do nível setorial do SETIC

Da percepção dos gestores de TI das organizações integrantes do nível setorial do SETIC acerca do Sistema, verificou-se que, em geral, a atuação do PRODERJ como Diretor Geral é considerada positiva e satisfatória. Contudo, foram apresentadas críticas, principalmente, quanto a sua atuação como integrador de soluções de TIC do ERJ.

Da atuação do PRODERJ verificou-se, apesar de melhorias graduais, falhas no atendimento dos prazos para avaliar as solicitações de contratação de TIC, assim como falhas na segurança dos portais sob sua gestão.

Foi possível mensurar uma evolução na adoção às boas práticas de governança e gestão de TI por parte dos órgãos do SETIC, quando se verificou uma ampla majoração no índice iGovTI do trabalho¹⁰⁸ realizado em 2020 para a fiscalização atual.

Para sanear esse quadro geral, foram propostas determinações e recomendações aos órgãos integrantes do SETIC.

Ao término da fase de execução da auditoria foram submetidos relatórios preliminares aos jurisdicionados a fim de coletar seus comentários quanto aos achados, conclusões e encaminhamentos propostos pela Equipe, concluindo assim o caráter dialógico do trabalho realizado.

Dessa forma, por meio desses itens apontados foi possível constatar o caráter indutor e orientador da auditoria corrente que, em conjunto com as determinações e recomendações comunicadas, ensejará uma melhora dos órgãos integrantes do SETIC quanto à adoção das boas práticas de governança e gestão de TI e cumprimento dos normativos editados pelo Diretor Geral do Sistema.

¹⁰⁸ Levantamento, Processo TCE-RJ nº 105.096-3/2020 que tinha por objetivo verificar aspectos-chaves de governança de TI dos principais entes que fazem uso de tecnologia da informação da esfera estadual, mensurando o indicador de governança de TI (iGovTI) de cada um desses entes.

8. PROPOSTA DE ENCAMINHAMENTO

CONSIDERANDO o pleno atendimento ao objetivo proposto pela auditoria, qual seja, o de verificar os aspectos das políticas de Governança e Gestão de TI enquanto norteadores das contratações de Tecnologia da Informação do Executivo Estadual no âmbito do SETIC, analisando, de forma subsidiária, a regularidade das contratações enquanto reflexo de tais políticas;

CONSIDERANDO a matriz de achados anexa ao presente relatório (Anexo 006 - Matriz de Achados);

CONSIDERANDO as atribuições desta Coordenadoria previstas no Ato Normativo nº 206, de 27 de maio de 2021;

CONSIDERANDO a baixa adesão dos órgãos setoriais do SETIC aos normativos expedidos pelo PRODERJ, como órgão Diretor Geral do SETIC;

CONSIDERANDO o nível incipiente na adoção de boas práticas de governança e gestão de TI pelos órgãos setoriais do SETIC;

CONSIDERANDO o caráter orientador e dialógico do presente trabalho, assim como o alinhamento à diretriz de incremento de eficiência e efetividade na gestão administrativa;

CONSIDERANDO que os resultados decorrentes das ações previstas no Plano de Ação poderão ser objeto de avaliação futura por meio de Monitoramento, considerando os preceitos definidos na Resolução TCE-RJ nº 302/17;

Sugere-se ao Egrégio Plenário desta Corte de Contas a adoção das seguintes propostas:

- 1. COMUNICAÇÃO ao atual Presidente do PRODERJ**, nos termos do artigo 15, inciso I, do Regimento Interno deste Tribunal, para que cumpra as **DETERMINAÇÕES** abaixo, alertando-o de que o não atendimento injustificado o sujeita às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas:

- 1.1. **DETERMINAÇÃO:** Estruturar, no prazo máximo de 60 (sessenta) dias a contar da ciência da decisão plenária, as medidas a serem adotadas pelo PRODERJ para solucionar os problemas identificados pela **presente Auditoria** em um Plano de Ação no modelo a seguir, registrando esse plano em um Processo Administrativo no Sistema Eletrônico de Informações (SEI), observando as determinações e recomendações relacionadas no tópico a seguir.

Plano de Ação				
Determinação / Recomendação	O que fazer	Como fazer	Quem vai fazer	Quando fazer

- 1.2. **DETERMINAÇÃO:** para que, com fulcro no art. 15, § 1º, art. 15, § 2º, e da matriz de responsabilidades constante do Anexo Único, todos da Instrução Normativa PRODERJ/PRE nº 03/2022, bem como das boas práticas constantes no Controles CIS v8, Controle 7 - Gestão contínua de vulnerabilidades (ACHADO 08):

- elabore um procedimento de avaliação de vulnerabilidade periódico para gerar o relatório de vulnerabilidade do *site* e/ou portal que se encontre no modelo de Administração Total e Parcial, mantendo o registro dessa avaliação de forma perene;
- exija dos clientes que mantêm portais e/ou *sites* no modelo de Administração Cliente relatórios de análise de vulnerabilidade de forma periódica, mantendo o registro dessa avaliação de forma perene, analisando a criticidade das eventuais vulnerabilidades e cobrando as devidas ações de correção dos clientes.

- 1.3. **DETERMINAÇÃO:** para que, com fulcro no art. 11, caput, no § 3º e no § 4º, todos da Instrução Normativa PRODERJ/PRE nº 03/2022, bem como nas boas práticas constantes no Controles CIS v8, Controle 3 – Proteção de dados, promova a comunicação criptografada entre os portais hospedados e o usuário, especialmente através do uso de HTTPS e certificados válidos,

fazendo tais aspectos constar em sua análise de vulnerabilidades. (ACHADO 09)

- 1.4. **DETERMINAÇÃO:** para que, com fulcro no Decreto Estadual n.º 47.278/2020, art. 5º, inciso XVII, XVIII, alínea d) e art. 7º, estabeleça controle interno adequado e tempestivo para monitorar os prazos de atendimento às solicitações que tratem de contratações de bens e serviços de TIC, conforme disposto no §2º, art. 6º da Instrução Normativa PRODERJ/PRE nº 01/2021. (ACHADO 10)
 - 1.5. **RECOMENDAÇÃO:** para que, pelo princípio da transparência e controle, edite sua orientação aos órgãos participantes das atas de registro de preço de forma que esses comuniquem a formalização dos contratos das aquisições resultantes das ARP não apenas por e-mail, mas também se registre nos autos do processo administrativo SEI. (ACHADO 07)
 - 1.6. **RECOMENDAÇÃO:** detalhe as obrigações do PRODERJ e do cliente em relação ao portal hospedado, abarcando os requisitos para a análise de vulnerabilidade, no instrumento contratual (ACHADO 08).
-
2. **COMUNICAÇÃO aos órgãos do nível setorial do SETIC elencados a seguir**, nos termos do artigo 15, inciso I, do Regimento Interno deste Tribunal, para que cumpram as **DETERMINAÇÕES** abaixo, alertando-o de que o não atendimento injustificado o sujeita às sanções previstas no art. 63 da Lei Complementar Estadual n.º 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - 2.1. **DETERMINAÇÃO:** Estruturar, no prazo máximo de 60 (sessenta) dias a contar da ciência da decisão plenária, as medidas a serem adotadas para solucionar os problemas identificados pela **presente Auditoria** em um Plano de Ação no modelo a seguir, registrando esse plano em um Processo Administrativo no Sistema Eletrônico de Informações (SEI), observando as determinações e recomendações relacionadas no tópico a seguir.

Plano de Ação

Determinação / Recomendação	O que fazer	Como fazer	Quem vai fazer	Quando fazer

ORGANIZAÇÕES: AGENERSA, AGERIO, AGETRANSP, CASERJ, CEASA, CECIERJ, CEHAB, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, Vice Governadoria, IASERJ, IEEA, INEA, IO, IPEM/RJ, IRM, ISP, ITERJ, IVB, JUCERJA, LOTERJ, PESAGRO, PGE, PROCON, RIOPREVIDÊNCIA, RIOTRILHOS, RJPREV, SEAP, SEAPPA, SEAS, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV, SEIC, SEPLAG, SEPM, SEPOL, SERGB, SES, SETD, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

2.2. **DETERMINAÇÃO:** estabeleçam formalmente um processo estruturado, com participação de representantes dos setores da organização, aos moldes descritos na Portaria PRODERJ/PRE nº 825/2021, visando elaborar, manter e revisar periodicamente um Plano Estratégico e Diretor de Tecnologia da Informação, o qual deve contemplar minimamente (ACHADO 02):

- objetivos, indicadores e metas de TI, alinhados aos objetivos de negócio;
- identificação dos riscos que possam impactar no cumprimento dos objetivos estratégicos e das metas de TI;
- projetos, aquisições e demais ações necessárias para o atingimento das metas fixadas e/ou para a mitigação de riscos de TI;
- alocação de recursos (financeiros, humanos tecnológicos etc.) necessários para a execução do plano.

ORGANIZAÇÕES: AGENERSA, AGERIO, AGETRANSP, CEASA, CECIERJ, CEHAB, CENTRAL, CEPERJ, CODERTE, CODIN, DEGASE, DER/RJ,

DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FTMRJ, FUNARJ, IASERJ, IEEA, IO, IPER/RJ, IRM, ITERJ, IVB, LOTERJ, PESAGRO, PGE, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEGOV, SEIC, SEPLAG, SEPM, SES, SETD, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

- 2.3. **DETERMINAÇÃO:** instituem o Comitê Permanente do PEDTIC com representantes dos setores da organização a fim de planejar, elaborar, revisar e monitorar o instrumento de Planejamento Estratégico e Diretor de Tecnologia da Informação – PEDTIC. (ACHADO 03)

ORGANIZAÇÕES: AGETRANS, CEASA, CODERTE, CODIN, DETRO, DRM, EMATER, FAETEC, FIA/RJ, FIPERJ, FLXIII, FS, FTMRJ, GVG, IEEA, IO, IRM, LOTERJ, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SECEC, SEDEC, SEELJE, SEGOV, SEIC, SEPM, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

- 2.4. **DETERMINAÇÃO:** elaborem, aprovem e publiquem a Política de Segurança da Informação (PSI), alinhada à Instrução Normativa PRODERJ/PRE nº 02/2022, e adotem as boas práticas estabelecidas na Norma Técnica NBR ISO/IEC 27002/2022, dispondo, ao menos, de princípios, diretrizes, procedimentos, responsabilidades, competências e outros controles que julgarem necessários para garantir de forma razoável a segurança da informação de sua organização. (ACHADO 05)

ORGANIZAÇÕES: AGENERSA, AGETRANS, CEASA, CECIERJ, CEHAB, CENTRAL, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IEEA, INEA, IO, IPER/RJ, IRM, ITERJ, IVB, LOTERJ, PESAGRO, PGE, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE,

SEPLAG, SEPM, SERGB, SES, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

- 2.5. **DETERMINAÇÃO:** elaborem e mantenham procedimentos de segurança da informação, com normas claras, objetivas, revisadas e divulgadas regularmente, com base nas diretrizes estabelecidas na Instrução Normativa PRODERJ nº 02/2022, acompanhada de seu Anexo, e nos normativos do órgão de Direção Geral do Sistema Estadual de Tecnologia da Informação e Comunicação – SETIC. (ACHADO 05)

ORGANIZAÇÕES: AGENERSA, AGETRANSP, CEASA, CECIERJ, CEHAB, CENTRAL, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IEEA, INEA, IO, IPEM/RJ, IRM, ITERJ, IVB, LOTERJ, PESAGRO, PGE, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEPLAG, SEPM, SERGB, SES, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

- 2.6. **DETERMINAÇÃO:** para que, conforme preceitua o art. 11, inc. VI, alínea a, da Instrução Normativa PRODERJ nº 02/2022 e o disposto no controle 5.2 - Papéis e responsabilidades pela segurança da informação - da Norma Técnica NBR ISO/IEC 27002/2022 (ACHADO 05):

- designem formalmente um Gestor de Segurança da Informação dentre os servidores públicos civis ou militares ocupantes de cargos efetivos, desde que lotados no órgão ou entidade e com formação ou capacitação técnica compatível às suas atribuições, na forma do § 1º do art. 17 da Instrução Normativa PRODERJ nº 02/2022, com, no mínimo, as competências arroladas nos incisos do art. 17 do mesmo normativo.

ORGANIZAÇÕES: AGENERSA, AGETRANSP, CEASA, CECIERJ, CEHAB, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ,

DETRAN, DETRO, DRM, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IEEA, INEA, IO, IPERJ/RJ, IRM, ISP, ITERJ, IVB, JUCERJA, LOTERJ, PESAGRO, PGE, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV, SEPLAG, SEPM, SERGB, SES, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

2.7. **DETERMINAÇÃO:** para que conforme preceitua o art. 11, inc. VI, alínea b, da Instrução Normativa PRODERJ nº 02/2022 e disposto no controle 5.2 - Papéis e responsabilidades pela segurança da informação - da Norma Técnica NBR ISO/IEC 27002/2022 (ACHADO 05):

- designem formalmente um Responsável pelo Tratamento e Resposta a Incidentes dentre os servidores públicos civis ou militares ocupantes de cargos efetivos, desde que lotados no órgão ou entidade e com formação ou capacitação técnica compatível às suas atribuições, na forma do § 1º do art. 18 da Instrução Normativa PRODERJ nº 02/2022, com, no mínimo, as competências arroladas nos incisos do art. 18 do mesmo normativo;

ORGANIZAÇÕES: AGENERSA, AGETRANS, CEASA, CECIERJ, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IEEA, INEA, IO, IPERJ/RJ, IRM, ISP, ITERJ, IVB, JUCERJA, LOTERJ, PESAGRO, PGE, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV, SEPM, SERGB, SES, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

2.8. **DETERMINAÇÃO:** nos próximos processos de contratação de objetos de TIC remetam suas solicitações de contratação e/ou renovação ao Diretor Geral do PRODERJ para que recebam sua anuência, conforme disposto no art. 4º da

Instrução Normativa PRODERJ/PRE nº 01/2021 c/c art. 7º do Decreto Estadual nº 47.278/2020. (ACHADO 07)

ORGANIZAÇÕES: CECIERJ, CENTRAL, CEPERJ, CODERTE, DEGASE, DER/RJ, DETRAN, DETRO, EMATER, EMOP, FAETEC, FS, FSC, INEA, IPEM/RJ, ITERJ, IVB, PGE, PROCON, RJPREV, SEDSODH, SEGOV, SEPM, SERGB, SES, SETUR, UENF, UERJ.

2.9. **DETERMINAÇÃO:** nos próximos processos de contratação de objetos de TIC atendam integralmente aos dispositivos elencados na Instrução Normativa PRODERJ/PRE nº 01/2021, atentando-se para (ACHADO 07):

- a solicitação de contratação de TIC deverá ser instruída com o Documento de Oficialização de Demanda e demais documentos relacionados à pesquisa preliminar de preços;
- as contratações de soluções de TIC deverão estar planejadas no respectivo PEDTIC e indicadas no Plano Anual de Contratações;
- realizar o planejamento da contratação previamente à adesão à Ata de Registro de Preço.

ORGANIZAÇÕES: AGETRANS, CEASA, CENTRAL, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRO, DRM, EMATER, FAETEC, FAPERJ, FS, FSC, IEEA, INEA, IRM, ITERJ, IVB, LOTERJ, PROCON, RIOTRILH, RJPREV, SEAPPA, SECEC, SEDEC, SEDSODH, SEELJE, SEIC, SEPM, SETRAB, SETRANS, SETUR, SUDERJ, UENF, UERJ.

2.10. **RECOMENDAÇÃO:** para que, observando as melhores práticas descritas no processo APO01 – Estrutura de gestão de TI gerenciada - do COBIT 2019 (ACHADO 01):

- Estabeleçam formalmente as estruturas organizacionais internas da área de TI conforme o projeto do sistema de gestão, possibilitando a tomada de decisões eficaz e eficiente, visando a garantir que o conhecimento necessário em tecnologia e informação esteja incluído na composição das estruturas de gestão;

- Definam e comuniquem as funções e responsabilidades para a tecnologia da informação, incluindo competências, atribuições, responsabilidades e prestação de contas, assegurando a ela, ao menos, as atribuições de planejamento, coordenação, gestão e controle da TI;
- Posicionem o setor de TI diretamente relacionado à alta administração na estrutura organizacional de forma a refletir a importância estratégica e a dependência operacional da TI dentro da organização.

ORGANIZAÇÕES: AGENERSA, AGERIO, AGETRANSP, CEASA, CEHAB, CENTRAL, CEPERJ, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IEEA, IPER/RJ, IRM, ISP, ITERJ, IVB, LOTERJ, PESAGRO, PGE, PROCON, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEGOV, SEIC, SEPLAG, SEPM, SERGB, SES, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

2.11. **RECOMENDAÇÃO:** para que, observando as boas práticas de gestão de serviços de TI elencadas no item 8.2.4 – Gerenciamento de catálogo de serviço da Norma Técnica ABNT NBR ISO/IEC 20000-1/2020 e 20000-2/2021, item 5.2.10 - *Service catalogue management* (Gerenciamento de catálogo de serviço – tradução livre) do ITIL 4 e APO09 – *Managed Service Agreements* (Acordos de serviços gerenciados – tradução livre) do COBIT 2019 (ACHADO 04):

- Elaborem e documentem seu processo de gestão de catálogo de serviços de TI, definindo indicadores e metas que permitam monitorar sua execução e propiciar sua melhoria contínua, e atribua um dono responsável ao processo para garantir sua eficácia e eficiência;
- elaborem catálogo dos serviços de TI prestados pela área de tecnologia da informação da organização, contendo, ao menos, as

descrições de cada um dos serviços, seus nomes, metas de níveis de serviço, forma de acesso e perfil do solicitante, em linguagem clara e objetiva, assegurando que ele seja de fácil acesso, atualizado periodicamente e amplamente disponível para seus usuários;

ORGANIZAÇÕES: AGENERSA, AGETRANSP, CEASA, CECIERJ, CEHAB, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, FAETEC, FAPERJ, FIA/RJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, IEEA, INEA, IO, IPER/RJ, IRM, ISP, ITERJ, IVB, JUCERJA, LOTERJ, PESAGRO, PGE, PROCON, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV, SEPLAG, SEPM, SERGB, SETD, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

2.12. **RECOMENDAÇÃO:** para que, observando as boas práticas de gestão de serviços de TI elencadas no item 8.2.5 - Gerenciamento de ativos e 8.2.6 – Gerenciamento de configuração da Norma Técnica ABNT NBR ISO/IEC 20000-1/2020 e 20000-2/2021, itens 5.2.6 - *IT asset management* (Gerenciamento de ativos de TI – tradução livre) e 5.2.11 *Service configuration management* (Gerenciamento de ativos de TI – tradução livre) do ITIL4 (ACHADO 04):

- Elaborem e documentem seu processo de gestão de configuração e ativos de TI, definindo indicadores e metas que permitam monitorar sua execução e propiciar sua melhoria contínua, e atribua um dono responsável ao processo para garantir sua eficácia e eficiência;
- Estabeleçam base de dados consolidada que contenha registro dos ativos e itens de configuração que são mapeados e gerenciados pela organização, preferencialmente sob uma solução de TI, assegurando que seja permitido analisar o histórico das informações e que os dados sejam atualizados periódica e automaticamente;

ORGANIZAÇÕES: AGENERSA, AGERIO, AGETRANSP, CEASA, CECIERJ, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IEEA, INEA, IO, IPEM/RJ, IRM, ISP, ITERJ, IVB, LOTERJ, PESAGRO, PGE, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV, SEIC, SEPLAG, SEPM, SERGB, SES, SETD, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

2.13. **RECOMENDAÇÃO:** para que, observando as boas práticas de gestão de serviços de TI elencadas no item 8.6.1 - Gerenciamento de incidente da Norma Técnica ABNT NBR ISO/IEC 20000-1/2020 e 20000-2/2021, item 5.2.5 - *Incident management* (Gerenciamento de incidentes – tradução livre) do ITIL 4 e DSS02 – *Managed Service Requests and Incident* (Requisições de serviço e incidentes gerenciados – tradução livre) do COBIT 2019 (ACHADO 04):

- Elaborem e documentem seu processo de gestão de incidentes de TI, definindo indicadores e metas que permitam monitorar sua execução e propiciar sua melhoria contínua, e atribua um dono responsável ao processo para garantir sua eficácia e eficiência;
- Estabeleçam base de dados consolidada que contenha registro dos incidentes de TI e que permita que eles sejam identificados, registrados, classificados e resolvidos, preferencialmente sob uma solução informatizada;
- Elaborem base de conhecimento de erros mais frequentes e conhecidos;

ORGANIZAÇÕES: AGENERSA, AGETRANSP, CEASA, CECIERJ, CEHAB, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IEEA, INEA, IO, IPEM/RJ, IRM, ISP, ITERJ, IVB, LOTERJ, PESAGRO, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC,

SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV, SEIC, SEPLAG, SEPM, SERGB, SES, SETD, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

2.14. **RECOMENDAÇÃO:** para que, observando as boas práticas de gestão de serviços de TI elencadas no item 8.7.2 - Gerenciamento de continuidade de serviço da Norma Técnica ABNT NBR ISO/IEC 20000-1/2020 e 20000-2/2021, item 5.2.12 - *Service continuity management* (Gerenciamento de continuidade de serviços – tradução livre) do ITIL 4 e DSS04 – *Managed Continuity* (Continuidade gerenciada – tradução livre) do COBIT 2019 (ACHADO 04):

- Elaborem e documentem seu processo de gestão de continuidade de serviços de TI, definindo indicadores e metas que permitam monitorar sua execução e propiciar sua melhoria contínua, e atribua um dono responsável ao processo para garantir sua eficácia e eficiência;
- Elaborem plano de continuidade dos serviços de TI, definindo os riscos que foram identificados, avaliados e registrados pela análise de impacto ao negócio (BIA), procedimentos a serem implementados no evento de uma interrupção significativa e procedimentos a serem executados para o retorno às condições normais de trabalho;

ORGANIZAÇÕES: AGENERSA, AGETRANSP, CEASA, CECIERJ, CEHAB, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IEEA, INEA, IO, IPEM/RJ, IRM, ITERJ, IVB, JUCERJA, LOTERJ, PESAGRO, PGE, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV, SEPLAG, SEPM, SERGB, SES, SETD, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

2.15. **RECOMENDAÇÃO:** para que considerem adotar nos seus procedimentos de segurança da informação, conforme elencado no art. 9º da Instrução Normativa PRODERJ nº 02/2022, as atividades a seguir (ACHADO 05):

- mantenham, monitorem e analisem logs de auditoria dos ativos de software, de hardware e de rede críticos para o negócio;
- implementem defesas contra malware e outras ameaças cibernéticas;
- implementem cópias regulares de segurança (backup) das informações em meio digital, incluindo a realização periódica de testes de recuperação das informações.

ORGANIZAÇÕES: AGERIO, AGETRANSP, CEASA, CECIERJ, CEHAB, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRAN, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, IEEA, INEA, IPER/RJ, IRM, ITERJ, IVB, LOTERJ, PESAGRO, PGE, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SECC, SECEC, SEDSODH, SEEDUC, SEELJE, SEGOV, SEIC, SEPLAG, SEPM, SERGB, SES, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

2.16. **RECOMENDAÇÃO:** para que, atendendo às boas práticas e princípios de governança do setor público, assim como às boas práticas de governança e gestão de TI elencados na Norma Técnica ABNT ISO/IEC 38.500/2018 e no APO07 – *Managed Human Resources* (Recursos humanos gerenciados – tradução livre) do COBIT 2019 (ACHADO 06):

- Editem e publiquem ato que defina perfis profissionais mínimos para provimento das ocupações de gestão de TI da organização, elencando seus requisitos, atribuições e responsabilidades, atentando para a necessidade de que sejam revisados periodicamente;

- Elaborem processo formal de recrutamento baseado nos perfis definidos;
- Definam e gerenciem as habilidades e competências necessárias para os recursos humanos de TI, verificando regularmente se o pessoal possui as competências para cumprir suas funções com base em sua capacitação, treinamento e/ou experiência;
- Assegurem que essas competências estejam sendo mantidas, utilizando programas de qualificação e certificação quando apropriado;
- Forneçam aos colaboradores aprendizado contínuo e oportunidades para manterem seus conhecimentos, habilidades e competências em um nível necessário para alcançar os objetivos da área de TI da organização.

ORGANIZAÇÕES: AGENERSA, AGETRANSP, CEASA, CECIERJ, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GSI, IASERJ, IEEA, INEA, IO, IPER/RJ, IRM, ITERJ, IVB, JUCERJA, LOTERJ, PESAGRO, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAP, SEAPPA, SEAS, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV, SEPLAG, SEPM, SERGB, SES, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO, UENF, UERJ.

2.17. **RECOMENDAÇÃO:** para que, atendendo às boas práticas e princípios de governança do setor público, assim como às boas práticas de governança e gestão de TI elencados no APO07 – *Managed Human Resources* (Recursos humanos gerenciados – tradução livre) do COBIT 2019 (ACHADO 06):

- elaborem estudos a fim de avaliar a estrutura de recursos humanos dos setores de TI, verificando, se as atividades ligadas ao planejamento estratégico de TI, à coordenação, à fiscalização e ao controle das ações do setor são executadas por servidores do

quadro permanente de pessoal, com vistas a promover ajustes no quadro funcional e a minimizar a dependência a agentes externos da Administração em papéis sensíveis da área de TI.

ORGANIZAÇÕES: AGENERSA, AGETRANSP, CASERJ, CEASA, CENTRAL, CEPERJ, CGE, CODERTE, CODIN, DEGASE, DER/RJ, DETRO, DRM, EMATER, EMOP, FAETEC, FAPERJ, FIA/RJ, FIPERJ, FLXIII, FMIS, FS, FSC, FTMRJ, FUNARJ, GVG, IASERJ, IEEA, IRM, ISP, ITERJ, IVB, LOTERJ, PESAGRO, PROCON, RIOPREVI, RIOTRILH, RJPREV, SEAPPA, SEAS, SECC, SECEC, SECTI, SEDEC, SEDSODH, SEEDUC, SEELJE, SEFAZ, SEGOV, SEPLAG, SEPM, SERGB, SES, SETD, SETRAB, SETRANS, SETUR, SUDERJ, TURISRIO.

3. ARQUIVAMENTO do presente processo.

CAS-TI, 28/12/2023

AUGUSTO CÉSAR BENVENUTO DE ALMEIDA
Analista de Controle Externo
Matrícula 02/004823

JOÃO PAULO DE FREITAS RAMIREZ
Analista de Controle Externo
Matrícula 02/004820

Senhor Coordenador

O presente relatório foi objeto de supervisão conforme as disposições da Portaria SGE nº 05/2019 e material armazenado nos assentamentos internos desta Coordenadoria, estando, portanto, **APROVADO** por esta supervisão e encaminhado à sua apreciação para adoção das medidas cabíveis.

CAS-TI, 28/12/2023

BRUNO MATTOS SOUZA DE SOUZA MELO
Supervisor
Matrícula 02/004258

Sra. Subsecretária-Adjunta da SUB-CIDADANIA,

Após revisão, nos termos do Manual de Auditoria Governamental do TCE-RJ, aprovado pela Resolução nº 373, de 16.06.21, manifestamo-nos DE ACORDO.

CAS-TI, 28/12/2023

ALBERTO DE FONTES TAVARES NETO
Coordenador
Matrícula 02/004260

DE ACORDO.

Ao **CAP/NDP**, em prosseguimento,



Assinado Digitalmente por: ANA MARIA FURBINO
BRETAS BARROS
Data: 2023.12.29 11:09:08 -03:00
Razão: Processo 109009-4/2023
Local: TCERJ



Assinado Digitalmente por: ALBERTO DE FONTES
TAVARES NETO
Data: 2023.12.28 21:27:59 -03:00
Razão: Processo 109009-4/2023
Local: TCERJ



ANA MARIA FURBINO BRETAS BARROS
Subsecretária-Adjunta
Matrícula 02/004253



Assinado Digitalmente por: BRUNO MATTOS
SOUZA DE SOUZA MELO
Data: 2023.12.28 18:50:03 -03:00
Razão: Processo 109009-4/2023
Local: TCERJ



Assinado Digitalmente por: AUGUSTO CESAR
BENVENUTO DE ALMEIDA
Data: 2023.12.28 18:33:24 -03:00
Razão: Processo 109009-4/2023
Local: TCERJ